

ANNEXES DE PREUVES

Bloc 2

Preuves sélectionnées, livrables d'évaluation et documentation d'exploitation complète - hors limite des 30 pages du dossier

Code source public : <https://github.com/Kevinmrgt/aiSport>

Application web : <https://ai-sport-web.vercel.app>

Pièce	Objet
B2-A19	Tests d'intégration sur PostgreSQL 16 réel
B2-A20	Navigation publique, reflow, clavier et axe
B2-A22	Construction Docker Node 24 et exécution non-root
B2-A25	Recette métier authentifiée et corrections
B2-A26	Playwright OAuth réel et stockage hors Git
B2-A27	Correction de l'audit des dépendances
B2-A28	Baseline main, CI, CD, OAuth et couvertures
B2-A29	Performance des healthchecks de production
B2-A30	Prototype final desktop/mobile et axe privé
B2-A31	Couverture autonome du package shared
B2-A34	Recettes métier finales et parcours journalisé
B2-A35	Recettes sécurité finales OWASP et navigateur
B2-A36	Audit accessibilité final public et privé
B2-A37	Zoom natif, contrastes et contre-recette
B2-A38	Preuve négative dynamique du blocage CI vers CD
B2-A39	Correction des dépendances et audit de sécurité rc.4
B2-A40	Audit sémantique authentifié et contre-recette rc.4
B2-A41	Parcours réel NVDA et contre-recette rc.5
B2-A42	Accès jury sécurisé sans compte Google
LIV-01	Cahier de recettes complet
LIV-02	Plan de correction des bogues complet
LIV-03	Revue de sécurité OWASP A01 à A10 complète
LIV-04	Matrice user stories, écrans, recettes et preuves complète
DOC-01	Manuel de déploiement complet
DOC-02	Manuel utilisateur complet
DOC-03	Manuel de mise à jour complet

Sommaire

B2-A19 - Intégration PostgreSQL réelle du 2026-07-20	4
B2-A20 - Recette navigateur et accessibilité publique du 2026-07-20	6
B2-A22 - Validation Docker réelle du 2026-07-20	8
B2-A25 - Recette authentifiée de production et correctifs	9
B2-A26 - Playwright authentifié avec une session OAuth réelle	11
B2-A27 - Correction de nouveaux avis de sécurité des dépendances	13
B2-A28 - Validation de la baseline de consolidation, CI, CD et OAuth	14
B2-A29 - Mesure de performance des healthchecks de production	15
B2-A30 - Prototype authentifié desktop et mobile	16
B2-A31 - Couverture autonome du package shared	19
B2-A34 - Recettes métier finales - 2026-07-21	20
B2-A35 - Recettes de sécurité finales du 21 juillet 2026	24
B2-A36 - Audit accessibilité final public et authentifié	29
B2-A37 - Zoom natif, contrastes et contre-recette d'accessibilité	33
B2-A38 - Preuve négative CI/CD courante sur branche isolée	38
B2-A39 - Correction des avis de dépendances du 22 juillet 2026	40
B2-A40 - Audit sémantique assisté du 22 juillet 2026	42
B2-A41 - Parcours réel NVDA sur la production	45
B2-A42 - Accès jury sécurisé sans compte Google	49
LIV-01 - Cahier de recettes complet	51
LIV-02 - Plan de correction des bogues complet	63
LIV-03 - Revue de sécurité OWASP A01 à A10 complète	73
LIV-04 - Matrice user stories, écrans, recettes et preuves complète	77
DOC-01 - Manuel de déploiement complet	79

DOC-02 - Manuel utilisateur complet	82
DOC-03 - Manuel de mise à jour complet	86

B2-A19 - Intégration PostgreSQL réelle du 2026-07-20

Portée et traçabilité

- Compétences concernées : C2.2.2 et C2.2.3.
- Environnement : Windows, Docker Desktop Engine 29.3.1, Node 24.14.0, pnpm 11.9.0.
- Image : postgres:16-alpine, digest sha256:57c72fd2a128e416c7fcc499958864df5301e940bca0a56f58fddf30ffc07777.
- Serveur interrogé : PostgreSQL 16.14, base et utilisateur alcide.
- État Git au moment du run : 69b21ef-dirty.
- Cette annexe est une preuve locale de correction. Elle n'est pas une preuve du SHA final et ne remplace pas le run CI à archiver avant remise.

Commandes réellement exécutées

```
docker compose up -d postgres
docker exec alcide-db psql -U alcide -d alcide -Atc 'select version();'
$env:DATABASE_URL='postgresql://alcide:alcide_dev@127.0.0.1:5432/alcide'
pnpm --filter api db:migrate
$env:TEST_DATABASE_URL=$env:DATABASE_URL
pnpm --filter api test:integration:coverage
pnpm --filter api typecheck
```

Les valeurs factices nécessaires à l'interpolation globale de Compose ont été limitées au processus qui démarrait uniquement postgres. Aucun service API ou Web ne les a utilisées et elles n'ont été écrites dans aucun fichier.

Résultats observés

- conteneur alcide-db : running, healthcheck healthy ;
- six migrations Drizzle présentes dans drizzle.__drizzle_migrations ;
- tables présentes : accounts, session_logs, sessions, training_programs, user_settings, users, workouts ;
- index métier présents : workouts_user_created_idx, training_programs_user_created_idx, session_logs_user_completed_idx, session_logs_workout_idx, session_logs_program_idx ;
- première mesure : 3/3 tests réussis, 44,13 % lignes/statements, 42,30 % branches, 53,33 % fonctions ;
- défaut constaté : couverture non majoritaire et repository des réglages à 0 % ;
- correction : cinq tests réels ajoutés pour CRUD, pagination, filtres, agrégats, journal de programme et réglages persistants ;
- première mesure après correction : 8/8 tests réussis en 614 ms ; suite terminée en 3,79 s ;
- couverture après correction : 93,69 % lignes/statements, 80 % branches et 100 % fonctions sur les repositories et le service de journalisation inclus ;
- seuils d'intégration fixés à 80 % lignes/statements, 70 % branches et 90 % fonctions, puis validés par un nouveau run PostgreSQL : 8/8 réussis en 846 ms, suite terminée en 4,93 s ;
- pnpm --filter api typecheck : sortie 0 ;

- nettoyage vérifié après le run : 0 ligne dans users, workouts, training_programs, session_logs et user_settings.

Le rapport généré localement se trouve dans apps/api/coverage/integration/. Ce répertoire de build reste ignoré par Git ; le rapport du SHA final devra être archivé depuis le job CI.

Limites explicites

- le seed n'a pas été exécuté dans ce lot ;
- les images API et Web n'ont pas été construites ou démarrées dans ce lot ;
- aucun parcours OAuth, aucun déploiement et aucun test Neon de production ne sont couverts par cette annexe ;
- le runtime local est Node 24.14.0 ; le job CI Node 24 doit encore être exécuté sur le SHA final.

B2-A20 - Recette navigateur et accessibilité publique du 2026-07-20

Compétences : C2.2.3 et C2.3.1

Version observée : 69b21ef-dirty, version locale 0.13.0-rc.1

Environnement : Windows, Node.js v24.14.0, Playwright 1.59.1

Périmètre réellement exécuté

Les contrôles ont été exécutés dans les navigateurs Playwright Chromium et Firefox. Aucun navigateur manuel n'était disponible dans cette session (aucun navigateur détecté) : aucune inspection via ce navigateur n'est donc revendiquée.

Commandes finales réussies :

```
pnpm exec playwright test tests/e2e/browser-evidence.spec.ts --project=chromium --reporter=list
12 passed (43.1s)
```

```
pnpm exec playwright test tests/e2e/browser-evidence.spec.ts --project=firefox --reporter=list
12 passed (56.6s)
```

Une tentative ciblée supplémentaire sur /dashboard a expiré sans sortie pendant un conflit de build. Elle n'est ni conservée dans le test final ni comptée dans les 24 résultats ci-dessus.

Résultats observés

Pages publiques à 320 × 720 px

Route	HTTP	Largeur document Chromium/Firefox	Erreurs JS	Violations axe ciblées	Capture
/	200	320 / 320 px	0 / 0	0 / 0	PNG Chromium + Firefox
/login	200	320 / 320 px	0 / 0	0 / 0	PNG Chromium + Firefox
/confidentialite	200	320 / 320 px	0 / 0	0 / 0	PNG Chromium + Firefox
/cette-page-nexiste-pas	404 attendu	320 / 320 px	0 / 0	0 / 0	PNG Chromium + Firefox

axe-core a été exécuté avec les tags wcag2a, wcag2aa, wcag21a et wcag21aa. Ce résultat automatisé ne constitue pas un audit RGAA manuel.

Chromium a journalisé une erreur console réseau pour la navigation HTTP 404 : Failed to load resource: the server responded with a status of 404 (Not Found). Firefox n'a pas émis ce message. Les deux JSON bruts conservent cette différence. Aucune pageerror JavaScript n'a été observée.

Clavier et focus

- sur /, /login et /confidentialite, la première touche Tab a focalisé le lien « Aller au contenu principal » dont la cible observée est #main-content ;
- après Entrée, l'élément actif observé est MAIN#main-content dans les deux navigateurs ; Chromium conserve le fragment dans l'URL, Firefox non ;
- le bouton de connexion a été focalisé et son nom accessible vérifié comme « Continuer avec Google » dans les deux navigateurs ;
- le fournisseur OAuth n'a pas été ouvert et aucune connexion n'a été tentée.

Protection sans session

Les routes /generate, /programs, /workouts et /settings ont réellement abouti à `http://localhost:3000/login` avec le titre de connexion attendu, dans Chromium et Firefox. /dashboard reste non exécuté dans cette annexe.

Anomalies détectées et corrections

1. Le lien d'évitement modifiait le fragment sans focaliser systématiquement le contenu. Correction : `tabIndex={-1}` sur `main#main-content`.
 2. La lettre décorative « G » était incluse dans le nom accessible du bouton Google. Correction : `aria-hidden="true"` sur ce décor.
 3. L'inspection des captures à 320 px a révélé un contraste visuellement faible sur la page de connexion et le pied de page. Correction : panneau sombre sur la zone de connexion et textes de pied de page assombris. Une mesure manuelle des ratios reste à effectuer avant de conclure sur le critère RGAA.
- Après ces corrections, les runs finaux séparés Chromium et Firefox sont ceux indiqués plus haut. Le typage Web et le lint Web ont également réussi.

Artefacts bruts

Le dossier `browser-evidence-2026-07-20/` contient 32 fichiers :

- 8 captures PNG, quatre routes dans deux navigateurs ;
- 8 JSON de page avec URL, statut HTTP, viewport, largeur, console, `pageerror` et violations axe ;
- 6 JSON clavier ;
- 2 JSON sur le bouton Google ;
- 8 JSON de redirection sans session.

Non exécuté - ne pas présenter comme preuve

- OAuth Google réel, création de session et déconnexion ;
- pages et composants authentifiés ;
- audit manuel RGAA complet, zoom 200/400 %, lecteur d'écran et technologies d'assistance ;
- mesure manuelle de tous les contrastes ;
- /dashboard dans cette recette instrumentée ;
- production et SHA final immuable.

B2-A22 - Validation Docker réelle du 2026-07-20

Portée et environnement

- Compétences concernées : C2.1.1, C2.1.2, C2.2.4 et C2.4.1.
- Exécution locale réelle sur Docker Desktop Engine 29.3.1.
- État Git : version locale non committée ; preuve à rejouer en CI sur le SHA final.

final.

- Images de base : node:24-alpine.
- Gestionnaire figé : pnpm 11.9.0.

Défaut détecté puis corrigé

Le premier build API a réellement échoué avec `ERR_PNPM_LOCKFILE_CONFIG_MISMATCH` : l'image utilisait pnpm 9 tandis que les overrides étaient définis dans `pnpm-workspace.yaml` selon la configuration pnpm 11 locale. Le dépôt, les images et la future CI ont été alignés sur pnpm 11.9.0, puis les builds ont été entièrement rejoués.

Commandes réellement exécutées

```
docker build --file apps/api/Dockerfile --tag alcide-api:bloc2-local .
docker build --file apps/web/Dockerfile --build-arg NEXT_PUBLIC_API_URL=http://localhost:3001 --tag alcide-web:bloc2-local .
docker compose --profile tools run --rm migrate
docker compose --profile tools run --rm seed
```

Les deux images ont ensuite été démarrées sur le réseau Docker local, sur les ports temporaires 3101 et 3100, puis arrêtées après les sondes.

Résultats observés

Contrôle	Résultat réel
Build API	réussi ; image sha256:01974da1c4dae064c0fb97ebf022ddd9088b3c91a00a3cff254097c47fe955ff
Build Web	réussi ; image sha256:fbbe969a8003a349c4cac088345efb635b7cefc4b3707d826efefe38792ebc3
Runtime API	utilisateur non-root hono ; /health 200 version 0.13.0-rc.1
Readiness API	200 ready ; PostgreSQL ok
Runtime Web	utilisateur non-root nextjs ; /api/health 200 version 0.13.0-rc.1
Pages Web	/confidentialite 200 ; /login 200
Service migrate	sortie 0 ; six migrations déjà appliquées
Service seed	sortie 0 ; un utilisateur de démonstration et trois séances créés
Nettoyage	suppression limitée au UUID fixe du seed ; tables métier revenues à zéro ligne

Limites explicites

- l'exécution part de l'arbre local existant, pas d'un clone vierge ;
- les valeurs OAuth et OpenAI fournies aux conteneurs étaient volontairement invalides et n'ont servi qu'au démarrage/contrôle de présence ; aucun OAuth ni appel OpenAI n'est prouvé ;
- ces images locales ne sont ni les previews Vercel ni la production ;
- le futur job Docker GitHub Actions reste à exécuter sur le SHA final.

B2-A25 - Recette authentifiée de production et correctifs

Date : 2026-07-20

Environnement : production Vercel/Neon

Navigateur : Chrome, session Google ouverte manuellement

Versions observées : 0.13.0-rc.2, puis 0.13.0-rc.3

Périmètre et méthode

La connexion Google a été terminée manuellement, puis la disponibilité de la session a été confirmée. La recette a été conduite dans cet onglet existant, sans lire ni exporter les cookies, le stockage local ou l'identité du compte. Les observations proviennent de l'arbre d'accessibilité, de l'URL, du focus actif et des journaux console du navigateur.

Cette annexe ne vaut pas audit RGAA humain complet et ne transforme pas les contrôles automatisés en preuve manuelle.

Recette métier initiale sur 0.13.0-rc.2

Parcours	Données et actions réellement exécutées	Résultat observé
Session	ouverture de /generate après connexion Google	formulaire privé affiché, navigation privée et bouton de déconnexion présents
Validation séance	soumission vide	deux alertes anglaises String must contain at least 1 character(s)
Séance IA	sport Mobilite - recette RNCP, durée 15 min, objectif et contraintes explicitement marqués comme données de recette	séance créée sous l'ID 2a4d598f-48a7-4068-8219-49ac6660adaa, détail totalisant exactement 15 min
Timer séance	démarrage, attente, pause, attente 2,2 s, reprise, Échap	décompte actif, valeurs inchangées pendant la pause, reprise correcte ; après Échap le focus tombait sur BODY
Filtre séances	inspection du filtre Sport	liste fermée à huit sports alors que la génération accepte un texte libre
Programme IA	même sport de recette, 2 semaines, 2 séances/semaine, 20 min/séance	programme créé sous l'ID e1fdc5af-84fc-4114-8af6-046daadd5f0d, 2 semaines et 4 séances de 20 min
Onglets programme	ArrowRight, Home, End	sélection et focus conformes sur les deux semaines
Séance programme	ouverture de la séance 2-1	détail de 20 min et Timer affichés
Dashboard	lecture des statistiques du compte	données réelles affichées ; variantes Course a pied et Course à pied séparées
Paramètres	lecture puis enregistrement sans changement	fournisseur OpenAI serveur, modèle GPT-5.4 mini, confirmation de sauvegarde
Suppressions	Échap sur la confirmation puis confirmation effective	focus restauré après Échap ; seules les deux ressources de recette ci-dessus ont été supprimées

Aucune erreur console n'a été observée sur ces parcours. Après le nettoyage, la liste comptait de nouveau 12 séances et 4 programmes. Aucune autre donnée du compte n'a été supprimée.

Anomalies issues de cette exécution

ID	Anomalie réelle	Correction
B2-BUG-023	messages Zod anglais dans les deux formulaires français	messages explicites français dans les schémas partagés et HTTP
B2-BUG-024	focus perdu après sortie du plein écran Timer	restauration vers le contrôle Timer vivant après démontage du portail
B2-BUG-025	filtre Sport incompatible avec les sports libres	champ de recherche texte, formulaire GET et requête conservée
B2-BUG-026	variantes typographiques comptées séparément au dashboard	regroupement casse, accents et espaces avant tri et limite

La correction a été livrée par la PR [#34](#), fusionnée dans le SHA applicatif 3a21e3b2b547e99410388d5b83b62df79a436ea8.

Vérifications de 0.13.0-rc.3

Contrôle	Preuve	Résultat
Local	pnpm test, typecheck, lint, build, audit low	155 tests API et 43 tests Web réussis ; aucune vulnérabilité connue
CI de PR	run 29746856421	6 jobs réussis, couvertures, PostgreSQL, E2E public/axe et Docker inclus
CI main	run 29747228594	6 jobs réussis sur le SHA fusionné
CD	run 29747592571	migration, API, Web et smoke tests réussis
Healthchecks	API /health, /health/ready, Web /api/health	HTTP 200, version 0.13.0-rc.3, DB ok, configuration IA ok
Monitoring	run 29748032763	succès et artefact de monitoring produit
Validation séance vide	soumission réelle de /generate	Le sport ne peut pas être vide et L'objectif ne peut pas être vide
Validation programme vide	soumission réelle de /programs/generate	mêmes alertes françaises adaptées aux champs
Filtre libre	valeur Mobilite - recette RNCP, bouton Filtrer	URL ?sport=Mobilite+-recette+RNCP&level=, valeur conservée, état Aucun resultat
Agrégation dashboard	lecture après déploiement	une entrée Course à pied à 2 au lieu de deux variantes à 1
Focus Timer	démarrage d'une séance existante puis Échap	élément actif BUTTON, texte Pause, aria-pressed=true, dialogue fermé
Déconnexion	bouton de déconnexion puis ouverture de /dashboard	redirection finale vers /login, lien Se connecter, aucun bouton de déconnexion

Aucun journal console n'a été observé durant la contre-recette rc.3.

Limites conservées

- les écrans Google de consentement n'ont pas été instrumentés : seuls la session obtenue et son fonctionnement ont été observés ;
- aucun cookie, token ou stockage de session n'a été inspecté ;
- il ne s'agit pas d'une suite Playwright authentifiée réutilisable avec storageState ;
- le lecteur d'écran, le zoom 200/400 %, les ratios de contraste exhaustifs et la recette mobile authentifiée restent à exécuter.

B2-A26 - Playwright authentifié avec une session OAuth réelle

Date : 2026-07-21

Environnement testé : `https://ai-sport-web.vercel.app`

Commit applicatif testé : `d149076e32b6e48c1bd0811060a5ad726451ed83`

Compétences : C2.2.1, C2.2.2, C2.2.3, C2.3.1 et C2.3.2

Objet de la preuve

Cette annexe ferme l'écart « suite Playwright authentifiée avec un `storageState` réel » relevé dans B2-A25. Elle ne repose ni sur une fixture vide, ni sur un cookie fabriqué, ni sur une interception de la route de session.

Une adresse dédiée a été configurée comme identité du compte Google de test. L'étape Google OAuth a été réalisée manuellement dans un profil Chrome temporaire. Le script a ensuite :

1. interrogé réellement `/api/auth/session` ;
2. refusé la capture si l'adresse `Auth.js` différait de l'identité attendue ;
3. conservé uniquement les cookies et origines du domaine exact `ai-sport-web.vercel.app` ;
4. vérifié la présence d'un cookie de session `Auth.js` ;
5. protégé le fichier local par ACL NTFS limitée à l'utilisateur courant ;
6. fermé Chrome et supprimé le profil temporaire.

L'adresse du compte et le contenu du `storageState` ne figurent pas dans Git. L'état local est sous `apps/web/playwright/.auth/`, chemin ignoré par `.gitignore`. Les trois cookies conservés appartenaient au seul domaine Alcide ; aucun cookie Google n'a été écrit dans le fichier.

Anomalies réellement détectées

Le premier workflow lancé sur main, run [29814300540](#), a restauré et utilisé la vraie session mais a terminé en échec : deux assertions anciennes ciblaient un champ interne caché et l'annonceur de route `Next.js` au lieu des éléments fonctionnels attendus.

Ces faux contrôles ont été remplacés par :

- l'inspection des champs visibles du formulaire nommé, après attente de son affichage ;
- des assertions sur les alertes de champ réelles, leur visibilité et leur message français.

Le filtrage du `storageState` possède aussi un test comportemental : un cookie Alcide est conservé, tandis qu'un cookie Google et un sous-domaine trompeur sont rejetés.

Résultats obtenus

Exécution locale contre la production

Commande :

```
pnpm test:e2e:authenticated
```

Résultat observé le 2026-07-21 après la correction des dépendances : **4 tests réussis sur 4** en 13,4 s. Chaque scénario vérifie d'abord que `/api/auth/session` retourne exactement l'identité configurée.

Les contrôles qualité exécutés avant publication ont aussi réussi :

- lint sans erreur ni avertissement ESLint ;
- typecheck des workspaces réussi ;

- 155 tests API et 43 tests Web réussis ;
- 3 tests de politique de session réussis.

GitHub Actions avec GitHub Secrets

- Workflow : E2E authentifié - compte Google dédié
- Run : [29816721099](#)
- Job : Parcours authentifié sans session personnelle
- Commit : d149076e32b6e48c1bd0811060a5ad726451ed83
- Conclusion : **success**

Faits visibles dans le journal du run :

- les secrets E2E_AUTH_EMAIL et E2E_AUTH_STORAGE_B64 sont présents ;
- l'identité est masquée par GitHub dans la sortie ;
- la session est restaurée dans un fichier hors suivi Git ;
- Running 4 tests using 1 worker puis 4 passed (5.5s) ;
- l'étape de suppression de la session du runner réussit ;
- le job complet réussit en 51 s.

Limites conservées

- Le caractère exclusivement dédié du compte relève de sa gouvernance ; le contrôle technique prouve l'identité configurée, pas les usages passés du compte Google.
- La connexion sur les écrans Google reste manuelle, Google refusant le navigateur directement automatisé ; Playwright intervient après le retour OAuth sur Alcide.
- Le workflow couvre quatre scénarios sur /generate. Il ne constitue pas un audit RGAA humain, un test mobile authentifié ou une recette exhaustive de toutes les routes privées.
- La session Auth.js expire et doit alors être recapturée puis remplacée dans GitHub Secrets. Aucun mot de passe Google n'est stocké par le projet.

B2-A27 - Correction de nouveaux avis de sécurité des dépendances

Date : 2026-07-21

Commit testé : d149076e32b6e48c1bd0811060a5ad726451ed83

Compétences : C2.1.2, C2.2.3 et C2.3.2

Anomalie détectée

Le run CI [29815728217](#) a échoué dans le job Security audit avec quatre vulnérabilités high :

- trois branches de brace-expansion, avis

[GHSA-3jxr-9vmj-r5cp](#) ;

- shell-quote 1.8.4, avis

[GHSA-395f-4hp3-45gv](#).

Ces avis de déni de service ont été publiés dans la base GitHub Advisory le 2026-07-20. Ils n'étaient donc pas couverts par la preuve historique B2-A23. Aucune exploitation n'a été observée ; l'échec provient du contrôle bloquant `pnpm audit --audit-level=low`.

Correction appliquée

Les overrides transitifs ont été limités aux plages vulnérables et remplacés par les premières versions publiées corrigées :

Dépendance	Versions corrigées utilisées	Dépendances parentes observées
brace-expansion	1.1.16, 2.1.2 et 5.0.7	minimatch 3, 9 et 10
shell-quote	1.9.0	concurrently et gel/drizzle-orm

La version 1.8.5 de shell-quote, initialement mentionnée par la sortie d'audit comme borne corrigée, n'existe pas dans le registre npm. Elle n'a pas été inventée ni ajoutée au lockfile : la première version corrigée publiée selon l'avis GitHub est 1.9.0.

Vérifications réelles

Les commandes locales suivantes ont réussi :

```
pnpm install --frozen-lockfile
pnpm audit --audit-level=low
pnpm exec concurrently "node --version" "node --version"
pnpm lint
pnpm typecheck
pnpm test
pnpm build
```

Résultats : aucune vulnérabilité connue, smoke concurrently réussi, 155 tests API et 43 tests Web réussis, build de production réussi.

La CI de PR [29816347653](#) a ensuite terminé avec les six jobs verts : audit de sécurité, lint/typecheck, tests et couvertures avec PostgreSQL, E2E public/accessibilité, builds des packages et images Docker.

Limite

Les avis de dépendances évoluent après chaque gel. Cette preuve décrit l'état du registre et du lockfile le 2026-07-21 ; le job bloquant doit rester actif pour détecter les avis ultérieurs.

B2-A28 - Validation de la baseline de consolidation, CI, CD et OAuth

Date : 2026-07-21

Baseline de consolidation avant le correctif final de reflow : 0d5c6b6041333e2b756e59cb5d4440cc7ef7128b

Version annoncée par les services : 0.13.0-rc.3

Baseline canonique après correctif de reflow : b002adb0e0e7d8d85ee493d54879e190d77d2078, CI 29845956008, CD 29846343559

Chaîne réellement exécutée

Contrôle	Exécution	Résultat
CI complète main	run 29832575391	6 jobs réussis
Migration et CD Vercel	run 29832944876	migration, API, Web et smoke tests réussis
Playwright OAuth	run 29833210488	6/6 scénarios réussis en 9,8 s
Playwright accessibilité du lot	exécution locale sur la production 0d5c6b6	33/33 sur 3 pages publiques et 5 privées
Web health	GET https://ai-sport-web.vercel.app/api/health	HTTP 200, status=ok
API readiness	GET https://ai-sport-api.vercel.app/health/ready	HTTP 200, DB ok, IA ok

La CI a exécuté lint, typecheck, tests de politiques, 170 tests API, 55 Web, 14 shared, couvertures, tests PostgreSQL, Playwright public et axe, builds de production, audit de dépendances et images Docker. Le CD n'a démarré qu'après le succès de la CI.

Artefacts de couverture détaillée du run antérieur 29817362423

Les métriques ci-dessous ont été extraites du premier run consolidé et restent conservées pour leur granularité. Le run de consolidation 29832575391 republie les quatre rapports après l'ajout des recettes finales.

Les artefacts suivants ont été listés puis téléchargés depuis GitHub Actions :

- coverage-report-api ;
- coverage-report-web ;
- coverage-report-api-integration ;
- playwright-report.

L'analyse des fichiers lcov.info donne :

Rapport	Lignes	Branches	Fonctions
API unitaire	1 038/1 212 - 85,64 %	197/245 - 80,41 %	62/65 - 95,38 %
Web	2 804/4 061 - 69,05 %	405/520 - 77,88 %	110/136 - 80,88 %
API intégration PostgreSQL	431/460 - 93,70 %	52/65 - 80 %	16/16 - 100 %

Le package shared ne disposait pas encore d'un rapport autonome dans ce run. Cette lacune est corrigée et prouvée séparément dans B2-A31.

Protection de la session OAuth

Le run authentifié restaure le storageState depuis GitHub Secrets, vérifie l'identité Auth.js attendue, n'enregistre aucune session Google et supprime le fichier du runner avant la publication du rapport. Les logs masquent l'identité. Le fichier local reste exclu de Git et protégé par les droits du seul utilisateur Windows.

Cette annexe prouve la chaîne technique observée, sans prouver l'usage historique exclusif du compte Google ni un audit RGAA humain. Elle conserve la preuve de la consolidation 0d5c6b6 : le correctif de reflow postérieur ne modifie ni le protocole CI/CD, ni les couvertures, ni le parcours OAuth. La baseline applicative finalement déployée est b002adb, validée par la CI 29845956008, le CD 29846343559, le zoom natif 16/16 et la contre-recette d'accessibilité 33/33 détaillés dans B2-A37.

B2-A29 - Mesure de performance des healthchecks de production

Date UTC : 2026-07-21 de 09:36:34 à 09:37:07

Poste : environnement Windows, réseau réel

Script : scripts/measure-production-health.mjs

Protocole

Le script a envoyé 50 requêtes séquentielles sans préchauffage et sans authentification vers chacun des trois endpoints. Une réponse n'est valide que si HTTP est réussi et si le JSON contient le statut attendu.

Objectif défini avant lecture des résultats :

- 100 % de réponses HTTP/JSON valides ;
- p95 inférieur ou égal à 1 000 ms par endpoint.

Commande :

```
node scripts/measure-production-health.mjs 50
```

Résultats bruts synthétisés

Endpoint	Succès	Minimum	Médiane	p95	Maximum	Moyenne	Objectif
Web /api/health	50/50	172,00 ms	195,12 ms	508,63 ms	552,93 ms	227,09 ms	atteint
API /health	50/50	167,91 ms	194,00 ms	339,66 ms	491,55 ms	216,42 ms	atteint
API /health/ready	50/50	169,46 ms	191,51 ms	267,11 ms	276,33 ms	199,70 ms	atteint

Total : 150 réponses valides sur 150 et trois objectifs p95 atteints.

Portée et limites

La readiness exerce réellement la connexion PostgreSQL et vérifie la présence de la configuration IA. Cette mesure ne remplace pas un test de charge, ne représente qu'un point réseau et ne mesure pas une génération OpenAI. Les erreurs fournisseur, retries et timeouts sont couverts par les tests API ; une génération réelle de production est consignée dans B2-A25 sans durée chiffrée conservée.

B2-A30 - Prototype authentifié desktop et mobile

Date : 2026-07-21

Production : <https://ai-sport-web.vercel.app>

Session : Auth.js réelle, fichier local hors Git

Méthode

Le script `apps/web/scripts/capture-rncp-prototype.mjs` ouvre Chromium avec le `storageState` Alcide déjà contrôlé, charge les formulaires privés en production et capture uniquement la zone principale. Il n'affiche ni adresse électronique ni donnée personnelle. Le profil mobile utilise un viewport de 390 x 844 px et le script échoue en cas de débordement horizontal.

La suite `apps/web/tests/e2e/generate.spec.ts` a ensuite exécuté six scénarios authentifiés sur la production :

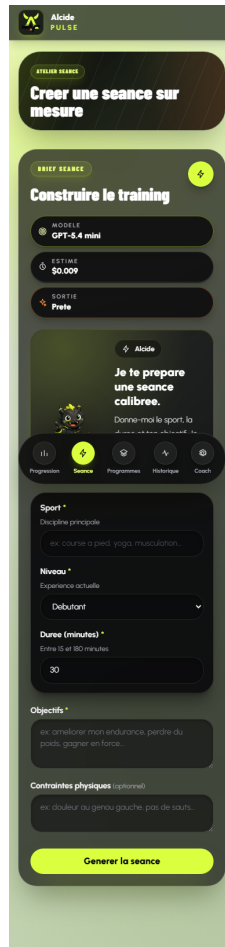
1. formulaire privé accessible après connexion ;
2. labels associés à tous les champs ;
3. erreur explicite sur le sport vide ;
4. erreurs de formulaire annoncées avec `role=alert` ;
5. utilisation à 390 px sans débordement horizontal ;
6. aucune violation axe critique ou sérieuse sur le formulaire privé.

Résultat local : 6/6 en 15,7 s.

Le workflow distant a ensuite exécuté la même suite sur le commit `81b2b0bd6afa0cf3a33cca6d7ee045ae5808709d` : run GitHub Actions [29820498452](#), 6/6 en succès. La session dédiée a été restaurée depuis GitHub Secrets, utilisée uniquement pour le domaine Alcide, puis supprimée du runner.

Captures et empreintes

Capture	Dimensions	SHA-256
génération séance desktop	1440 x 992	A2E6530CA4E189359641F1CA611A4F99A7D0C3F6010E629FC0B81F9AB239443C
génération programme desktop	1440 x 1101	2CB08B244579FCB3546173E10459536819268E43943E8122957E4336F7FD6E97
génération séance mobile	390 x 1634	481517A35F7AD80E0A7B186681A88790F8372CFC046DA5D61AB68002532E79BC



Génération d'une séance à 390 px

Limite

Le contrôle mobile et axe est automatisé. Il ne remplace pas le zoom manuel, les contrastes exhaustifs ou la restitution par un lecteur d'écran.

B2-A31 - Couverture autonome du package shared

Date : 2026-07-21

Commit technique : 81b2b0bd6afa0cf3a33cca6d7ee045ae5808709d

CI de pull request : [run 29819423534](#)

Écart corrigé

Les contrats shared étaient exercés indirectement depuis les tests API, mais ne disposaient ni d'une suite autonome ni d'un rapport de couverture séparé. Le dossier ne pouvait donc pas chiffrer honnêtement ce périmètre.

Harnais ajouté

La suite packages/shared/tests/schemas.test.ts couvre :

- cohérence de la durée détaillée d'une séance ;
- bornes des formulaires séance et programme ;
- numérotation des semaines et séances ;
- nombre de semaines et de séances ;
- durée annoncée et durée détaillée des programmes ;
- références autorisées pour un journal de séance simple ou de programme.

Commande :

```
pnpm --filter shared test:coverage
```

Résultat local et CI

Indicateur	Résultat
Fichiers de test	1/1 réussi
Tests	14/14 réussis
Statements	100 %
Lignes	100 %
Fonctions	100 %
Branches	92,85 %

Le job Unit tests and coverage du run 29819423534 a réussi et a publié l'artefact coverage-report-shared. La CI continue de publier séparément les rapports API, Web et PostgreSQL ; les taux ne sont pas fusionnés artificiellement.

Les fichiers de types TypeScript sans code runtime sont compilés par tsc et ne sont pas inclus dans le taux V8 des schémas exécutables.

B2-A34 - Recettes métier finales - 2026-07-21

Repère de lecture : cette campagne datée du 21 juillet compte 55 tests Web. Deux tests de non-régression ajoutés avec les correctifs rc . 5 portent la baseline finale à 57 tests Web et 241 tests au total.

Compétence : C2.3.1 - cahier de recettes.

Exécution : 21 juillet 2026, de 14 h 23 à 14 h 40 (Europe/Paris).

Révision de départ : bac3b916770cabbb92e3cda0d58ac3ed7e5e119.

Baseline du lot de recettes métier testée et déployée : correctifs fusionnés par la PR 43 dans

0d5c6b6041333e2b756e59cb5d4440cc7ef7128b, puis CI 29832575391, CD

29832944876 et E2E OAuth 29833210488 réussis.

Baseline canonique après le correctif de reflow, sans modification de ces règles métier :

b002adb0e0e7d8d85ee493d54879e190d77d2078, CI 29845956008, CD 29846343559.

Référence : résultats datés et révisions indiquées dans chaque partie.

Le SHA effectivement archivé est porté par le manifeste du paquet de remise.

1. Environnements et données

Couche	Environnement réellement utilisé
API/Web local	Windows, Node 24.14.0, pnpm 11.9.0, Vitest et build Next.js
PostgreSQL	conteneur local postgres:16-alpine, base de test sur localhost:5432
Parcours authentifié	https://ai-sport-web.vercel.app, Chromium Desktop Chrome, session OAuth réelle dédiée et non versionnée
Identité	l'adresse du compte de recette a été dérivée de /api/auth/session pour vérifier la session, sans être imprimée dans les sorties

Les tests PostgreSQL créent deux comptes aléatoires et les suppriment en fin de suite. Le parcours de production utilise uniquement le compte OAuth de recette.

2. Anomalies corrigées pendant la recette

CR-038 - modèle OpenAI non autorisé accepté

L'API acceptait toute chaîne commençant par gpt -, alors que l'interface ne propose que trois modèles. Un appel direct pouvait donc persister une valeur non autorisée.

Correctif dans apps/api/src/controllers/settings.controller.ts :

- liste fermée gpt-5.4-mini, gpt-5.4, gpt-5.5 ;
- validation Zod avant tout appel au repository ;
- repli sur gpt-5.4-mini à la lecture d'une ancienne valeur inconnue ;
- test HTTP : réponse 400 BAD_REQUEST et zéro appel à upsertSettings.

CR-030/CR-034 - revalidation de la page courante après journalisation

Une tentative de production a montré que la revalidation de la page Timer pouvait remonter le composant avant que la confirmation de sauvegarde reste visible. La séance et le programme ne changent pas lors de la création d'un journal ; seule la donnée du dashboard doit être invalidée.

Correctif dans les deux pages de séance :

- conservation de revalidatePath('/dashboard') ;
- suppression de la revalidation de la page Timer courante ;
- conservation de la revalidation de la fiche programme parente pour une séance

issue d'un programme.

3. Résultats par scénario

ID	Exécution et preuve	Résultat
CR-013	simulations OpenAI 429, 503 et timeout de 45 000 ms ; test HTTP 503, absence d'appel à createWorkout ; test UI du message et de la réutilisation du formulaire	Réussi sur la version testée par simulation déterministe
CR-018	page 2/2 rendue côté Web ; paramètres page=2, limit=1 et userId transmis ; PostgreSQL réel avec trois programmes du propriétaire et un programme d'un autre compte	Réussi, pagination et isolation confirmées
CR-021	suppression programme en erreur 500 ; message conservé par l'API et confirmation UI maintenue ouverte avec alerte	Réussi
CR-030	création HTTP d'un journal avec durée active 487 s ; PostgreSQL réel ; parcours production Timer puis enregistrement	Réussi
CR-034	note facultative normalisée puis stockée sous l'identité authentifiée ; page Confidentialité vérifiée ; note de recette saisie en production	Réussi
CR-035	annulation, Échap, restauration du focus et panne API testés pour une séance ; confirmation maintenue ouverte	Réussi
CR-037	changement local autorisé ; en production, changement, rechargement et lecture de la valeur persistée, puis restauration de la valeur initiale dans un bloc finally	Réussi, aucun réglage temporaire laissé
CR-038	valeur gpt-modelle-interdit envoyée à l'API locale testée	Réussi : 400, aucune persistance
CR-040	dashboard rendu avec zéro séance et zéro journal	Réussi : état « Aucune activité encore », explication et CTA /generate
CR-041	rendu de totaux connus (4, 3, 1 h 30, effort 6.5/10), agrégation sport ; PostgreSQL réel isolé ; production après journalisation	Réussi
CR-065	session OAuth validée, page Programmes ouverte, séance existante ouverte, toutes les phases Timer passées, effort/feedback/note saisis, journal sauvegardé puis dashboard relu	Réussi : compteur « Terminé » de 3 à 4

4. Commandes et sorties conservées

Les commandes ci-dessous ont été lancées avec le runtime Node fourni par l'espace de travail. Aucun secret ni cookie n'a été affiché.

Tests ciblés métier

```
pnpm --filter api exec vitest run \
  tests/rncp-ai-unavailability-recipes.test.ts \
  tests/rncp-business-recipes.test.ts
```

```
Test Files 2 passed (2)
Tests      9 passed (9)
```

```
pnpm --filter web exec vitest run components/rncp-business-recipes.test.tsx
```

```
Test Files 1 passed (1)
Tests      9 passed (9)
```

Suites complètes et PostgreSQL

```
pnpm --filter api test

Test Files  19 passed (19)
Tests       170 passed (170)

pnpm --filter web test

Test Files  14 passed (14)
Tests       55 passed (55)

$env:TEST_DATABASE_URL='postgresql://alcide:alcide_dev@localhost:5432/alcide'
pnpm --filter api test:integration

Test Files  1 passed (1)
Tests       8 passed (8)
```

Cette suite PostgreSQL contient notamment : pagination et suppression des programmes sans exposition inter-compte, journalisation d'une source détenue, stockage de painNotes, statistiques exactes et statistiques vides pour l'autre compte.

Les sorties ci-dessus sont celles des suites complètes : 170 tests API et 55 tests Web. Les rapports de couverture correspondants instrumentent 155 tests API et 43 tests Web. Pour PostgreSQL, 8 tests sont instrumentés dans le rapport de couverture ; la recette de sécurité SQL indépendante porte le total RNCP à 9. La suite shared compte 14 tests dans les deux présentations.

Qualité et compilation

```
pnpm typecheck
packages/shared: Done
apps/api: Done
apps/web: Done

pnpm lint
apps/api: Done
apps/web: No ESLint warnings or errors

pnpm build
shared: tsc réussi
api: tsc réussi
web: Next.js - Compiled successfully, 13/13 pages générées
```

Production authentifiée

Commande assainie :

```
PLAYWRIGHT_AUTH_STORAGE=<fichier local ignoré par Git>
E2E_AUTH_EMAIL=<valeur dérivée de la session, non affichée>
E2E_BASE_URL=https://ai-sport-web.vercel.app
pnpm --filter web exec playwright test \
  --config=playwright.rncp-recipes.config.ts
```

Résultats utiles :

```
CR-037 : passed (4.6 s), modèle initial restauré
CR-030/034/041/065 : passed (14.5 s)
[RNCP CR-065] dashboard 3 -> 4; formulaire=confirmation-visible
```

5. Traçabilité honnête des tentatives

Trois exécutions du parcours authentifié ont eu lieu :

1. la première s'est arrêtée avant l'envoi du journal, car le clic Playwright visait l'input radio visuellement masqué ; aucune donnée n'a été créée par cette tentative ;
2. la deuxième a atteint l'envoi, puis l'assertion a échoué parce que `getByRole( ' status ' )` correspondait à trois éléments. Elle a pu créer un journal, mais l'incrément du dashboard n'a pas été mesuré pendant cette tentative ;
3. la dernière exécution a mesuré explicitement 3 -> 4 et constitue la preuve de clôture retenue.

Il n'existe pas d'interface de suppression des journaux. Le journal final - et éventuellement celui de la deuxième tentative - reste donc dans le compte de recette. Les champs contiennent uniquement les marqueurs de test suivants :

- douleur: Recette RNCP : gene legere temporaire, donnee de test.;
- notes: Parcours final automatise du 2026-07-21..

6. Limites

- CR-013 a été couvert par simulations reproductibles 429, 503 et timeout ; aucune panne réelle d'OpenAI n'a été provoquée en production.
- CR-018 et l'isolation multi-compte de CR-041 ont été exécutés sur PostgreSQL local réel, pas avec deux comptes OAuth de production.
- CR-040 est une recette de rendu déterministe avec données vides simulées ; le compte de production n'est plus vide.
- CR-065 valide une session OAuth existante et visite les objets déjà présents ; il ne rejoue pas l'écran Google ni une nouvelle génération OpenAI.
- Le verrouillage CR-038 et les suppressions de revalidation ont été intégrés à

la baseline 0d5c6b6041333e2b756e59cb5d4440cc7ef7128b, puis ont passé la CI 29832575391, le CD 29832944876, les smoke tests et la contre-recette OAuth 29833210488. Le correctif de reflow ultérieur n'a pas modifié ce périmètre métier ; la baseline canonique b002adb a ensuite passé la CI 29845956008 et le CD 29846343559. Leur déploiement final n'est donc plus à confirmer.

7. Pièces techniques

- apps/api/tests/rncp-ai-unavailability-recipes.test.ts
- apps/api/tests/rncp-business-recipes.test.ts
- apps/web/components/rncp-business-recipes.test.tsx
- apps/web/tests/e2e/rncp-recipes-final.spec.ts
- apps/web/playwright.rncp-recipes.config.ts
- apps/api/src/controllers/settings.controller.ts
- apps/web/app/workouts/[id]/page.tsx
- apps/web/app/programs/[id]/sessions/[sessionId]/page.tsx

Conclusion : les onze scénarios du lot métier disposent maintenant d'une preuve exécutée. Les limites de production ci-dessus ne sont pas converties en preuves plus fortes qu'elles ne le sont.

B2-A35 - Recettes de sécurité finales du 21 juillet 2026

Objet et conclusion

Cette annexe consigne la fermeture non destructive des recettes de sécurité CR-042, CR-043, CR-045, CR-046 et CR-047. Elle complète la revue OWASP pour les catégories A02, A03, A04, A05 et A09.

Les contrôles automatisés et les observations de production sont concluants :

- 6/6 tests API en mémoire et 1/1 test d'intégration PostgreSQL réussis ;
- 1/1 test de rendu React hostile réussi ;
- 6/6 tests Playwright réussis dans Chromium et Firefox, puis 3/3 Chromium après le durcissement de la collecte des ressources ;
- 0 vulnérabilité connue retournée par `pnpm audit --audit-level low` ;
- 0 sink DOM dangereux, 0 appel DB non paramétré recherché et 0 clé OpenAI longue dans les fichiers suivis ;
- production Web et API disponibles en HTTPS ;
- CORS de production refusé à une origine hostile et accordé uniquement au front officiel ;
- 0 occurrence des marqueurs de secrets recherchés dans le HTML et les neuf scripts JavaScript chargés par la page de production.

Aucun défaut applicatif nécessitant un correctif de production n'a été trouvé pendant cette campagne. Les ajouts sont des tests de non-régression et la présente preuve. Le risque résiduel principal est la présence de `'unsafe-inline'` dans `script-src` et `style-src` ; `'unsafe-eval'` est bien absent de la CSP de production.

Périmètre et environnement

Élément	Valeur contrôlée
Date et heure de fin des observations	2026-07-21, 14:26 CEST / 12:26 UTC
Révision de base locale	bac3b916770cabbbc92e3cda0d58ac3ed7e5e119 (main)
Baseline de la campagne sécurité	0d5c6b6041333e2b756e59cb5d4440cc7ef7128b, CI/CD réussies
Baseline canonique déployée	b002adb0e0e7d8d85ee493d54879e190d77d2078, CI 29845956008, CD 29846343559
État local	révision de base avec tests et documents RNCP non commités
Système	Windows NT 10.0.22631
Node.js	24.14.0
pnpm	11.9.0
Vitest	3.2.6
Playwright	1.59.1
Navigateurs	Chromium et Firefox fournis par Playwright
PostgreSQL local	16.14 dans le conteneur alcide-db
Web local	Next.js démarré automatiquement sur <code>http://localhost:3000</code>
Web officiel observé	<code>https://ai-sport-web.vercel.app</code>
API officielle observée	<code>https://ai-sport-api.vercel.app</code>

Les tests API de CORS, headers et refus d'authentification utilisent l'instance Hono en mémoire. Le test CR-042 distinct utilise PostgreSQL local, crée un utilisateur jetable, insère et relit la charge via le repository, vérifie la table puis supprime l'utilisateur par cascade. Aucun test n'appelle OpenAI ou OAuth. Les requêtes de production sont uniquement des GET, HEAD ou pré-requêtes OPTIONS.

Le passage de 0d5c6b6 à b002adb corrige uniquement le reflow de composants Web. Il ne modifie pas les contrôles de sécurité testés ici ; la CI canonique a néanmoins rejoué l'ensemble des jobs avant le CD final.

Résultat par scénario

ID	Contrôle exécuté	Résultat observé	Statut
CR-042	Compilation du prédicat Drizzle avec <code>' ; DROP TABLE workouts; --</code>	la requête contient un placeholder \$1, le texte n'apparaît pas dans le SQL et reste dans params	Fermé
CR-042	Insertion et relecture via le repository sur PostgreSQL 16.14	la chaîne exacte est relue dans la colonne et le JSONB ; workouts reste requêtable ; nettoyage vérifié à 0 utilisateur de test	Fermé
CR-042	Validation HTTP Zod avec chaînes SQL-like et dépassement de borne	la chaîne bornée reste une donnée ; un objectif de 501 caractères est rejeté	Fermé
CR-043	Rendu d'un titre <code><script></code> et d'un sport <code></code> dans WorkoutCard	texte visible mais aucun nœud script ou image hostile, aucun attribut d'exécution modifié	Fermé
CR-043	Payload XSS contrôlé dans l'URL, Chromium et Firefox	aucune exécution et aucune réflexion brute dans le HTML	Fermé
CR-045	Inspection HTML et scripts dans deux navigateurs locaux	aucun nom ou valeur sentinelle de secret, aucun motif de clé sk - * longue	Fermé
CR-045	Inspection de la production officielle	HTML de 54 578 caractères et 9 scripts ; 0 OPENAI_API_KEY, SERVICE_SECRET, AUTH_SECRET, AUTH_GOOGLE_SECRET et clé sk - * longue	Fermé
CR-046	Pré-requête locale avec <code>Origin: https://hostile.rncp.test</code>	HTTP 204 sans Access-Control-Allow-Origin	Fermé
CR-046	Pré-requête de production avec une origine hostile	HTTP 204 sans Access-Control-Allow-Origin	Fermé
CR-046	Pré-requête de production avec le front officiel	HTTP 204 avec Access-Control-Allow-Origin: <code>https://ai-sport-web.vercel.app</code>	Fermé
CR-047	Headers effectifs dans Chromium et Firefox	CSP, nosniff, DENY, referrer policy et permissions policy présents	Fermé
CR-047	Headers du Web de production	HSTS, CSP complète, nosniff, DENY, referrer policy et permissions policy présents ; 'unsafe-eval' absent	Fermé avec risque résiduel documenté

Détail des contrôles OWASP

A02 - Défaillances cryptographiques

- Les URL HTTP du Web et de l'API répondent 308 Permanent Redirect vers HTTPS.
- Le Web retourne ``Strict-Transport-Security: max-age=63072000; includeSubDomains; preload``.
- L'API retourne ``Strict-Transport-Security: max-age=15552000; includeSubDomains``.
- Le navigateur ne reçoit aucun des marqueurs de secrets serveur recherchés.
- Le module d'appel API reste importé avec `server-only` et injecte le secret interservice uniquement côté serveur.

A03 - Injection

Le test compile le même prédicat `eq(workouts.sport, valeur)` utilisé par les repositories. Même avec la charge textuelle `' ; DROP TABLE workouts; --`, le texte reste dans le tableau des paramètres et n'est pas concaténé au SQL. Une recherche complémentaire ne trouve ni `sql.raw()` ni `db.execute()` dans `apps/api/src`, et aucun usage de `dangerouslySetInnerHTML`, affectation à `innerHTML`, `eval()` ou `new Function()` dans le code applicatif.

La charge exacte a ensuite été envoyée au PostgreSQL local uniquement comme paramètre du repository Drizzle. Elle a été relue sans altération dans la colonne `sport` et le JSONB. Une requête `SELECT` exécutée après l'insertion a confirmé que `workouts` restait utilisable. Le nettoyage par suppression de l'utilisateur de test a laissé 0 utilisateur `rnnp-security-*` et 0 séance dans cette base locale. Aucune requête de suppression issue de la charge n'a été exécutée et la production Neon n'a pas été modifiée.

A04 - Conception non sécurisée

- Zod revalide les données au contrôleur HTTP, indépendamment de la validation du formulaire Web.
- Les limites sont vérifiées : la charge SQL-like bornée est une donnée valide, tandis qu'un champ dépassant 500 caractères est rejeté.
- Les tests n'appellent aucun fournisseur externe et n'augmentent aucune charge de production.
- Le refus d'accès aux routes privées reste effectué avant tout accès à la base lorsque le secret interservice est invalide.

A05 - Mauvaise configuration de sécurité

Le Web de production retourne notamment :

```
Content-Security-Policy: default-src 'self';
script-src 'self' 'unsafe-inline';
style-src 'self' 'unsafe-inline';
img-src 'self' data: https;;
font-src 'self';
connect-src 'self' https://ai-sport-api.vercel.app;
object-src 'none'; base-uri 'self'; form-action 'self';
frame-ancestors 'none'; upgrade-insecure-requests
X-Content-Type-Options: nosniff
X-Frame-Options: DENY
Referrer-Policy: strict-origin-when-cross-origin
Permissions-Policy: camera=(), microphone=(), geolocation=()
```

L'API de production ajoute entre autres `Cross-Origin-Opener-Policy: same-origin`, `Cross-Origin-Resource-Policy: same-origin, nosniff, HSTS` et `Cache-Control: no-store, max-age=0` sur `/health`.

A09 - Journalisation et surveillance

Le test d'accès privé avec un secret contrôlé invalide obtient HTTP 401. Le serveur émet l'événement `[Auth] Secret interne invalide` ou manquant avec le chemin `/workouts`. Le corps client contient uniquement l'erreur générique `UNAUTHORIZED` et n'expose ni la valeur envoyée, ni le secret attendu, ni une stack trace.

Cette preuve porte sur la génération et la séparation serveur/client des logs. Elle ne revendique pas une plateforme centralisée de corrélation, d'alerte et de rétention des journaux.

Commandes reproductibles et sorties synthétiques

Tests API et rendu React

```
pnpm --filter api exec vitest run tests/rncp-security-final.test.ts
## 1 fichier réussi ; 6 tests réussis

docker start alcide-db
$env:TEST_DATABASE_URL = `
  'postgresql://alcide:alcide_dev@127.0.0.1:5432/alcide'
pnpm --filter api exec vitest run --config vitest.rncp-security.config.ts
## 1 fichier réussi ; 1 test PostgreSQL réussi (4.39s)
docker exec alcide-db psql -U alcide -d alcide -tAc `
  "select count(*) from users where email like 'rncp-security-%@alcide.test';"
## 0
docker exec alcide-db psql -U alcide -d alcide -tAc `
  "select count(*) from workouts;"
## 0 dans cette base locale après cleanup
docker stop alcide-db

pnpm --filter web exec vitest run components/rncp-security-final.test.tsx
## 1 fichier réussi ; 1 test réussi
```

L'avertissement indiquant que OPENAI_API_KEY est absente est attendu dans le test API : aucune route de génération n'est appelée.

Tests navigateur

```
pnpm --filter web exec playwright test tests/e2e/rncp-security-final.spec.ts
## Running 6 tests using 2 workers
## 6 passed (48.9s)

pnpm --filter web exec playwright test `
  tests/e2e/rncp-security-final.spec.ts --project=chromium
## rejeu après attente déterministe des corps de réponse : 3 passed (33.7s)
```

Les trois scénarios sont exécutés une fois sous Chromium et une fois sous Firefox : XSS URL, absence de secrets navigateur et headers/CSP effectifs.

Audit des dépendances et recherches ciblées

```
pnpm audit --audit-level low
## No known vulnerabilities found

rg -n "dangerouslySetInnerHTML|\.innerHTML\s*=\|beval\(|new Function\(" `
  apps packages --glob '!*/.test.*' --glob '!*/.next/**' `
  --glob '!*/node_modules/**'
## aucune occurrence

rg -n "sql\.raw\(|db\.execute\(" apps/api/src --glob '*.ts'
## aucune occurrence

git grep -I -n -E "sk-[A-Za-z0-9_-]{20,}" -- . ':!pnpm-lock.yaml'
## aucune occurrence
```

CORS et headers de production

```
curl.exe -sS -D - -o NUL -X OPTIONS `
  https://ai-sport-api.vercel.app/health `
  -H "Origin: https://hostile.rncp.test" `
  -H "Access-Control-Request-Method: GET"
## 204 ; aucun Access-Control-Allow-Origin

curl.exe -sS -D - -o NUL -X OPTIONS `
  https://ai-sport-api.vercel.app/health `
  -H "Origin: https://ai-sport-web.vercel.app" `
  -H "Access-Control-Request-Method: GET"
## 204 ; Access-Control-Allow-Origin: https://ai-sport-web.vercel.app

curl.exe -sS -D - -o NUL https://ai-sport-web.vercel.app/
curl.exe -sS -D - -o NUL https://ai-sport-api.vercel.app/health
## 200 pour les deux services ; headers décrits ci-dessus
```

Inspection des ressources navigateur de production

```
$base = 'https://ai-sport-web.vercel.app'
$html = (curl.exe -sS "$base/" | Out-String)
$scripts = [regex]::Matches($html, '<script[^>]+src="([^\"]+)"') |
    ForEach-Object { $_.Groups[1].Value } | Sort-Object -Unique
$parts = foreach ($source in $scripts) {
    $url = if ($source.StartsWith('http')) { $source } else { "$base$source" }
    curl.exe -sS $url | Out-String
}
$surface = $html + [string]::Join("`n", $parts)
## HTML_CHARS=54578 ; SCRIPT_COUNT=9
## OPENAI_API_KEY=0 ; SERVICE_SECRET=0 ; AUTH_SECRET=0
## AUTH_GOOGLE_SECRET=0 ; LONG_SK_PATTERN=0
```

Fichiers de preuve ajoutés

- apps/api/tests/rncp-security-final.test.ts ;
- apps/api/tests/rncp-security-final.integration.test.ts ;
- apps/api/vitest.rncp-security.config.ts ;
- apps/web/components/rncp-security-final.test.tsx ;
- apps/web/tests/e2e/rncp-security-final.spec.ts ;
- docs/rncp/bloc2-annexes/B2-A35-recettes-securite-finales-2026-07-21.md.

Limites et risque résiduel

1. La chaîne contenant DROP TABLE est compilée puis persistée comme donnée dans PostgreSQL local. Elle n'est jamais exécutée comme SQL et n'est pas envoyée à Neon ; la preuve ne simule donc aucune attaque sur la production.
2. Le test XSS couvre le sink React d'une carte alimentée par une valeur persistée et la non-réflexion URL dans deux vrais navigateurs. Il ne crée pas de séance en production et n'engendre aucun coût OpenAI.
3. L'inspection de secrets est une recherche déterministe de noms, valeurs sentinelles et formats de clés connus dans les ressources effectivement chargées ; elle ne remplace pas un gestionnaire de secrets ni une rotation.
4. Le refus CORS protège les navigateurs. Un client serveur n'est pas soumis à CORS ; l'authentification interservice reste donc le contrôle principal des routes privées.
5. La CSP autorise encore 'unsafe-inline' pour les scripts et styles requis par l'implémentation Next.js actuelle. Une CSP à nonce ou hash constitue un durcissement futur. En revanche, 'unsafe-eval' est absent en production, object-src vaut 'none' et frame-ancestors vaut 'none'.
6. La preuve A09 vérifie la génération d'un événement et l'absence de fuite client ; l'observabilité centralisée et les alertes restent un chantier MCO distinct.

B2-A36 - Audit accessibilite final public et authentifie

Repère de lecture : les 55 tests Web cités dans cette preuve correspondent à la campagne du 21 juillet. La baseline finale rc.5 ajoute deux tests de non-régression et compte 57 tests Web, soit 241 tests au total.

Date d'execution : 2026-07-21

Application observee : `https://ai-sport-web.vercel.app`

Source locale au debut du controle : `bac3b916770cabbbc92e3cda0d58ac3ed7e5e119`

Contre-recette après déploiement du correctif de reflow : 33/33 et zoom natif

16/16 sur `b002adb0e0e7d8d85ee493d54879e190d77d2078`, après CI 29845956008

et CD 29846343559.

Référence : résultats datés et révisions indiquées dans chaque partie.

Le SHA effectivement archivé est porté par le manifeste du paquet de remise.

Referentiel de travail : RGAA 4.1.2 et WCAG 2.1 A/AA

Statut : preuves renforcees, conforme RGAA exhaustive non revendiquee

Objet et perimetre

Cette campagne ferme les controles automatisables restes ouverts sur un echantillon public et prive : reflow CSS, complete par un zoom Chromium natif a 200 % et 400 % dans B2-A37, parcours clavier, visibilite du focus, contrastes calculables, structure et annonces exposees aux technologies d'assistance.

Pages publiques testees :

- / ;
- /login ;
- /confidentialite.

Pages privees testees avec une vraie session Auth.js locale :

- /dashboard ;
- /generate ;
- /programs ;
- /workouts ;
- /settings.

Un controle navigateur authentifie independant a aussi couvert /programs/generate. Les champs hidden ajoutes par Next.js pour les Server Actions ont ete exclus des controles de labels : ils ne sont ni visibles, ni modifiables, ni atteignables au clavier.

Protection de la session

Le storageState OAuth utilise est un fichier local ignore par Git et non suivi. La configuration dediee desactive traces, captures et videos pour eviter d'enregistrer des cookies ou des donnees de compte. Le test verifie uniquement la presence d'un cookie de session Auth.js sans imprimer son nom complet, sa valeur, l'adresse electronique ou le contenu du fichier.

Methode reproductible

La suite dediee se trouve dans `apps/web/tests/e2e/rncp-accessibility-final.spec.ts` et sa configuration dans `apps/web/playwright.rncp-accessibility.config.ts`. Elle a ete executee avec Chromium et Playwright, en production, avec un worker unique :

```
$env:PLAYWRIGHT_AUTH_STORAGE='<chemin local ignore par Git>'
$env:E2E_BASE_URL='https://ai-sport-web.vercel.app'
pnpm --filter web exec playwright test --config=playwright.rncp-accessibility.config.ts
```

Les controles sont les suivants :

1. reflow a 640 pixels CSS, approximation de mise en page d'un viewport bureau de

1280 pixels zoome a 200 % ;

2. reflow a 320 pixels CSS, approximation de mise en page du meme viewport zoome a 400 % ;

3. parcours Tab complet de toutes les commandes visibles, jusqu'a la sortie du document, avec comparaison a l'inventaire des elements tabulables ;

4. verification de :focus-visible et d'un indicateur perceptible, par contour ou ombre de focus, a chaque etape ;

5. regle color-contrast d'axe sans filtrage par severite, completee par le calcul sRGB du ratio texte/fond du bouton principal opaque ;

6. inspection de l'arbre d'accessibilite Chromium par CDP : RootWebArea, main, navigation et au moins un titre nomme ;

7. declenchement des erreurs de /generate et controle des regions role="alert".

L'inspection CDP est une lecture de l'arbre d'accessibilite. Elle ne constitue pas un test avec un lecteur d'ecran.

Resultats Playwright

Résultat post-déploiement : **33 tests réussis sur 33**, en 58,7 secondes.

Controle	Pages	Resultat
Reflow 640 et 320 pixels CSS	3 publiques + 5 privees	8/8, aucun scrollwidth superieur au viewport
Cycle clavier complet et focus visible	3 publiques + 5 privees	8/8, aucune commande omise, aucun piege detecte
Contrastes	3 publiques + 5 privees	8/8 tests sans violation axe ; mesure representative conforme
Arbre d'accessibilite	3 publiques + 5 privees	8/8, racine, contenu principal, navigation et titre exposes
Erreurs dynamiques	/generate	erreurs de champs exposees avec role="alert"

Le controle navigateur authentifie independant a confirme l'absence de debordement horizontal sur /generate, /programs/generate, /workouts, /dashboard et /settings a 640 x 720 puis 320 x 720 pixels. Les largeurs de document relevees etaient respectivement 625 et 305 pixels, donc inferieures a la largeur utile du viewport. Aucun identifiant HTML duplique n'a ete trouve sur les etats stabilises.

Le rejeu du 2026-07-21 a de nouveau lance les **33 tests** sur la production avec la session OAuth locale et s'est termine avec le code 0. Le zoom natif a ete rejoue separement sur les huit routes : **16/16 mesures**, facteur obtenu 2x puis 4x, aucun debordement horizontal et aucun texte ou controle rogne.

Contrastes mesures

Les ratios sRGB du texte sur le fond opaque du bouton principal sont :

Pages	Ratio minimal mesure	Seuil AA texte normal
/, /login, /confidentialite	17,36:1	4,5:1
/dashboard, /generate, /programs, /workouts, /settings	8,19:1	4,5:1

Axe a mesure en plus 1 texte sur /, 2 sur /login, aucun sur /confidentialite ni sur le dashboard vide, 1 sur /generate, 4 sur /programs, 10 sur /workouts et 1 sur /settings. Aucune violation de la regle color-contrast n'a ete renvoyee.

Chaque page conserve toutefois **une verification axe incomplete** en raison des fonds composites, transparences ou images. Les ratios ci-dessus sont donc des mesures representatives, pas une mesure exhaustive de chaque texte, et ne suffisent pas a declarer une conformite RGAA complete.

Le script `scripts/rncp-a11y-contrast-sampling.ps1` a ensuite regroupe les 416 occurrences par cause axe, couleurs CSS, fond, graisse, corps et seuil WCAG. Il produit **79 signatures de rendu**, dont **34 P1** et **45 P2**, et **166 contextes route-signature**. Ce tri rend la revue humaine bornée et reproductible ; toutes les signatures conservent le statut `human_review_required` tant qu'un operateur n'a pas saisi le ratio mesure, sa decision et la preuve.

Structure et annonces

Les huit pages de l'echantillon exposent dans l'arbre d'accessibilite une racine de document, une region principale, une navigation nommee et au moins un titre. Sur `/generate`, l'envoi du formulaire vide rend visibles plusieurs erreurs, dont `#input-sport-error` et `#goals-error`, chacune exposee avec `role="alert"`.

Le controle independant a detecte deux h1 sur `/generate` et `/programs/generate` : un titre de page et un titre de formulaire. Le titre de chaque formulaire a ete corrige en h2 dans `WorkoutForm.tsx` et `ProgramForm.tsx`. Le test de non-regression `apps/web/components/rncp-accessibility-structure.test.tsx` verifie que les deux titres internes restent de niveau 2 et continuent de nommer leur formulaire. Resultat : **2 tests reussis sur 2**. Cette correction a ete integree a la baseline `0d5c6b6041333e2b756e59cb5d4440cc7ef7128b`, puis verifiee par la CI `29832575391`, le CD `29832944876` et la contre-recette de production `33/33`.

Anomalies et corrections

Identifiant	Observation	Action	Etat
B2-A36-01	Deux h1 sur chacune des pages de generation	Titres internes passes en h2 et test de non-regression ajoute	Corrige et contre-recette en production 33/33
B2-A36-02	Axe ne peut pas calculer les contrastes composites	Audit detaille rejoue : 0 violation, 19 nœuds calcules conformes et 416 nœuds incomplets regroupes en 79 signatures ; échantillonnage pixel du 2026-07-22 : 69 signatures sans alerte, 8 avec alerte et 2 non concluantes ; correctifs locaux à redéployer et contre-recetter	Partiellement couvert, voir B2-A37
B2-A36-03	Aucun lecteur d'ecran reel utilise pendant cette campagne	Narrator disponible, NVDA absent ; grille operateur prete pour une restitution documentee	Ouvert : aucune ecoute realisee
B2-A36-04	Limite historique : le reflow initial reposait uniquement sur des viewports CSS	Audit natif à 200/400 %, détection puis correction des troncatures de métriques et cartes	Clos : correctif <code>b002adb</code> déployé, zoom natif production 16/16, voir B2-A37

Conclusion et limites

Les sous-contrôles reflow, clavier, focus visible, structure de l'arbre et annonces d'erreur sont couverts sur l'echantillon. Les contrastes opaques representatifs respectent largement le seuil AA et aucune violation axe n'est remontee.

Le scenario d'accessibilite ne doit cependant pas etre marque entierement clos tant que les points suivants ne sont pas realises et consignés :

- verification manuelle des contrastes composites signales incomplete ;
- parcours avec un vrai lecteur d'ecran, par exemple NVDA ou Narrator.

En particulier, **aucun test NVDA, Narrator, JAWS ou VoiceOver n'a ete realise** ici. L'arbre d'accessibilite Chromium apporte une preuve structurelle utile, mais ne permet pas de conclure sur la qualite de la restitution vocale ni sur le confort d'usage reel. Le statut global reste donc « conforme RGAA non determinee », sans revendication de conformite exhaustive.

Addendum du 22 juillet 2026

Le rejeu de la production a confirmé **33/33 tests**, **0 violation axe** et le même périmètre de **79 signatures / 166 contextes**. L'échantillonnage des pixels composites, détaillé dans B2-A37, a isolé 14 alertes sur 8 signatures et 2 contextes non concluants. Les contrastes concernés ont été renforcés dans la source locale ; **55/55 tests Web**, le typecheck et le lint réussissent.

Cet addendum ne transforme pas la production observée le 21 juillet : les correctifs devaient encore être déployés puis contre-recettés. La mesure des deux contextes non concluants et les dix parcours Narrator/NVDA restaient ouverts à la date de cette campagne. Le rejeu rc . 4 consigné dans B2-A37 ferme ensuite les 166 contextes composites de l'échantillon, dont le dernier par une borne conservatrice à 15,00:1. La campagne réelle NVDA ultérieure est consignée dans B2-A41 ; aucune validation auditive humaine n'y est revendiquée.

B2-A37 - Zoom natif, contrastes et contre-recette d'accessibilité

Repère de lecture : les 55 tests Web cités dans cette preuve correspondent à la campagne du 21 juillet. La baseline finale rc.5 ajoute deux tests de non-régression et compte 57 tests Web, soit 241 tests au total.

Date d'exécution : 2026-07-21

Production observée : <https://ai-sport-web.vercel.app>

Chromium : 147.0.7727.15

Playwright : 1.59.1

Baseline corrective déployée : ea703aef912ce9e7c49c4c9b7872a5a7b595b666

CI : 29907294766 - succès ; CD Vercel : 29907642144 - succès

Statut historique avant B2-A41 : reflow, focus, onglets et 166/166 contextes

composites décidés. Le parcours réel NVDA ultérieur est consigné dans B2-A41.

1. Rejeu complet public et authentifié

La suite `rncp-accessibility-final.spec.ts` a été rejouée avec une vraie session OAuth locale, ignorée par Git et jamais imprimée dans les sorties.

Contre-recette après déploiement : **33 tests réussis sur 33 en 58,7 secondes** sur les routes suivantes :

- publiques : `/`, `/login`, `/confidentialite` ;
- privées : `/dashboard`, `/generate`, `/programs`, `/workouts`, `/settings`.

Les contrôles couvrent le reflow 640/320 pixels CSS, le cycle clavier, la visibilité du focus, `color-contrast`, l'arbre d'accessibilité Chromium et les alertes du formulaire de génération.

Un nouveau rejeu le 2026-07-21 a lancé les **33 tests** sur la même production et s'est terminé avec le code 0. Les traces, captures et vidéos sont restées désactivées afin de ne pas enregistrer la session.

2. Zoom navigateur natif à 200 % et 400 %

Le test `apps/web/scripts/e2e-native-zoom-audit.mjs` charge une extension Chromium locale réservée à l'audit. Elle applique le zoom natif avec `chrome.tabs.setZoom`, puis contrôle le facteur réellement obtenu, le `devicePixelRatio`, la largeur CSS, les débordements et les éléments textuels rognés. Aucun cookie ni identifiant n'est consigné.

L'audit initial de la production précédente a exécuté **16 mesures sur 16** : huit routes multipliées par les deux niveaux de zoom. Le facteur obtenu valait bien 2 puis 4, sans débordement horizontal global. Le contrôle renforcé a toutefois détecté quatre échecs à 400 % :

Route	Texte visuellement rogné
<code>/login</code>	libellé Séances d'une métrique
<code>/dashboard</code>	libellés Facile et Dosé
<code>/programs</code>	titres longs des cartes programme
<code>/workouts</code>	titres longs des cartes séance

Cause : les composants `MetricPill`, `ProgramCard` et `WorkoutCard` utilisaient la classe Tailwind `truncate`, donc `overflow: hidden` et une ellipse sans retour à la ligne.

Correctif : remplacement de la troncature par `break-words` et un interligne compact. Résultats après correction :

- **55 tests Web sur 55** ;
- typecheck réussi ;
- build Next.js réussi ;
- **6 mesures sur 6** sur les pages publiques de la version locale ;
- **16 mesures sur 16** sur une prévisualisation corrective, sans texte ni

commande rognés ;

- CI 29845956008 entièrement verte sur le commit b002adb ;
- CD Vercel 29846343559 réussi : migration, API, Web et smoke tests ;
- **16 mesures sur 16 sur la production corrigée**, sans prévisualisation, avec zoom Chromium natif à 200 % et 400 % ;
- **33/33 tests d'accessibilité de production** après déploiement.

Les rapports avant correction, de prévisualisation et de contre-recette sont séparés sous tmp/accessibility-final/native-zoom/ afin de ne pas les confondre. Le rapport post-déploiement est native-zoom-production.json.

Le contrôle a été rejoué le 2026-07-21 à 16:56:26Z sur Chromium 147.0.7727.15. Résultat : **16/16 mesures**, facteurs réels 2x et 4x, devicePixelRatio cohérent, contenu principal et titre visibles, aucun débordement horizontal, aucun texte ni contrôle rogné sur les huit routes.

3. Contrastes opaques et composites

Le script apps/web/scripts/e2e-contrast-incomplete-audit.mjs a rejoué la règle axe color-contrast sur les huit routes avec la session réelle :

- **0 violation** ;
- 416 nœuds classés incomplete : 331 à cause de gradients, 69 à cause de pseudo-éléments, 15 textes trop courts et un élément recouvert.

Le rejeu du 2026-07-21 à 16:55:46Z, avec Chromium 147.0.7727.15, confirme le même résultat route par route : **0 violation, 19 nœuds calculés et classés conformes, 416 nœuds incomplete**. Le rapport JSON temporaire ne contient ni cookie ni identité de compte.

Ces 416 occurrences ne sont pas 416 non-conformités : elles indiquent qu'axe ne peut pas calculer automatiquement le fond composite final. Les mesures opaques représentatives déjà consignées dans B2-A36 restent conformes, mais la revue visuelle exhaustive des fonds composites n'est pas déclarée close.

3.1 Préqualification reproductible des composites

Le script scripts/rncp-a11y-contrast-sampling.ps1 transforme le rapport détaillé en une liste de contrôle JSON et CSV :

```
powershell.exe -NoProfile -ExecutionPolicy Bypass -File `
.\scripts\rncp-a11y-contrast-sampling.ps1
```

Le regroupement exclut volontairement le texte littéral, le sélecteur et la route de sa clé. Une signature correspond à une même cause axe, aux mêmes couleurs et fonds CSS, à la même typographie et au même seuil WCAG. Chaque route concernée conserve cependant son propre contexte à vérifier.

Résultat du tri	Valeur
Occurrences axe incomplete	416
Signatures de rendu distinctes	79
Contextes route-signature à revoir	166
Signatures P1	34, soit 74 contextes
Signatures P2	45, soit 92 contextes
Gradients	331 occurrences
Pseudo-éléments	69 occurrences
Textes trop courts pour axe	15 occurrences
Élément recouvert	1 occurrence (Routine active, page /)

Les priorités P1 couvrent notamment les textes atténués au seuil 4,5:1, les pseudo-éléments et l'élément recouvert. P1/P2 ordonnent la revue ; elles ne qualifient pas à elles seules une non-conformité. Les fichiers produits sont

contrast-review-sampling.json et contrast-review-sampling.csv, sous tmp/accessibility-final/contrast/. Ils ne contiennent ni cookie ni identité.

Ce tri ne clôt aucune signature automatiquement. Pour chaque contexte, un opérateur doit mesurer le pixel composite le plus défavorable, renseigner le ratio, la décision et la preuve, puis contre-recetter les corrections éventuelles.

3.2 Requalification automatisée du 22 juillet 2026

Le rapport source, la liste de contrôle et la suite Playwright ont été rejoués le 22 juillet 2026 sur la production encore déployée. Les résultats historiques ont été reproduits exactement : **0 violation axe**, **416 occurrences incomplete**, **79 signatures** et **166 contextes route-signature**. La suite publique et authentifiée a également réussi ses **33 tests sur 33**.

Un contrôle complémentaire, implémenté dans apps/web/scripts/e2e-contrast-composite-sampling.mjs, a comparé en mémoire le rendu de chaque contexte avant et après neutralisation de la couleur du texte. Il estime ainsi les pixels de fond effectivement placés sous les glyphes sans enregistrer de capture ni de donnée de session. Résultat sur les 166 contextes :

Qualification automatisée	Signatures	Contextes
Échantillonnage conforme au seuil	69	150
Alerte de contraste à corriger ou contre-mesurer	8	14
Mesure automatisée non concluante	2	2

Les alertes ont notamment concerné la navigation inactive, les métriques du dashboard, l'introduction sur photographie, le libellé de section placé sur le fond clair et le pied de page transparent de l'accueil. Une correction locale a été appliquée : fonds plus opaques pour l'en-tête, les métriques, les libellés de section, l'introduction et le pied de page ; textes secondaires renforcés dans la navigation, le dashboard et la page de confidentialité. Deux assertions de non-régression ont été ajoutées aux tests de composants et de pages publiques.

Validation locale après correction : **55 tests Web sur 55**, typecheck réussi et lint réussi sans avertissement applicatif. Ces modifications ne sont pas encore qualifiées en production dans cette annexe : le déploiement, le rejeu 33/33 et le nouvel échantillonnage des 79 signatures restent requis.

Cette méthode constitue un tri technique plus fort que la seule couleur CSS, mais pas une mesure normative exhaustive : elle ne permet pas de déclarer la conformité RGAA et les deux contextes non concluants restent à mesurer par un opérateur. Les décisions humaines de contraste doivent conserver le pixel le plus défavorable et la preuve associée.

4. Lecteur d'écran

La détection locale en lecture seule donne l'état suivant :

Outil	Disponibilité constatée	Portée réelle
Narrator	Présent : C:\Windows\System32\Narrator.exe, version 10.0.22621.6133	Lecteur utilisable par un opérateur ; aucune écoute réalisée
NVDA	Absent des emplacements système usuels et non trouvé comme commande	Aucun essai NVDA possible sur ce poste sans installation
Magnifier	Présent, même version de fichier que Narrator	Utile au grossissement visuel, pas à la restitution vocale
Gestion des couleurs Windows	ColorCpl.exe présent	Ne mesure pas le contraste texte/fond d'une page Web

Le contrôle de l'arbre d'accessibilité Chromium est réussi sur les huit routes ; il ne remplace pas un parcours humain capable de juger l'ordre, les annonces et le confort d'écoute.

Aucun test réel NVDA, Narrator, JAWS ou VoiceOver n'était revendiqué au moment de cette annexe. Cette limite historique est remplacée par la campagne réelle NVDA 2026.1.1 de B2-A41 ; aucune validation auditive humaine n'y est inventée.

4.1 Grille Narrator/NVDA prête à exécuter

Préconditions opérateur : navigateur à 100 %, son actif, langue française, session de test sans données sensibles et captures limitées aux anomalies. Avec Narrator, démarrer ou arrêter par Windows + Ctrl + Entrée. Pour chaque ligne, consigner navigateur, lecteur et version, heure, données affichées, résultat, verbatim utile de l'annonce et chemin de preuve.

ID	Parcours et points d'écoute obligatoires	Résultat	Preuve/anomalie
SR-01	/login : langue, titre, ordre, nom/rôle du bouton et absence de répétition parasite	À renseigner	À renseigner
SR-02	/dashboard : lien d'évitement, main, navigation nommée, ordre et lien courant	À renseigner	À renseigner
SR-03	/generate vide : label, aide, requis, valeur et annonce immédiate des erreurs	À renseigner	À renseigner
SR-04	Génération valide : attente, erreur API éventuelle, résultat et maintien du focus	À renseigner	À renseigner
SR-05	Programme, onglets et séance : titres, nom/état, contenu actif et liens distincts	À renseigner	À renseigner
SR-06	/workouts : filtre, nombre ou état de résultats et lecture de la chronologie	À renseigner	À renseigner
SR-07	Timer : commandes, temps sans bavardage et changements status/live	À renseigner	À renseigner
SR-08	/settings : label/champ, option sélectionnée et confirmation ou erreur	À renseigner	À renseigner
SR-09	Suppression : titre, focus initial, piège, retour du focus et annonce finale	À renseigner	À renseigner
SR-10	Déconnexion : nom de l'action, changement de page, focus et titre de destination	À renseigner	À renseigner

Critère de fermeture : les dix lignes doivent être décidées par un opérateur, les anomalies reliées au plan de correction, puis rejouées après correctif. Un simple lancement de Narrator sans écoute consignée ne satisfait pas ce critère.

5. Rejeu post-déploiement rc . 4 du 22 juillet

Après la fusion de la PR #47 et le CD 29907642144, les trois healthchecks ont répondu HTTP 200 en version 0.13.0-rc.4. La suite authentifiée a réussi **33/33** et le zoom natif **16/16**. L'audit contraste conserve zéro violation calculable et 416 résultats incomplète regroupés en 79 signatures et 166 contextes. L'échantillonnage composite post-correction classe **165/166 contextes** en succès automatisé. Le contexte restant est décidé par la borne conservatrice décrite ci-dessous : **166/166 contextes sont décidés sur l'échantillon**.

5.1 Décision du dernier contexte composite

Le contexte A11Y-CONTRAST-060, route /programs, sélecteur .section-kicker, correspond au texte « Cycles guides ». L'échantillonneur avait renvoyé human_review_required avec changedPixels: 0 : il n'avait pas isolé de pixel modifié, ce qui est une absence de mesure et non un échec de contraste.

L'inspection du rendu de production donne les styles calculés suivants :

Propriété observée	Valeur
Texte	Cycles guides
Couleur du texte	rgb(241, 255, 184) soit #F1FFB8
Fond propre	rgba(9, 9, 11, 0.9)
Taille et graisse	10.88px, 900

Propriété observée	Valeur
::before / ::after	content : none pour les deux
Seuil exigé	4,5:1

La cause pseudoContent du regroupement est donc un faux positif de classification : aucun pseudo-contenu n'est rendu. Pour ne retenir aucune hypothèse favorable sur le fond situé sous la couche à 90 %, la borne prend le fond sous-jacent le plus clair possible, le blanc pur. La composition donne un fond maximal proche de rgb(33.6, 33.6, 35.4) et un contraste de **15,0009:1**, arrondi à **15,00:1**. Sur un fond noir, le ratio est 19,74:1. Tout fond sous-jacent possible compris entre ces extrêmes maintient donc un ratio supérieur au seuil de 4,5:1.

Décision : le contexte A11Y-CONTRAST-060 est conforme sur l'état observé et B2-BUG-035 est clos sur l'échantillon. Cette décision technique reproductible ne constitue ni une écoute humaine ni un audit exhaustif de tous les critères RGAA et de toutes les variantes de données.

La contre-recette sémantique confirme aussi le focus sur le champ sport après soumission invalide et la résolution de 3/3 relations aria-controls vers des panneaux présents. Les détails figurent dans B2-A40.

6. Décision de clôture

Le reflow natif a désormais une méthode reproductible. Le défaut découvert est corrigé, déployé et contre-recetté : B2-A36-04 et B2-BUG-034 sont clos. Le parcours avec un lecteur d'écran réel a ensuite été exécuté dans B2-A41 : NVDA 2026.1.1, dix scénarios, 6 conformes, 3 partiels et 1 non conforme. Aucun résultat d'écoute humaine n'est inféré de l'arbre AX, de Speech Viewer ou de la présence de Narrator sur le poste.

La conformité RGAA exhaustive reste non revendiquée.

7. Matrice de décision

Contrôle	Méthode réellement exécutée	Résultat	Décision
Reflow CSS	Playwright à 640/320 pixels	8/8 routes sans débordement	Clos sur l'échantillon
Zoom navigateur réel	Extension locale et chrome.tabs.setZoom à 200/400 %	16/16, aucun rognage	Clos sur l'échantillon
Clavier et focus	Inventaire tabulable et cycle Tab	8/8 routes	Clos sur l'échantillon
Structure exposée	Arbre AX Chromium et tests de titres	8/8 routes et 2/2 tests	Clos structurellement
Contrastes calculables	axe color-contrast et ratios sRGB	0 violation, 19 passes	Clos pour les nœuds calculables
Contrastes composites	axe signale 416 incomplète, regroupés en 79 signatures et 166 contextes	165/166 passent l'échantillonnage ; le dernier est borné à 15,00:1 dans le pire cas	Clos sur l'échantillon
Restitution lecteur d'écran	NVDA 2026.1.1 et Visionneuse de parole, B2-A41	6 conformes, 3 partiels, 1 non conforme	Partiel : correctifs et contre-recette requis

Cette matrice distingue un résultat automatisé positif d'une appréciation humaine. Elle ne transforme ni un résultat incomplète ni l'arbre AX en preuve de conformité avec un lecteur d'écran.

B2-A38 - Preuve négative CI/CD courante sur branche isolée

Date : 2026-07-21

Compétences : C2.1.2, C2.2.4, C2.3.1 et C2.3.2

Scénario : CR-062 - empêcher tout déploiement de production après une CI rouge

Objectif et garde-fous

Le test devait provoquer un échec réel de la CI courante sans pousser de commit défaillant sur main et sans modifier la production. Une branche isolée et une pull request brouillon, explicitement non fusionnable, ont donc été utilisées :

- branche isolée dédiée au test de la règle CD ;
- commit volontairement rouge : ef393f873ce3337c4ba83b84cf75eb5ce07549b4 ;
- pull request brouillon #46, fermée après collecte des preuves ;
- unique défaut injecté : variable TypeScript inutilisée dans un fichier de

preuve temporaire, soit une erreur @typescript-eslint/no-unused-vars.

Le test ne modifie ni la branche main, ni les migrations, ni les secrets, ni les applications de production.

Résultat GitHub Actions

Contrôle	Résultat observé
CI courante	run 29856584668, événement pull_request, conclusion failure
Job fautif	Lint and typecheck 88722310839, échec à l'étape ESLint après installation, build shared et typecheck réussis
Audit sécurité	job 88722310861, succès
Tests unitaires et couverture	job 88722490150, skipped
Build packages	job 88722490096, skipped
E2E smoke et accessibilité	job 88722489720, skipped
Build Docker	job 88722490652, skipped
Runs associés au SHA	un seul run : CI - Alcide 29856584668 ; aucun run CD - Vercel

Le workflow de production écoute uniquement les fins de CI dont la branche de tête est main. Une CI rouge de pull request n'engendre donc aucun workflow CD. Cette absence est un résultat attendu de la politique, pas un job CD présenté à tort comme skipped.

Inventaire Vercel production avant/après

L'inventaire a été lu avec Vercel CLI 54.17.2, filtre --environment production --format json, avant la création de la PR puis après la fin de la CI rouge.

Projet	Dernier déploiement production avant	Dernier déploiement production après	Décision
API ai-sport-api	https://deploiement-anonymise.vercel.app, READY, créé à 1784650955064, SHA b3ca385c0014c6acfd5c29ebbe14fa38ca766c02	valeurs strictement identiques	aucun nouveau déploiement production
Web ai-sport-web	https://deploiement-anonymise.vercel.app, READY, créé à 1784651047559, SHA b3ca385c0014c6acfd5c29ebbe14fa38ca766c02	valeurs strictement identiques	aucun nouveau déploiement production

La vérification concerne la cible production. La preview Web de la pull request est restée distincte et ne constitue pas un déploiement production.

Test automatique de non-contournement

Le script `scripts/cd-workflow-policy.test.mjs` exécute six contrôles :

1. déclencheur `workflow_run` sur CI - Alcide, branche `main`, type `completed` ;
2. absence de `workflow_dispatch` dans le CD ;
3. conditions `conclusion == 'success'` et `ENABLE_GHA_VERCEL_CD == 'true'` sur `migrate-db`, `deploy-api` et `deploy-web` ;
4. checkout du `head_sha` exact de la CI pour chaque job ;
5. simulation `failure`, `cancelled` et `skipped` : décision de déploiement fausse ;
6. tests mutants : détection d'un déclencheur manuel ou du retrait de la gate.

Résultat local : **6/6 réussis**. Le contrôle est ajouté à la CI par la commande `pnpm test:cd-policy`.

Conclusion et portée

CR-062 est fermé par combinaison de preuves :

- chemin positif de production 29845956008 vers 29846343559 ;
- ancienne preuve `main rouge` 28506873066 vers CD 28506912686 `skipped` ;
- CI rouge courante réellement exécutée sur une PR isolée, aucun run CD associé ;
- inventaires Vercel production API/Web inchangés avant/après ;
- six tests de politique sur le YAML courant.

La limite est conservée : aucun commit volontairement rouge n'a été poussé sur `main`, car cette manipulation dégraderait inutilement la branche et pourrait perturber les utilisateurs. Le dossier ne prétend donc pas avoir reproduit ce risque destructif à l'identique.

B2-A39 - Correction des avis de dépendances du 22 juillet 2026

Repère de lecture : le relevé 55 Web / 239 total ci-dessous est celui de la baseline intermédiaire rc . 4. La baseline finale rc . 5 ajoute deux tests Web de non-régression et compte 57 Web / 241 total.

Compétences : C2.1.2, C2.2.3, C2.3.2

Version publiée : 0 . 13 . 0 - rc . 4

Date du contrôle : 2026-07-22

Statut : correction publiée, CI/CD verte et healthchecks de production validés.

Anomalie détectée

Le paquet 0 . 13 . 0 - rc . 3 avait passé l'audit le 21 juillet 2026. Un nouvel audit du lockfile le 22 juillet a cependant terminé avec le code 1 et cinq avis publiés depuis le gel précédent :

- un avis high sur sharp < 0 . 35 . 0, hérité par Next.js ;
- trois avis moderate sur hono < 4 . 12 . 27 ;
- un avis moderate sur @hono/node-server < 2 . 0 . 5.

Cette détection ne rend pas fausse la sortie historique datée du 21 juillet, mais elle rendait obsolète l'affirmation « aucune vulnérabilité connue » pour la version remise le lendemain. Le job d'audit CI étant volontairement bloquant dès le niveau low, une nouvelle CI aurait échoué.

Correction appliquée

Dépendance	Résolution corrigée	Mode de correction
sharp	0 . 35 . 3	override centralisé dans pnpm-workspace . yaml
hono	4 . 12 . 31	dépendance directe API
@hono/node-server	2 . 0 . 11	dépendance directe API avec validation du changement majeur

La version racine, API et Web est passée à 0 . 13 . 0 - rc . 4. Les valeurs de repli des healthchecks et leur test de non-régression ont été alignés. Le lockfile a été régénéré par pnpm 11.9.0. L'override sharp est placé dans pnpm-workspace . yaml, emplacement effectivement pris en charge par cette version de pnpm.

Résultats locaux reproductibles

```
pnpm audit --prod --audit-level=low
No known vulnerabilities found
```

```
pnpm --filter web why sharp
sharp@0.35.3
Found 1 version of sharp
```

```
pnpm --filter api list hono @hono/node-server --depth 0
hono@4.12.31
@hono/node-server@2.0.11
```

La validation complète locale a également réussi :

Contrôle	Résultat
installation pnpm	réussie
lint	réussi
typecheck shared/API/Web	réussi
tests shared	14/14
tests API	170/170
tests Web	55/55
total	239/239

Contrôle	Résultat
build shared/API/Next.js	réussi

Publication et validation distante

La pull request #47 a fusionné la correction dans main. Le SHA applicatif ea703aef912ce9e7c49c4c9b7872a5a7b595b666 a passé les contrôles suivants :

Contrôle distant	Résultat
CI de la pull request 29906947215	6 jobs réussis
CI main 29907294766	6 jobs réussis
CD 29907642144	migration, API, Web et smoke tests réussis
API /health	HTTP 200, version 0.13.0-rc.4
API /health/ready	HTTP 200, base et configuration IA ok
Web /api/health	HTTP 200, version 0.13.0-rc.4

La contre-recette d'accessibilité authentifiée a ensuite réussi à **33/33** et le zoom natif à **16/16** sur la production rc.4.

Portée et limite

Les avis Hono concernaient notamment des modules ou adaptateurs non utilisés directement par Alcide, et les images traitées par Next.js sont des ressources locales. La correction a néanmoins été appliquée sans dérogation, car la règle qualité du projet refuse toute vulnérabilité connue à partir du niveau low.

Cette annexe prouve à la fois la correction locale et son passage réel dans la chaîne CI/CD. Elle ne remplace pas l'écoute humaine au lecteur d'écran. Le dernier contexte composite initialement réservé est décidé séparément dans B2-A37 par une borne conservatrice reproductible.

B2-A40 - Audit semantique assiste du 22 juillet 2026

Repère de lecture : les 55 tests Web cités dans cette preuve ont été exécutés sur rc.4. Les deux tests de non-régression issus de la campagne NVDA portent la baseline finale rc.5 à 57 tests Web et 241 tests au total.

État historique avant B2-A41 : aucun lecteur d'écran réel n'a été utilisé

pendant cette campagne. Le parcours NVDA ultérieur est consigné dans B2-A41.

Compétences : C2.2.1, C2.2.3, C2.3.1, C2.3.2

Application observee : <https://ai-sport-web.vercel.app>

Baseline de production : 0.13.0-rc.4, commit ea703aef912ce9e7c49c4c9b7872a5a7b595b666

CI main : 29907294766 ; CD : 29907642144

Date du controle : 2026-07-22

Statut : structure automatisee controlee ; deux anomalies corrigees et
contre-recettees en production ; restitution vocale reelle non executee.

Objectif

Ce controle complete les campagnes B2-A36 et B2-A37 par une inspection authentifiee de la structure semantique exposee par Chromium. Il porte sur les regions, les titres, les noms accessibles, les relations ARIA, les messages d'erreur, les onglets, les zones dynamiques du Timer et la confirmation de suppression.

L'inspection du DOM et de la projection d'accessibilite permet de detecter des relations absentes ou incoherentes. Elle ne produit pas de restitution audio et ne remplace donc pas un parcours humain avec Narrator, NVDA, JAWS ou VoiceOver.

Perimetre et methode

La session authentifiee a parcouru les huit routes principales suivantes :

Route	Structure attendue	Ecartes releves
/	langue fr, 1 main, 1 h1, lien d'evitement resolu	aucun
/confidentialite	langue fr, 1 main, 1 h1, lien d'evitement resolu	aucun
/dashboard	langue fr, 1 main, 1 h1, lien d'evitement resolu	aucun
/generate	langue fr, 1 main, 1 h1, lien d'evitement resolu	aucun
/programs	langue fr, 1 main, 1 h1, lien d'evitement resolu	aucun
/programs/generate	langue fr, 1 main, 1 h1, lien d'evitement resolu	aucun
/workouts	langue fr, 1 main, 1 h1, lien d'evitement resolu	aucun
/settings	langue fr, 1 main, 1 h1, lien d'evitement resolu	aucun

Sur ces huit routes, l'attribut de langue vaut fr, le contenu principal est identifie par main#main-content, les navigations possedent un nom accessible et aucune image sans alternative n'a ete relevee. Aucun identifiant duplique, aucune commande visible sans nom et aucune relation aria-controls invalide n'ont ete releves sur ces routes de premier niveau.

Trois routes dynamiques ont ensuite ete inspectees sans publier ni supprimer de donnee :

- /programs/{id} ;
- /programs/{id}/sessions/{semaine-seance} ;
- /workouts/{id}.

Les deux pages Timer exposent un contenu principal unique, un titre de niveau 1 et les regions dynamiques attendues pour le temps et les messages de statut. Cette presence est une preuve structurelle ; l'ordre et le confort d'annonce restent a ecouter avec un lecteur d'ecran reel.

Formulaire invalide

Le formulaire vide de generation de seance a produit deux messages `role="alert"`. Les deux champs invalides etaient relies a leurs messages et aucune cible `aria-describedby` ne manquait. Sur la production `rc.3`, le focus est toutefois reste sur le bouton d'envoi au lieu d'etre place sur le premier champ invalide.

Le correctif recherche le premier champ signale par le schema de validation et lui donne le focus. Il est applique aux formulaires de seance et de programme dans :

- `apps/web/components/WorkoutForm.tsx` ;
- `apps/web/components/ProgramForm.tsx`.

Les tests de composants verifient desormais la presence des alertes, l'absence d'appel du service et le focus sur le champ Sport. La suite Web reste verte : **55/55 tests**, typecheck et lint reussis. Apres deploiement, une soumission vide sur `/generate` a produit les deux alertes attendues et place le focus sur `INPUT#input-sport[name="sport"]`. B2-BUG-040 est donc clos en production.

Onglets d'un programme

La page `/programs/{id}` comportait deux onglets dont `aria-controls` designait des panneaux absents du DOM lorsque leur semaine n'etait pas active. Le panneau actif etait utilisable, mais la relation exposee par les onglets etait incomplete.

`ProgramWeekTabs.tsx` rend maintenant un panneau pour chaque semaine. Les panneaux inactifs restent presents avec `hidden` et `tabIndex=-1` ; le panneau actif demeure focalisable. Un test de non-regression verifie que chaque valeur `aria-controls` correspond a un element existant et que le panneau precedent devient masque apres changement d'onglet. Resultat local : **55/55 tests Web**, typecheck et lint reussis.

La contre-recette sur `/programs/{id}` en production `rc.4` a trouve trois onglets et trois panneaux. Les trois valeurs `aria-controls` resolvent un `tabpanel` existant, un seul onglet porte `aria-selected="true"` et les deux panneaux inactifs sont `hidden`. B2-BUG-041 est donc clos en production.

Confirmation de suppression

Le bouton de suppression d'une seance a ete active sans confirmer l'action destructive. Le composant de confirmation obtenu presente :

- un groupe nomme par une cible `aria-labelledby` existante ;
- le focus initial sur le bouton Confirmer ;
- deux choix explicites, Confirmer et Annuler ;
- apres Annuler, la disparition du groupe et le retour du focus sur le bouton

de suppression exact qui l'avait ouvert.

Aucune seance n'a ete supprimee pendant ce controle.

Anomalies et tracabilite

Identifiant	Observation en production rc.3	Correction rc.4	Non-regression	Etat
B2-BUG-040	apres soumission invalide, le focus reste sur le bouton	focaliser le premier controle invalide dans les deux formulaires	assertions Testing Library, CI 29907294766, focus <code>input-sport</code> observe sur rc.4	clos en production
B2-BUG-041	deux onglets referencent des panneaux absents	conserver tous les panneaux dans le DOM et masquer les inactifs	CI 29907294766, 3/3 cibles resolues et panneaux inactifs masques sur rc.4	clos en production

Conclusion et limites

L'audit confirme une base sémantique cohérente sur les huit écrans principaux et les trois routes dynamiques examinées. Il apporte aussi une preuve concrète de la gestion du focus lors de l'annulation d'une suppression et a permis de détecter deux régressions qui ne ressortaient pas des campagnes précédentes.

Les corrections ont passé la CI/CD et la contre-recette de production. Le jeu authentifié a réussi 33/33 tests, le zoom natif 16/16 et l'échantillonnage composite classe 165/166 contextes en succès automatisé ; le dernier est borné à 15,00:1 dans le pire cas, soit 166/166 contextes décidés. Aucune écoute avec un lecteur d'écran n'a été réalisée. Cette annexe renforce donc la preuve d'actions d'accessibilité, sans constituer une déclaration de conformité RGAA exhaustive.

B2-A41 - Parcours réel NVDA sur la production

Date d'exécution : 2026-07-22, de 10:34 à 10:56 UTC

Production observée : <https://ai-sport-web.vercel.app>, version 0.13.0-rc.4

Compétences : C2.2.3, C2.3.1 et C2.3.2

Statut initial : lecteur d'écran réellement exécuté ; 6 scénarios conformes, 3 partiels et 1 non conforme sur rc.4

Statut final : correctifs publiés dans rc.5 et contre-recette NVDA déclarée validée

1. Environnement et méthode

Le contrôle a été exécuté dans une session Windows 11 Pro 23H2, build 22631.5624, avec une vraie session OAuth du compte de recette dédié.

Élément	Version ou état
NVDA	copie portable officielle 2026.1.1
Empreinte de l'installateur	SHA-256 6E0289EB5A3AA076EB97EA99C5D5465CB48B5ECC6A3257DC3D811F881A1747C9
Synthèse	voix française OneCore ; langue NVDA fr
Navigateur principal	Google Chrome 150.0.7871.129
Contrôle complémentaire	Firefox 148.0.2, première restitution réussie mais focus instable dans la session RDP
Trace	Visionneuse de parole NVDA et journal niveau entrée/sortie 12

La Visionneuse de parole affiche le texte effectivement envoyé par NVDA au synthétiseur. Chaque scénario a été déclenché au clavier après placement réel du focus dans le navigateur. Les cookies OAuth sont restés dans le fichier de session ignoré par Git ; aucun cookie, e-mail ou contenu personnel n'est repris ci-dessous.

Narrator a aussi été réellement lancé sur le poste, version de fichier 10.0.22621.6133. Sa commande de récapitulatif n'a produit aucune sortie textuelle exploitable dans cette session RDP. Aucun résultat positif Narrator n'est donc revendiqué.

Cette campagne est un contrôle technique avec un lecteur d'écran réel et une trace textuelle réelle. Elle ne constitue pas une appréciation auditive humaine du confort, du rythme ou de la compréhension. Aucun résultat humain fictif n'a été ajouté.

2. Résultats SR-01 à SR-10

ID	Parcours réellement exécuté	Restitution NVDA observée	Décision
SR-01	/login, navigation, zone principale et action OAuth	« Navigation principale », « Reprendre votre entraînement. région formulaire », « Continuer avec Google bouton »	Conforme sur le parcours
SR-02	/dashboard, lien d'évitement, navigation, région principale et titre	« Aller au contenu principal lien », « Navigation principale navigation région », lien courant « Progression », « Votre progression titre niveau 1 »	Conforme sur le parcours
SR-03	/generate, soumission vide	focus sur « Sport (requis) édition obligatoire entrée invalide », puis deux alertes : sport et objectif vides	Conforme sur le parcours
SR-04	génération valide d'une séance	la séance est créée et la navigation atteint son détail, mais NVDA annonce avant le changement de page « alerte Erreur : NEXT_REDIRECT »	Non conforme : B2-BUG-042
SR-05	liste des programmes, onglets et séances	« Semaines du programme onglet », « Sem. 1 onglet sélectionné 1 sur 3 » ; flèche droite : « Sem. 2 onglet sélectionné 2 sur 3 » ; liens de séances nommés distinctement	Conforme sur le parcours
SR-06	/workouts, filtre et liste	« Niveau liste déroulante Tous les niveaux », « Filtrer bouton », « 9 entraînements sur 13 liste de 9 éléments »	Conforme sur le parcours
SR-07	Timer, démarrage, plein écran, commandes et sortie	étape et titre annoncés ; « Pause bouton bascule enfoncé », « Passer bouton », « Quitter plein écran bouton » ; Échap restitue le focus au bouton Pause ; aucune annonce à chaque seconde	Conforme sur le parcours
SR-08	/settings, modèle et sauvegarde	le libellé, la liste et « Enregistrer bouton » sont restitués ; la sauvegarde réussit et le statut existe dans le DOM, mais aucune annonce spontanée du succès n'est capturée	Partiel : B2-BUG-043
SR-09	suppression de la séance de test	« Confirmer la suppression groupe », focus sur « Confirmer bouton » ; Échap restitue le focus au déclencheur ; la suppression confirmée réussit, mais aucun message final explicite n'est annoncé	Partiel ; amélioration suivie
SR-10	déconnexion	la déconnexion atteint / et l'action « Se connecter lien » est accessible ; aucun titre de destination n'est capturé spontanément pendant la transition	Partiel ; amélioration suivie

La séance créée pour SR-04 a été supprimée pendant SR-09. Une nouvelle lecture authentifiée de /workouts a confirmé l'absence de son déclencheur de suppression (count = 0). Aucune donnée métier durable n'a été conservée par la campagne.

3. Correctifs locaux issus de la campagne

Deux correctifs sont appliqués dans la copie de travail :

1. WorkoutForm et ProgramForm ignorent désormais le signal technique

NEXT_REDIRECT uniquement pour la région d'erreur, après vérification de son digest Next.js, au lieu de l'exposer comme une erreur métier ;

2. la région status de SettingsForm reste montée vide avant la sauvegarde, puis reçoit le texte de confirmation sans déplacement de focus.

Non-régression locale après correction :

- components/forms.test.tsx : **6/6**, avec tests dédiés séance, programme et paramètres ;
- suite complète : **241/241** - shared 14, API 170 et Web 57 ;
- audit de production au seuil low : aucune vulnérabilité connue ;
- typecheck Web : réussi ;
- lint Web : réussi sans avertissement applicatif.
- build complet : réussi.

Ces résultats constituaient l'état local avant publication de rc.5. La suite de cette annexe consigne séparément la CI/CD, les contrôles de production et la validation humaine reçue après déploiement.

4. Trace technique expurgée

Le journal brut de la session NVDA porte l'empreinte SHA-256

4E6A212B4E750799978E6B4E3D0E73B2A74AFDF68959788BC2D17BF104C72CD9. Il n'est pas intégré au paquet : le niveau entrée/sortie a aussi capturé du contenu sans rapport avec la recette lorsque le focus RDP a quitté le navigateur. Les extraits utiles suivants sont reproduits sans cookie, identité de compte ni donnée personnelle :

Ligne du journal brut	Extrait Speaking expurgé	Scénario
1558	Reprendre votre entraînement., région, formulaire, Continuer avec Google, bouton	SR-01
711	Votre progression, titre, niveau 1	SR-02
1169 / 1175	Sport (requis), édition, obligatoire, entrée invalide ; Objectifs (requis), entrée invalide	SR-03
1181	alerte, Erreur : NEXT_REDIRECT	SR-04
1226	Sem. 1, onglet, sélectionné, 1 sur 3	SR-05
1290	9 entraînements sur 13, liste, de 9 éléments	SR-06
1342	bouton, Quitter plein écran	SR-07
1418	Enregistrer, bouton	SR-08
1461	Confirmer la suppression, groupe, Confirmer, bouton	SR-09
1526	Se connecter, lien	SR-10

Cette sélection permet d'auditer les décisions sans publier le journal brut contenant des données hors périmètre. L'absence d'annonce finale sur SR-08 à SR-10 est une observation de la campagne, pas une preuve par absence de ligne.

5. Contre-recette de la version 0.13.0-rc.5

La correction a été fusionnée dans main par la PR #49. La baseline applicative déployée est c63439e8ac8d68efd5ba091211b326ee8575fbba.

Contrôle	Résultat
CI main	run 29930722308, six jobs réussis
CD main	run 29931146789, migration, API, Web et smoke tests réussis
API liveness	HTTP 200, version 0.13.0-rc.5
API readiness	HTTP 200, version 0.13.0-rc.5, base et configuration IA ok
Web health	HTTP 200, version 0.13.0-rc.5
Non-régression	241/241 tests, lint, typecheck, audit low et builds réussis

Après cette publication, l'utilisateur a déclaré : « Pour les tests NVDA j'ai fait les tests de mon côté c'est validé. » Cette déclaration est enregistrée comme une validation utilisateur de la contre-recette NVDA de r c . 5 et rattachée aux correctifs B2-BUG-042 et B2-BUG-043.

Aucun détail supplémentaire de navigateur, version NVDA, verbatim, données ou protocole n'a été fourni pour ce rejeu ; aucun de ces éléments n'est donc revendiqué. Le tableau SR-01 à SR-10 et les transcriptions précédentes restent la trace de la campagne r c . 4 et ne sont pas réécrits comme des résultats r c . 5.

Écart	Décision finale
B2-BUG-042 / SR-04	Clos sur r c . 5 : correctif déployé, tests séance/programme verts et contre-recette NVDA déclarée validée
B2-BUG-043 / SR-08	Clos sur r c . 5 : région vive persistante, test de focus vert et contre-recette NVDA déclarée validée
B2-BUG-044 / SR-09	Ouvert non bloquant : l'ajout d'un message final reste une amélioration P2 ; aucun résultat détaillé r c . 5 n'est inventé
B2-BUG-045 / SR-10	Ouvert non bloquant : une annonce de route dédiée reste une amélioration P2 ; aucun résultat détaillé r c . 5 n'est inventé

6. Décision C2.2.3

Le risque « aucun lecteur d'écran réellement exécuté » est levé : NVDA a été utilisé sur les parcours publics et authentifiés, avec une sortie textuelle traçable. Le test a confirmé les noms, rôles, états, régions, alertes, onglets, commandes du Timer et restitutions de focus sur l'échantillon.

C2.2.3 est **acquise sur le périmètre présenté du Bloc 2** : B2-BUG-042/043 sont déployés et contre-recettés, et les 166 contextes composites sont décidés séparément dans B2-A37. B2-BUG-044/045 restent des améliorations P2 ouvertes et non bloquantes. Cette conclusion ne constitue ni une déclaration de conformité RGAA exhaustive ni une généralisation à tous les lecteurs d'écran et navigateurs.

B2-A42 - Accès jury sécurisé sans compte Google

Objet

Permettre au jury de tester le prototype autonome <https://ai-sport-web.vercel.app> sans utiliser un compte Google personnel, tout en conservant les contrôles d'authentification, d'autorisation et d'isolation des données.

Conception retenue

- ajout d'un fournisseur Auth.js Credentials identifié jury ;
- identité technique stable et e-mail réservé, résolu ensuite en UUID par l'API et PostgreSQL ;
- mot de passe aléatoire remis séparément, seul son hash scrypt salé est configuré dans Vercel ;
- comparaison par `timingSafeEqual`, entrées bornées et message d'échec générique ;
- expiration absolue, kill switch et empreinte de configuration revalidés par le callback JWT à chaque lecture de session ;
- rotation du hash ou de la version de session invalidant les sessions déjà ouvertes ; la version doit aussi être renouvelée avant une réactivation ;
- règle Vercel Firewall active sur le callback jury : 10 tentatives par minute et par IP, puis refus ;
- quota de 30 générations réussies maximum, partagé entre séances et programmes, conservé dans PostgreSQL et incrémenté atomiquement par l'API ;
- refus de la 31e demande en HTTP 429 avec le code `GENERATION_QUOTA_EXCEEDED` ;
- réservation libérée après une erreur IA ou d'enregistrement, mais non remboursée lorsqu'une génération réussie est supprimée ;
- comptes Google non limités par ce quota ;
- parcours Google historique inchangé ;
- édition PDF confidentielle générée hors des chemins suivis par Git.

Il ne s'agit pas d'une route ouverte ou d'un contournement applicatif. Après la connexion, le jury possède une session Auth.js normale. Les pages privées continuent d'appeler `auth()` et l'API continue d'appliquer l'ownership par utilisateur.

Fichiers principaux

- `apps/web/lib/jury-auth.ts` : validation, hash, comparaison et expiration ;
- `apps/web/lib/auth-callbacks.ts` : révocation continue de la session ;
- `apps/web/lib/auth.ts` : fournisseur Credentials ;
- `apps/web/app/(auth)/login/page.tsx` : formulaire accessible ;
- `apps/web/lib/jury-auth.test.ts` et `apps/web/lib/auth.test.ts` : tests unitaires ;
- `apps/web/tests/e2e/auth.spec.ts` : parcours navigateur ;
- `apps/api/src/repositories/generation-quota.repository.ts` : réservation et décrémentation atomiques ;

- apps/api/src/services/generation-quota.service.ts : règles jury/Google et comptabilisation des succès ;
- apps/api/src/routes/generation-quota.routes.ts : état du quota protégé ;
- apps/api/drizzle/0006_spotty_kingpin.sql : persistance PostgreSQL ;
- apps/web/components/GenerationQuotaNotice.tsx : compteur commun accessible ;
- docs/rncp/tools/build_bloc2_jury_pdfs.py : édition privée.

Recettes prévues et résultats

Contrôle	Résultat attendu	Résultat
Identifiants valides	session Auth.js puis /generate	réussi localement et en production sur rc.7
Mauvais identifiant ou mot de passe	refus générique	réussi localement et en production ; aucune session créée
Accès expiré	formulaire absent et session refusée	tests unitaires réussis
Kill switch désactivé	formulaire absent et session existante révoquée	tests callback JWT réussis
Rotation du hash	session existante révoquée	tests callback JWT réussis
Déconnexion	cookie supprimé et route privée redirigée	Playwright local et recette production réussis
Compteur partagé	même solde sur les deux pages de génération	29/30 après un succès sur les deux pages en production
Plafond concurrent	au plus 30 réservations jury acceptées	intégration PostgreSQL concurrente réussie
31e génération	HTTP 429 GENERATION_QUOTA_EXCEEDED	tests API et service réussis
Erreur IA ou DB	réservation rendue au compte jury	tests automatisés réussis
Suppression d'un résultat	aucun remboursement du quota	tests automatisés réussis
Session Google	aucune limite jury appliquée	tests d'autorisation réussis
PDF public	URL présente, aucun secret	gate documentaire réussie sur les deux PDF rc.7
PDF jury privé	URL, mode d'emploi et identifiants présents	hash runtime vérifié avant génération privée

Preuve de production

- commit : d42e7f2c8fc86f26c46f850d32eb748870c6140d ;
- CI : 29994929981, six jobs réussis, 267 tests (14 shared, 179 API, 74 Web) et intégration PostgreSQL concurrente ;
- CD : 29995297354, migration, API, Web et smoke tests réussis ;
- healthchecks : API liveness/readiness et Web en HTTP 200, version 0.13.0-rc.7, base et configuration IA ok ;
- navigateur intégré : connexion valide vers /generate, une génération validée puis compteur à 29/30, même solde affiché sur /programs/generate ;
- console du navigateur : zéro erreur pendant la recette.

Limites et exploitation

L'accès est temporaire et doit être désactivé après l'évaluation. Le PDF privé ne doit pas être publié. La règle de limitation Vercel protège le callback /api/auth/callback/jury, sans remplacer la rotation du secret et de la version de session. Les données créées pendant l'évaluation sont isolées par le compte jury mais restent de vraies données de démonstration ; il faut éviter d'y saisir des informations personnelles ou médicales. Le quota est global pour le compte jury : il ne se réinitialise ni à la déconnexion, ni sur un autre navigateur, ni après suppression d'une donnée créée.

LIV-01 - Cahier de recettes complet

Cahier de recettes - Alcide

Bloc 2 RNCP39583 - C2.3.1, compétence éliminatoire

Version déployée : 0.13.0-rc.7 au 2026-07-23, commit d42e7f2c8fc86f26c46f850d32eb748870c6140d.

Validation de la version : CI 29994929981 ; CD 29995297354.

Le SHA archivé et les empreintes de la remise rc.7 figurent dans le

MANIFESTE.txt généré avec le paquet ; ils ne modifient pas la baseline de

production rc.7.

Règles de preuve

Code	Signification
Exécuté	scénario exécuté sur une version explicitement identifiée, résultat et preuve conservés
Automatisé	test exécuté automatiquement ; l'environnement local, CI ou production doit être précisé
Historique	preuve obtenue sur une ancienne version, à ne pas assimiler à la version finale
À exécuter	scénario préparé mais sans preuve suffisante
Échec	résultat différent de l'attendu, anomalie obligatoire

Une inspection du code n'est pas une exécution. Chaque résultat final doit indiquer date, environnement, navigateur/runtime, données, testeur ou commande, artefact et anomalie éventuelle.

Synthèse de la version déployée

Élément	Valeur
Scénarios de recette comptabilisés	65 ; CR-049 est un risque architectural suivi séparément et n'entre pas dans le dénominateur
Scénarios avec résultat	65 : exécutions, observations ou contrôles automatisés avec une preuve associée
Réserves	CR-055 conserve deux améliorations P2 et une contre-recette NVDA sans transcription détaillée
Échecs fonctionnels finaux	Aucun connu ; B2-BUG-042/043 sont corrigés et validés sur rc.5 ; B2-BUG-044/045 restent des améliorations P2 non bloquantes
SHA testé	baseline déployée d42e7f2c8fc86f26c46f850d32eb748870c6140d
Environnement	baseline rc.7 en CI/production ; trois endpoints de santé en HTTP 200
Artefacts	preuves A20, A25 à A42 ; matrice user stories ; paquet rc.7 généré, inspecté et vérifié

Les 65 scénarios ne sont pas tous des manipulations manuelles : le statut Automatisé - Automatisé désigne un cas réellement exécuté dans l'environnement indiqué. Le statut Exécuté désigne une recette ou une observation conservée. CR-063 est vérifié par la génération du paquet incluant B2-A41, le contrôle visuel des deux PDF, la décompression, le contrôle d'anonymisation et la comparaison des empreintes SHA-256.

Contrôles de la version 0.13.0-rc.7 - 2026-07-23

Contrôle	Résultat
Audit, lint et types	réussis localement et dans la CI 29994929981
Tests	267/267 : shared 14, API 179, Web 74, plus intégration PostgreSQL concurrente
Playwright accès jury	18/18 sur Chromium et Firefox, complétés par la recette navigateur de production
Builds et images Docker	réussis dans les six jobs de CI
CD	29995297354 : migration, API, Web et smoke tests réussis
Santé production	liveness/readiness/Web HTTP 200 en rc.7, DB et IA ok
Recette navigateur jury	connexion valide, 29/30 restantes après une génération, compteur partagé et zéro erreur console
Quota jury	30 succès maximum ; persistance et concurrence vérifiées côté API/PostgreSQL
PDF public / privé	URL publique contrôlée ; secrets exclus des PDF publics

Contrôles de la version 0.13.0-rc.5 - 2026-07-22

Contrôle	Résultat local	Limite
Dépendances résolues	sharp 0.35.3, hono 4.12.31, @hono/node-server 2.0.11	cinq avis nouvellement détectés corrigés dans le lockfile
pnpm audit --prod --audit-level=low	aucune vulnérabilité connue	exécution locale consignée dans B2-A39
Lint et types	verts	localement et dans la CI 29930722308
Tests	241/241 : shared 14, API 170, Web 57	formulaires séance/programme et région vive paramètres inclus
Builds	verts	déploiement CD 29931146789 réussi
Santé production	API liveness/readiness et Web HTTP 200 en rc.5	base et configuration IA ok
Lecteur d'écran	contre-recette NVDA déclarée validée après déploiement	aucune nouvelle transcription détaillée, B2-A41

Matrice fonctionnalités → scénarios → preuves

Fonctionnalité	Scénarios comptés	Résultats	Preuves principales
Authentification et session	CR-001 à CR-009 (9)	9 renseignés	B2-A25, B2-A30, accès jury rc.7, E2E OAuth 29833210488
Génération de séance	CR-010 à CR-015 (6)	6 renseignés	B2-A25, B2-A34, CI applicative
Programmes	CR-016 à CR-021 (6)	6 renseignés	B2-A25, B2-A34, PostgreSQL réel
Séances, Timer et journalisation	CR-022 à CR-035 (14)	14 renseignés	B2-A25, B2-A34, tests API/Web/PostgreSQL
Paramètres et dashboard	CR-036 à CR-041 (6)	6 renseignés	B2-A25, B2-A34
Sécurité fonctionnelle	CR-042 à CR-048 et CR-050 (8)	8 renseignés	B2-A35, audit low local rc.4, B2-A39
Accessibilité	CR-051 à CR-055 (5)	5 renseignés, réserves sur CR-055	B2-A25, B2-A36, B2-A37, B2-A40, B2-A41
Qualité, intégration et déploiement	CR-056 à CR-066 (11)	11 renseignés	B2-A19, B2-A22, B2-A38, B2-A42, manifeste du paquet
Total	65	65 résultats documentés	index des annexes et présent cahier

CR-049 est conservé sous son identifiant pour assurer la traçabilité du risque, mais il ne correspond pas à une fonctionnalité livrée ni à une recette exécutée.

Campagne de fermeture des risques éliminatoires du 2026-07-21

Lot	Résultat exécuté	Preuve
Métier et erreurs	9/9 API ciblés, 9/9 Web ciblés, 170/170 API, 55/55 Web, 8/8 PostgreSQL et parcours production CR-065 réussi	B2-A34
Sécurité	6/6 API, 1/1 PostgreSQL réel, 1/1 rendu XSS, 6/6 Playwright Chromium/Firefox, audit propre et production inspectée	B2-A35
Accessibilité automatisable	33/33 Playwright production authentifiée, 2/2 tests de structure, audit sémantique et parcours réel NVDA sur dix scénarios	B2-A36, B2-A40, B2-A41

Les correctifs CR-038, confirmation de journalisation et hiérarchie des titres ont passé la CI 29832575391, le CD 29832944876, les smoke tests et la contre-recette OAuth 29833210488 sur la baseline antérieure. CR-055 est clos sur l'échantillon : les 166 contextes composites sont décidés, les correctifs B2-BUG-042/043 sont déployés dans rc.5, les healthchecks sont verts et la contre-recette NVDA a été déclarée validée. Cette conclusion reste limitée aux parcours décrits et ne vaut pas déclaration de conformité RGAA exhaustive.

Les rapports de couverture instrumentent 155 tests API, 43 Web, 8 PostgreSQL et 14 shared. La campagne historique B2-A34 comptait 170 tests API, 55 Web et 14 shared. Deux tests Web de non-régression ont ensuite été ajoutés avec les correctifs rc.5 : la CI finale 29930722308 compte donc 170 API, 57 Web et 14 shared, soit 241 tests. Le neuvième contrôle PostgreSQL RNCP est la recette de sécurité SQL exécutée hors du rapport de couverture. Ces présentations mesurent des versions et des périmètres explicitement distincts.

Compléments automatisés du 2026-07-21

Contrôle	Résultat	Preuve et limite
CI du complément	Succès des six jobs	run 29819423534 : lint/typecheck, audit, 155 tests API, 43 Web, 14 shared, couvertures, PostgreSQL, Playwright public, build et Docker
Playwright authentifié local	6/6	session OAuth réelle locale non versionnée ; génération, mobile 390 × 844, débordement horizontal et axe critique/sérieux
Playwright authentifié CI	6/6	run 29820498452 : session dédiée restaurée depuis GitHub Secrets, puis supprimée du runner
Performance production	150/150 réponses valides	B2-A29 : 50 requêtes par endpoint, p95 de 267,11 à 508,63 ms ; mesure ponctuelle, pas un test de charge
Prototype authentifié	Desktop et mobile capturés	B2-A30 ; aucune adresse personnelle ou donnée de recette visible
Couverture shared	14/14	B2-A31 : 100 % lignes/statements/fonctions et 92,85 % branches sur les schémas partagés
CI finale main	Succès des six jobs	run 29930722308 sur c63439e : audit, qualité, 241 tests API/Web/shared, PostgreSQL, Playwright, build et Docker
CD final Vercel	Succès	run 29931146789 : migration, API, Web et smoke tests
Snapshot documentaire v5	Succès CI/CD	b3ca385 : diff applicatif nul depuis b002adb, CI 29847808450, CD 29848187523 ; preuve antérieure, ne remplace pas la contre-recette de b002adb
E2E OAuth post-déploiement	6/6	run 29833210488 : session dédiée restaurée puis supprimée du runner
Accessibilité post-déploiement	33/33 + zoom natif 16/16	production ea703ae : 3 pages publiques et 5 privées ; 166/166 contextes composites décidés ; B2-A40 fermé
Contre-recette NVDA rc.5	Validation déclarée	l'utilisateur déclare avoir effectué et validé les tests ; aucun détail supplémentaire non fourni n'est revendiqué, B2-A41

Ces compléments démontrent le périmètre automatisé exécuté ; ils ne constituent pas une déclaration de conformité exhaustive au RGAA.

Vérification finale automatisée du 2026-07-20

Contrôle	Résultat	Preuve et limite
CI du SHA applicatif	Succès des 6 jobs	run 29747228594 : audit low, lint/typecheck, 198 tests API/Web et couvertures, PostgreSQL, Playwright/axe, packages et Docker
CD du SHA applicatif	Succès	run 29747592571 : migration, API, Web et smoke tests
Production	HTTP 200	API liveness/readiness et Web en 0.13.0-rc.3, DB et configuration IA ok
Monitoring officiel	Succès	run 29748032763 sur le SHA applicatif
Déploiement unique	Une production READY par projet	tentatives Git automatiques API/Web CANCELED, productions GitHub Actions READY

Ces résultats automatisés ne sont pas confondus avec la recette authentifiée manuelle B2-A25. Ils ne valident ni l'inspection interne de la session, ni l'audit RGAA humain complet.

Vérification locale non finale du 2026-07-20

Contrôle	Résultat local	Portée de la preuve
Tests unitaires API	86/86 réussis	version locale historique ; la CI finale exécute 91 tests API
Tests unitaires Web	39/39 réussis	version locale non commitée ; sortie brute finale non archivée
Couverture API	84,97 % lignes/statements ; 80,40 % branches	périmètre unitaire documenté
Couverture Web	68,07 % lignes/statements ; 77,45 % branches	app, components, lib
Playwright public	48/48 réussis, Chromium et Firefox	sans parcours OAuth réel ; rapport brut final non archivé
Recette navigateur publique instrumentée	12/12 Chromium + 12/12 Firefox	version locale 69b21ef-dirty ; 320 px, axe ciblé, console/pageerror, clavier et quatre redirections ; B2-A20
PostgreSQL réel	8/8 réussis ; PostgreSQL 16.14 ; 93,69 % lignes/statements, 80 % branches, 100 % fonctions	version locale 69b21ef-dirty, Node 24.14.0 ; annexe B2-A19 ; job PostgreSQL final réussi dans la CI 29742672052

Ces résultats facilitent la correction, mais ne renseignent pas les totaux de recette du SHA final et ne valent pas validation manuelle ou production.

Authentification et session

ID	Fonctionnalité	Préconditions et actions	Résultat attendu	Preuve prévue	Statut
CR-001	Connexion Google	Sans session, /login, autoriser Google	session créée et redirection vers /generate	recette production + capture	Exécuté - Connexion réalisée ; session privée active observée sur /generate dans B2-A25, écrans Google non instrumentés
CR-002	Route privée sans session	ouvrir /generate, /workouts, /programs, /dashboard, /settings	redirection /login	Playwright public	Exécuté - Redirections publiques automatisées ; /dashboard également observé en production sans session
CR-003	Déconnexion	session active, cliquer Sortir	session supprimée et retour public	recette production	Exécuté sur r.c. 3 : /dashboard redirige ensuite vers /login, B2-A25
CR-004	Navigation selon session	comparer accueil connecté/déconnecté	liens privés uniquement connecté ; aucun faux nom Google annoncé	capture desktop/mobile	Exécuté - États connecté/déconnecté observés ; génération authentifiée capturée en desktop et mobile, B2-A25/B2-A30
CR-005	Connexion jury valide	accès actif, saisir les identifiants temporaires	vraie session Auth.js dédiée puis redirection /generate	tests unitaires + Playwright + recette production	Exécuté localement et en production sur r.c. 7 ; session puis redirection /generate, B2-A42
CR-006	Connexion jury invalide	identifiant ou mot de passe erroné	refus et message générique sans révéler la cause	tests unitaires + Playwright	Automatisé localement ; message accessible role=alert
CR-007	Révocation accès jury	expirer, désactiver ou faire tourner le secret	session existante refusée et retour à /login	tests unitaires callback JWT	Automatisé localement ; expiration absolue et empreinte de configuration
CR-008	Compteur jury partagé	session jury, ouvrir /generate, générer une fois puis /programs/generate	compteur persistant commun aux deux formulaires, de 30 à 29	API/PostgreSQL + recette navigateur production	Exécuté sur r.c. 7 : 29/30 restantes après une validation et même compteur affiché sur les deux pages, sans erreur console
CR-009	Limite jury atteinte	compte jury à 30 succès, demander une 31e génération	refus HTTP 429 GENERATION_QUOTA_EXCEEDED, sans appel IA ni création	tests API + intégration PostgreSQL concurrente	Automatisé sur r.c. 7 : 30 réservations concurrentes acceptées, la suivante refusée ; compteur atomique et persistant

Génération de séance

ID	Fonctionnalité	Préconditions et actions	Résultat attendu	Preuve prévue	Statut
CR-010	Séance valide	compte actif, sport/niveau/durée/objectifs valides	réponse créée, sauvegarde, détail affiché	E2E full-stack + production	Exécuté - Génération réelle r.c. 2, 15 min exactes, puis donnée de recette supprimée ; B2-A25
CR-011	Sport vide	soumettre sans sport	message relié au champ, aucun appel API	test composant/E2E	Exécuté - 64 tests de schémas et soumission r.c. 3 avec message français ; B2-A25
CR-012	Durée hors limites	saisir une durée invalide	validation client et serveur cohérente	tests schéma/formulaire/controller	Automatisé - Automatisé, CI finale verte
CR-013	OpenAI indisponible	simuler timeout/429/5xx	erreur claire, aucune donnée incomplète	test service + E2E erreur	Exécuté - Simulations 429, 503 et timeout, HTTP 503 sans persistance et erreur UI permettant de réessayer ; B2-A34
CR-014	JSON IA invalide puis valide	première réponse invalide, seconde correcte	retry borné puis succès	test service IA	Automatisé - Automatisé, CI finale verte
CR-015	Cohérence durée séance	réponse 30 min avec contenu incohérent	rejet et nouvelle tentative/erreur ; cas répétitions pris en charge	tests contrats/service	Automatisé - Automatisé, CI finale verte

Programmes

ID	Fonctionnalité	Préconditions et actions	Résultat attendu	Preuve prévue	Statut
CR-016	Générer un programme	objectif, niveau, semaines, séances et durée valides	programme créé et affiché	E2E full-stack + production	Exécuté - Génération réelle r.c. 2, 2 semaines/4 séances de 20 min, puis donnée supprimée ; B2-A25
CR-017	Structure programme	provoquer semaines/séances manquantes ou n°99	rejet : quantités et numéros conformes à la demande	tests contrats/service	Automatisé - Automatisé, CI finale verte
CR-018	Lister et paginer	plusieurs programmes du compte	uniquement ses programmes, pagination correcte	test PostgreSQL + E2E	Exécuté - Page 2/2, paramètres API, isolation utilisateur et PostgreSQL réel exécutés ; B2-A34
CR-019	Détail programme	ouvrir un programme détenu	semaines et séances affichées	test service + E2E	Exécuté - Détail réel, 2 semaines et séance 2-1 de 20 min ; B2-A25
CR-020	Onglets semaines	flèches, Home, End, clic	sélection/focus conformes au pattern tabs	test composant + manuel clavier	Exécuté - ArrowRight, Home, End exécutés ; B2-A25
CR-021	Supprimer programme	confirmer puis simuler aussi une erreur	suppression réelle ; erreur visible sans fermer la confirmation	test composant + E2E/API	Exécuté - Suppression production historique et erreur 500 contrôlée avec confirmation maintenue ; B2-A25/B2-A34

Séances, Timer et journalisation

ID	Fonctionnalité	Préconditions et actions	Résultat attendu	Preuve prévue	Statut
CR-022	Liste personnelle	deux comptes avec séances	liste filtrée par utilisateur	test PostgreSQL multi-utilisateur	Automatisé - Automatisé, CI finale verte
CR-023	Accès séance d'autrui	compte A ouvre l'ID du compte B	API 403 sans contenu ; UI n'affiche pas une fausse 404 réseau	test PostgreSQL/API	Automatisé - Automatisé, CI finale verte
CR-024	ID invalide	appeler détail/suppression avec ID non UUID	400, jamais erreur PostgreSQL 500	tests controllers	Automatisé - Automatisé, CI finale verte
CR-025	Démarrer Timer	séance minutée, cliquer démarrer	deadline initialisée, décompte visible	test composant	Exécuté - Décompte réel observé en production et tests verts, B2-A25
CR-026	Pause/reprise	laisser tourner, pause, attendre, reprendre	pause exclue du temps actif et du décompte	test Timer avec horloge simulée	Exécuté - Valeurs stables pendant 2,2 s de pause puis reprise réelle, B2-A25
CR-027	Onglet ralenti	avancer l'horloge de plusieurs secondes	décompte recalé sur deadline, sans dérive cumulative	test Timer	Automatisé - Automatisé, CI finale verte
CR-028	Passage de phase	laisser une phase atteindre zéro	phase suivante annoncée et démarrée	test Timer	Automatisé - Automatisé, CI finale verte
CR-029	Plein écran Timer	ouvrir, Tab/Shift+Tab, Échap	dialogue nommé, focus contenu/restreint puis restauré	test composant + manuel	Exécuté - Défaut reproduit sur rc . 2, corrigé ; focus BUTTON Pause sur rc . 3, B2-A25
CR-030	Fin de séance	terminer et enregistrer effort/feedback	journal créé avec durée active	test composant/service/DB	Exécuté - Durée active 487 s vérifiée localement et journal créé en production ; B2-A34
CR-031	Ownership journal workout	utiliser workout d'un autre compte	403 et aucune insertion	test service + PostgreSQL	Automatisé - Automatisé, CI finale verte
CR-032	Ownership journal programme	utiliser programme d'un autre compte	403 et aucune insertion	test service + PostgreSQL	Automatisé - Automatisé, CI finale verte
CR-033	Métadonnées falsifiées	envoyer titre/sport/durée différents	valeurs serveur dérivées de la ressource détenue	test service + DB	Automatisé - Automatisé, CI finale verte
CR-034	Notes de douleur	enregistrer une note facultative	stockage lié au compte et information confidentialité visible	recette UI + DB	Exécuté - Stockage propriétaire PostgreSQL, page Confidentialité et saisie production vérifiés ; B2-A34
CR-035	Suppression séance accessible	confirmer, annuler, Échap, erreur API	focus géré, annulation sûre, erreur visible	test composant + manuel	Exécuté - Annulation, Échap, restauration du focus et panne API avec dialogue maintenu ; B2-A25/B2-A34

Paramètres et dashboard

ID	Fonctionnalité	Préconditions et actions	Résultat attendu	Preuve prévue	Statut
CR-036	Lire paramètres	compte actif	fournisseur OpenAI serveur et modèle courant affichés	test API/Web + E2E	Exécuté - OpenAI serveur et GPT-5.4 mini observés en production, B2-A25
CR-037	Enregistrer modèle	choisir un modèle autorisé	valeur persistée et confirmation	test controller/DB + E2E	Exécuté - Modèle changé et relu en production, puis valeur initiale restaurée ; B2-A34
CR-038	Modèle non autorisé	envoyer valeur arbitraire	400, aucune persistance	test controller	Exécuté - Défaut reproduit et allowlist API ajoutée ; valeur arbitraire rejetée 400 sans persistance ; B2-A34
CR-039	Panne settings	API indisponible	erreur explicite, pas de faux défaut présenté comme enregistré	test server-api/page	Automatisé - Automatisé, CI finale verte
CR-040	Dashboard vide	aucun journal	état vide compréhensible	test rendu/E2E	Exécuté - État vide déterministe, explication et CTA /generate vérifiés ; B2-A34
CR-041	Dashboard alimenté	plusieurs journaux du compte	totaux/durée/effort/fee dback exacts et isolés	test PostgreSQL + E2E	Exécuté - Totaux déterministes et isolation PostgreSQL, puis compteur production 3 → 4 ; B2-A34

Sécurité

ID	Fonctionnalité	Préconditions et actions	Résultat attendu	Preuve prévue	Statut
CR-042	Chaîne SQL-like	saisir ' ; DROP TABLE workouts ; -- comme texte valide	chaîne traitée comme donnée ; requête paramétrée ; table intacte	test PostgreSQL	Exécuté - Insérée et relue comme donnée sur PostgreSQL 16.14 ; table requêteable et cleanup vérifié ; B2-A35
CR-043	XSS	saisir balise script dans un champ accepté	aucun script exécuté au rendu	Playwright navigateur	Exécuté - Charges script et img onerror inertes en React et Chromium/Firefox ; B2-A35
CR-044	API sans secret	appeler une route privée sans secret	401	test middleware + curl	Automatisé - Automatisé, CI finale verte
CR-045	Secret non exposé	inspecter HTML, JS et réseau navigateur	aucune clé OpenAI ni secret interservice	build + navigateur	Exécuté - HTML et 9 scripts de production inspectés : 0 marqueur de secret ou clé longue ; B2-A35
CR-046	CORS hostile	requête avec origine non autorisée	absence d'autorisation CORS	curl automatisé	Exécuté - Origine hostile refusée localement et en production ; origine officielle seule autorisée ; B2-A35
CR-047	Headers/CSP	inspecter réponse production	headers présents ; unsafe-eval absent en production	test headers/curl	Exécuté - CSP/HSTS/headers contrôlés en production ; unsafe-eval absent, unsafe-inline documenté ; B2-A35
CR-048	Rate limit local	dépasser quota dans un processus	429 et Retry-After	test middleware	Automatisé - Automatisé, CI finale verte
CR-050	Audit dépendances	lancer audit sur lockfile final	aucune vulnérabilité connue au niveau low	B2-A39	Exécuté - r.c.4 : cinq avis corrigés, audit low propre ; lint, types, 239 tests et builds verts localement et en CI ; CD et production vérifiés.

Risque architectural associé - hors comptage de la recette

ID	Risque	État réel	Décision et preuve
CR-049	Le rate limit en mémoire n'est pas global entre plusieurs instances serverless.	Non implémenté et non exécuté avec un store partagé.	Risque accepté pour le prototype ; le 429 local de CR-048 ne prouve pas un quota distribué. Industrialisation : store partagé et test multi-instance.

Accessibilité RGAA 4.1.2 / WCAG 2.1 AA

ID	Fonctionnalité	Préconditions et actions	Résultat attendu	Preuve prévue	Statut
CR-051	Pages publiques	axe complet sur / et /login	aucune violation applicable non traitée	Playwright/axe	Exécuté localement puis en CI finale sur le périmètre public ; ne vaut pas audit RGAA manuel
CR-052	Pages authentifiées	axe sur generate, programmes, listes, détail, dashboard, settings	aucune violation applicable non traitée	Playwright avec vrai storage state	Exécuté - Cinq pages privées auditées sans violation de contraste axe, arbre AX contrôlé ; /programs/generate contre-vérifié ; B2-A36
CR-053	Clavier	parcourir navigation, formulaires, tabs, suppressions, Timer	toutes actions atteignables, ordre/focus cohérents	audit navigateur + tests composants	Exécuté - Cycle Tab complet et focus perceptible sur 3 pages publiques et 5 privées ; annulation de suppression avec restitution du focus ; focus du premier champ invalide et 3/3 relations d'onglets contre-recettés en production ; B2-A25/B2-A36/B2-A40
CR-054	Reflow/mobile	320 px CSS et viewport mobile	aucune perte d'information/action ni scroll 2D injustifié	captures + audit manuel	Exécuté - Reflow 640/320 px sur 3 pages publiques et 5 privées, plus /programs/generate, sans débordement ; B2-A36
CR-055	Zoom/contraste/annonces	zoom 200/400 %, contraste, lecteur d'écran	contenu lisible et annonces compréhensibles	grille RGAA + transcription NVDA	Exécuté - Résultats disponibles sur l'échantillon : rejeu r.c. 4 33/33, zoom 16/16, zéro violation axe et contrastes 166/166 décidés ; campagne NVDA détaillée, correctifs publiés dans r.c. 5, puis contre-recette déclarée validée. Ne vaut pas conformité RGAA exhaustive ; B2-A37/A40/A41.

Qualité, intégration et déploiement

ID	Fonctionnalité	Préconditions et actions	Résultat attendu	Preuve prévue	Statut
CR-056	Tests et couvertures	lancer pnpm test : coverage	API/Web/PostgreSQL/ shared mesurés séparément ; exclusions expliquées	rapports CI	Exécuté - CI 29819423534 verte ; quatre rapports publiés, dont shared 100 % lignes/statements/fonctions
CR-057	PostgreSQL réel	PostgreSQL 16 et migrations, puis tests repositories/ownership sans skip	tests et couverture d'intégration réussis	B2-A19 + rapport CI	Exécuté - 8/8 locaux sur 69b21ef-dir ty, puis job PostgreSQL final vert dans 29742672052
CR-058	Qualité/build	lint, typecheck, build sous Node 24	toutes commandes réussies	logs CI + B2-A39/A41/A42	Exécuté - rc.7 : lint, types, 267 tests et builds verts localement et dans la CI 29994929981
CR-059	Docker	construire API/Web et contrôler la procédure migrate/seed	images Node 24 non-root ; migrate/seed fonctionnels	CI + B2-A22	Exécuté - Images finales construites en CI ; migrate/seed validés localement ; clone vierge non archivé
CR-060	Readiness API	DB/clé disponibles puis indisponibles	200 prêt ; 503 avec dépendance défaillante	tests route + curl	Exécuté - Cas automatisés verts ; readiness production 200, DB/IA ok
CR-061	CI complète	pousser le SHA final	tous les jobs obligatoires verts	run GitHub	Exécuté - Run final 29994929981 réussi sur d42e7f2
CR-062	CD sans contournement	CI échoue puis réussit	aucun déploiement après échec ; déploiement après succès	runs GitHub + B2-A38	Exécuté - Fermé sans toucher à main : CI courante 29856584668 rouge sur PR isolée, quatre jobs aval ignorés, aucun run CD associé et inventaires Vercel production API/Web identiques avant/après ; politique YAML 6/6. Chemin vert 29845956008 → 29846343559. Limite : aucun commit volontairement rouge sur main.
CR-063	Version immuable	construire le paquet depuis un état Git propre et vérifier PDF, source, SHA et empreintes	build refusé si fichiers suivis modifiés ; PDF principal ≤ 30 pages ; livrables de premier niveau présents ; archive et PDF anonymisés ; SHA-256 consignés	build_bloc2_deliv ery_pack.py + manifeste	Exécuté - Vérifié sur rc.7 : paquet généré avec B2-A42 ; limite des 30 pages respectée ; deux PDF inspectés ; anonymisation validée ; ZIP décompressé et empreintes comparées. Le MANIFESTE.txt de la dernière génération fait foi.
CR-064	Production API/Web	déployer le SHA final	liveness/readiness/We b en 200	curl daté	Exécuté - CD finale 29995297354, HTTP 200 rc.7, DB et configuration IA ok

ID	Fonctionnalité	Préconditions et actions	Résultat attendu	Preuve prévue	Statut
CR-065	Parcours post-déploiement	login, séance, programme, Timer, journal, dashboard	parcours complet sans erreur	recette production	Exécuté - Session OAuth, Programmes, Timer, effort/feedback/douleur, journal et dashboard 3 → 4 en production ; B2-A34
CR-066	Comptabilisation du quota	session jury puis succès, erreur IA/DB et suppression ; comparer une session Google	seuls les succès jury consomment ; erreurs IA/DB remboursées ; suppression sans remboursement ; Google illimité	tests services/API + PostgreSQL concurrent	Automatisé sur r.c. 7 : règles de réservation/libération et distinction jury/Google couvertes ; B2-A42

Critère de clôture C2.3.1

Les 65 scénarios de recette sont reliés à une preuve ou à une réserve explicite. CR-063 est validé par la construction, l'inspection, la décompression et la comparaison des empreintes du paquet r.c. 7. CR-055 réunit les mesures, la campagne technique, le déploiement r.c. 5 et la contre-recette NVDA déclarée validée. CR-062 combine une CI rouge courante isolée, un inventaire Vercel avant/après et six tests de politique. CR-008, CR-009 et CR-066 couvrent le quota jury partagé, son plafond atomique et ses règles de comptabilisation. CR-049 demeure un risque architectural hors dénominateur. Les tests Vitest/Playwright ne sont pas présentés comme un audit RGAA exhaustif.

LIV-02 - Plan de correction des bogues complet

Plan de correction des bogues - Bloc 2 RNCP39583

Compétence ciblée : C2.3.2 - Élaborer un plan de correction des bogues à partir de l'analyse des anomalies et des régressions détectées au cours de la recette.

1. Objectif

Ce plan décrit comment les anomalies détectées pendant la recette, les tests automatisés, la CI ou la revue documentaire sont qualifiées, corrigées et vérifiées sur Alcide.

Il complète :

- le cahier de recettes : docs/bloc2/cahier-recettes.md ;
- les fiches bugs existantes : docs/bloc4/bugs/ ;
- le journal de version : CHANGELOG.md.

Le cahier associé comptabilise **65 scénarios de recette**. CR-049 est conservé comme identifiant de traçabilité, mais relève d'un risque d'architecture serverless : il n'est ni une fonctionnalité attendue, ni une recette exécutée, ni un scénario inclus dans ce dénominateur.

Références de la version présentée :

Référence	Rôle
d42e7f2c8fc86f26c46f850d32eb748870c6140d	baseline applicative r.c. 7 testée et déployée
b5f941311fb034831f2c6a310c61585ad7b3f092	baseline historique r.c. 6
c63439e8ac8d68efd5ba091211b326ee8575fbba	baseline applicative r.c. 5 testée et déployée
ea703aef912ce9e7c49c4c9b7872a5a7b595b666	baseline historique r.c. 4
rnep-bloc2-2026-07-21-v5	snapshot documentaire antérieur avec CI/CD verte
MANIFESTE.txt du paquet	SHA effectivement archivé et empreintes SHA-256 des livrables

La baseline de production est 0.13.0 - r.c. 7. La CI 29994929981 et la CD 29995297354 établissent sa publication ; les healthchecks et la recette de l'accès jury sont consignés dans B2-A42. La contre-recette NVDA historique reste consignée dans B2-A41.

2. Processus de correction

Étape	Action	Sortie attendue
1. Détection	Identifier l'anomalie via recette, test, CI, audit sécurité, retour utilisateur ou revue documentaire	Ticket, ligne du plan ou fiche bug
2. Qualification	Définir gravité, impact, périmètre et compétence RNCP concernée	Priorité P0 à P3
3. Reproduction	Décrire les préconditions, données et étapes	Procédure reproductible
4. Analyse	Identifier cause racine et fichiers concernés	Hypothèse technique vérifiable
5. Correction	Modifier uniquement le périmètre nécessaire	Patch code ou documentation
6. Non-régression	Ajouter ou relancer test/recette	Commande ou scénario CR
7. Validation	Vérifier résultat attendu, CI et cohérence documentaire	Statut corrigé
8. Traçabilité	Mettre à jour cahier de recettes, changelog ou dossier RNCP	Preuve exploitable jury

3. Niveaux de priorité

Priorité	Définition	Délai cible
P0	Bloque une compétence éliminatoire ou un parcours critique	Avant dépôt
P1	Fragilise une preuve importante ou une fonctionnalité centrale	Avant dépôt
P2	Amélioration qualité ou cohérence documentaire	Dès que possible
P3	Confort, reformulation, amélioration mineure	Opportuniste

4. Registre des anomalies Bloc 2

ID	Source	Priorité	Anomalie	Cause probable	Correction attendue	Test de non-régression	Statut
B2-BUG-001	Cahier de recettes CR-013	P0	Panne OpenAI non exécutée dans une recette navigateur	La preuve unitaire avait été assimilée à une recette réelle	Conserver la preuve unitaire et exécuter un parcours contrôlé avec réponse OpenAI simulée en erreur	test service + rendu UI avec 4 29/503/timeout simulés	Clos : 9/9 recettes API ciblées et message UI/reprise vérifiés, B2-A34
B2-BUG-002	Ancien cahier CR-040 ; nouveau CR-060	P1	JSON attendu du healthcheck API incomplet	Route API renvoie aussi timestamp et version	Aligner résultat attendu sur le code réel	apps/api/tests/health.routes.ts, curl /health	Clos : tests finaux et healthchecks production réussis
B2-BUG-003	Ancien cahier CR-044 ; nouveaux CR-040/041	P1	Dashboard attendu trop ancien : barres par niveau/top sports seulement	Dashboard réel affiche aussi séances terminées, durée, effort moyen et feedback	Aligner scénario avec l'interface actuelle	Démo /dashboard, tests d'agrégation et recette authentifiée	Clos : documentation, tests d'agrégation et dashboard de production vérifiés dans B2-A25
B2-BUG-004	Audit du 2026-07-20	P0	E2E authentifiés redirigés vers /login et exclus du smoke	Fixture storageState vide et setup d'auth inexistant	Remplacer la fausse fixture par un mode de test explicite et sûr, puis exécuter les parcours cœur	pnpm test:e2e:authenticated	Clos : session OAuth réelle limitée au domaine Alcide, 4/4 local et CI 29816721099, preuve B2-A26
B2-BUG-005	CI GitHub	P1	Audit sécurité en erreur mais workflow global vert	continue-on-error au niveau job et step	Rendre pnpm audit --audit-level=low bloquant	validation YAML + audit local + nouveau run CI	Clos : audit low propre et job bloquant vert dans la CI finale
B2-BUG-006	Documentation Bloc 2	P1	Manuel utilisateur absent comme livrable autonome	Preuves dispersées dans README/ dossier	Créer bloc2-manuel-utilisateur-alcide.md	Relecture des routes et fonctionnalités réelles	Clos : manuel présent dans le gel v0.13.0-rc.3
B2-BUG-007	Documentation Bloc 2	P1	Manuel de mise à jour absent comme livrable autonome	Procédures dispersées dans CI/CD, deployment et changelog	Créer bloc2-manuel-mise-a-jour.md	Relecture des scripts et workflows	Document présent ; clone vierge non testé
B2-BUG-008	Documentation Bloc 2	P2	Pack d'annexes non indexé	Preuves non centralisées	Créer index d'annexes Bloc 2	Vérifier présence des pièces et statut réel	Clos pour l'index ; les preuves humaines manquantes restent signalées
B2-BUG-009	Coverage	P0	88 % annoncé alors que DB, repositories, routes, Web et shared sont exclus	Périmètre d'inspiration réduit pour franchir le seuil CI	Mesurer séparément API, Web, PostgreSQL et shared ; publier les exclusions déclaratives	pnpm test:coverage, quatre rapports CI	Clos sur le périmètre annoncé : rapports séparés publiés dans la CI 29819423534, exclusions explicites
B2-BUG-010	Sorties IA	P0	Séances/programmes JSON valides mais incohérents en durée ou structure acceptés	Schémas sans invariants métier transverses	Valider durée, nombre et numérotation semaines/séances avec cas répétitions	tests schémas + services IA	Clos sur le périmètre automatisé : tests finaux verts

ID	Source	Priorité	Anomalie	Cause probable	Correction attendue	Test de non-régression	Statut
B2-BUG-011	Session logs	P0	Un journal peut référencer le workout/programme d'un autre utilisateur	FK vérifie l'existence mais pas l'ownership	Introduire un service qui charge la ressource avec user Id avant insertion	tests service ownership 403/404	Clos sur le périmètre automatisé : tests unitaires et PostgreSQL finaux verts
B2-BUG-012	Timer	P1	Temps réalisé incluant les pauses et dérive de setTimeout	Calcul basé sur temps mural depuis le premier démarrage	Accumuler uniquement le temps actif avec horloge monotone/date de reprise	tests pause/reprise/suspension /fin	Clos : tests verts et pause/reprise réelle observée en production dans B2-A25
B2-BUG-013	Accessibilité	P0	Tests limités aux pages publiques et interactions modales incomplètes	Fixture auth absente et tests automatiques assimilés à RGAA	Corriger focus/Échap/onglets/Timer et vérifier l'échantillon authentifié	tests composants, Playwright, axe et parcours NVDA	Clos sur le périmètre initial : 33/33 sur 3 pages publiques et 5 privées, contrastes 166/166 décidés et parcours NVDA réel consigné. Les nouveaux écarts détectés sont suivis séparément en B2-BUG-042 à 045 ; B2-A36/A37/A40/A41.
B2-BUG-014	Ancien cahier de recettes	P0	Fonctions programmes/settings /journaux absentes et résultats des anciens CR-021/CR-030 faux	Inspection du code confondue avec exécution	Reconstituer l'inventaire et relier chaque scénario à une preuve ou à une réserve explicite	cahier v2 + artefacts datés	Inventaire initial clos à 62/62 ; rc . 7 ajoute CR -008/009/066 pour le quota jury, soit 65/65 recettes. CR-049 reste hors dénominateur, B2-A34 à A42.
B2-BUG-015	Versionnement	P1	Dossier, branche, production et commit de référence différents ; aucun tag	Pack généré après le SHA présenté et changelog incomplet	Distinguer le SHA applicatif du repère documentaire et du SHA réellement archivé	git rev-parse, manifeste, healthchecks et run CI/CD	Clos par CR-063 : baseline b002adb, tag v8, SHA documentaire/source archivé et empreintes sont distingués dans le manifeste généré avec le paquet
B2-BUG-016	Docker	P1	Manuel demandait drizzle-kit/tsx dans l'image runtime qui ne les contient pas	Confusion stage builder/runtime	Ajouter services outillage migrate/seed et corriger les commandes	docker compose config, build et exécution migration/seed	Corrigé : B2-A22 local et build Docker final CI verts ; clone vierge non archivé
B2-BUG-017	UI erreurs	P1	Panne API transformée en 404 ou valeurs par défaut silencieuses ; suppression sans erreur visible	Gestion générique de toutes les exceptions	Distinguer 404/403/5xx, timeout et afficher les échecs de mutation	tests server-api/pages/composants	Clos pour les parcours ciblés : erreurs OpenAI et suppression restent visibles et permettent une reprise, B2-A34

ID	Source	Priorité	Anomalie	Cause probable	Correction attendue	Test de non-régression	Statut
B2-BUG-018	Sécurité production	P1	CSP permissive et rate limit mémoire présenté comme contrôle complet	Configuration dev appliquée en production et état par instance	Durcir CSP ; présenter le rate limit distribué comme risque tant qu'aucun store partagé n'est configuré	headers production ; CR-048 local ; test multi-instance à prévoir	CSP/headers/CORS contrôlés et unsafe-eval absent. CR-049 est un risque architectural accepté, hors comptage fonctionnel : aucun quota distribué n'est revendiqué ; unsafe-inline reste documenté, B2-A35
B2-BUG-019	Données personnelles	P1	Notes de douleur stockées sans information claire ni politique d'exploitation	Fonction ajoutée sans documentation privacy dédiée	Informé l'utilisateur et définir finalité, conservation et droits ; ne pas prétendre export/suppression s'ils n'existent pas	revue page confidentialité et flux session	Information déployée ; durée automatique de conservation toujours absente
B2-BUG-020	Recette clavier 2026-07-20	P1	Le lien d'évitement changeait le fragment sans focaliser systématiquement le contenu principal	La cible main n'était pas focalisable programmiquement	Ajouter tabIndex=-1 à main#main-content	Playwright Chromium et Firefox, trois pages publiques	Clos : cycle clavier/focus exécuté sur 3 pages publiques et 5 privées, B2-A36
B2-BUG-021	Recette nom accessible 2026-07-20	P2	Le bouton Google était annoncé « Continuer avec Google G »	Lettre décorative incluse dans l'arbre d'accessibilité	Masquer le décor avec aria-hidden="true"	Playwright Chromium et Firefox	Clos : tests locaux et E2E final verts
B2-BUG-022	Inspection des captures 320 px 2026-07-20	P1	Texte clair sur fond clair sur la page de connexion et pied de page peu contrasté	Styles pensés pour des surfaces sombres appliqués sur le fond vert clair	Ajouter un panneau sombre et assombrir le texte du footer	Captures 320 px Chromium/Firefox ; échantillonnage composite et borne conservatrice	Clos : ratios opaques 17,36:1 public et 8,19:1 privé ; les 166 contextes composites sont décidés, dont le dernier borné à 15,00:1 dans le pire cas, B2-A36/A37.
B2-BUG-023	Recette authentifiée rc.2	P1	Les champs vides affichaient String must contain at least 1 character(s) dans une interface française	Messages par défaut de Zod dans les schémas partagés et programme HTTP	Définir tous les messages required/type/int/min/max en français	64 tests de schémas + soumissions navigateur séance/programme	Clos dans 0.13.0-rc.3 : CI 29747228594 et contre-recette B2-A25 vertes
B2-BUG-024	Recette Timer authentifiée rc.2	P1	Le focus tombait sur BODY après Échap du plein écran	Le portail démontait le bouton mémorisé avant sa refocalisation	Retrouver le contrôle Timer vivant à la fermeture applicative ou native	tests Échap/full screenchange + focus actif en production	Clos dans 0.13.0-rc.3 : focus sur BUTTON Pause, B2-A25

ID	Source	Priorité	Anomalie	Cause probable	Correction attendue	Test de non-régression	Statut
B2-BUG-025	Liste des séances r.c.2	P1	Le filtre proposait huit sports fixes alors que la génération accepte un libellé libre	Liste codée en dur non dérivée du contrat métier	Remplacer par un champ de recherche texte conservant le formulaire GET	typecheck, E2E manuel avec sport personnalisé	Clos dans 0.13.0-rc.3 : requête libre et état vide observés, B2-A25
B2-BUG-026	Dashboard r.c.2	P2	Casse, accents et espaces créaient plusieurs lignes pour un même sport	Agrégation SQL exacte sur le libellé saisi	Regrouper les variantes typographiques avant classement	3 tests unitaires + lecture dashboard production	Clos dans 0.13.0-rc.3 : Course à pied agrégé à 2, B2-A25
B2-BUG-027	CI PR #37	P0	Quatre vulnérabilités high détectées dans brace-expansion et shell-quote	Nouveaux avis publiés après le gel précédent et overrides devenus vulnérables	Cibler les seules plages vulnérables vers 1.1.16, 2.1.2, 5.0.7 et 1.9.0	installation figée, audit low, tests, build et CI	Clos : aucune vulnérabilité connue localement et six jobs verts dans la CI 29816347653, B2-A27
B2-BUG-028	Couverture shared 2026-07-21	P0	Le paquet de contrats partagé n'avait aucun rapport autonome	Les schémas étaient exercés indirectement par l'API et le Web	Ajouter Vitest au paquet shared, des tests de contrats et un artefact CI distinct	14 tests, couverture et CI 29819423534	Clos : 100 % lignes/statements/fonctions, 92,85 % branches, B2-A31
B2-BUG-029	Rendu final 2026-07-21	P1	Le PDF, le manifeste et le README des livrables désignaient des états et fichiers différents	Plusieurs exports intermédiaires conservés sans désignation finale unique	Générer un dossier et des annexes datés, les inspecter, puis produire un paquet avec empreintes	gate CR-063 dans build_loc2_delivery_pack.py, contrôle visuel et unzip	Clos pour les paquets r.c.3 et r.c.4 ; la nouvelle gate de B2-BUG-039 est validée localement.
B2-BUG-030	Authentifié mobile/axe 2026-07-21	P0	Aucun contrôle automatisé mobile ou axe avec session réelle n'était archivé	Suite authentifiée limitée aux parcours fonctionnels desktop	Ajouter viewport 390 × 844, contrôle de largeur et axe critique/sérieux sur /generate	Playwright authentifié 6/6 local	Clos sur le périmètre automatisé ; audit humain multi-page reste ouvert
B2-BUG-031	Recette CR-038 2026-07-21	P0	L'API acceptait tout modèle commençant par gpt - alors que l'UI en autorisait trois	Validation serveur plus permissive que le contrat d'interface	Ajouter une allowlist Zod partagée par lecture et écriture	requête HTTP avec gpt-model-interdit, statut 400 et repository non appelé	Clos : 9/9 recettes API ciblées, suite API 170/170, CI 29832575391 et CD 29832944876, B2-A34
B2-BUG-032	Recette journal 2026-07-21	P0	La revalidation de la page Timer pouvait masquer la confirmation après création du journal	La page courante était invalidée alors que seule la donnée du dashboard change	Ne revalider que le dashboard et, pour une séance de programme, la fiche programme parente	test UI confirmation + parcours production Timer/journal/dashboard	Clos : parcours CR-065 réussi, dashboard 3 → 4, suites finales et CD 29832944876, B2-A34
B2-BUG-033	Audit structure 2026-07-21	P1	/generate et /programs/generate exposaient chacun deux titres h1	Le titre interne du formulaire utilisait le même niveau que le titre de page	Passer les titres de formulaire en h2 sans perdre leur association aria-labelledby	2/2 tests de structure et arbre d'accessibilité	Clos : 2/2 tests de structure, 33/33 post-déploiement et CD 29832944876, B2-A36

ID	Source	Priorité	Anomalie	Cause probable	Correction attendue	Test de non-régression	Statut
B2-BUG-034	Zoom natif 400 % 2026-07-21	P0	Quatre routes rognaien des métriques ou titres de cartes à 400 %	Classe truncate incompatible avec le reflow attendu	Remplacer la troncature par break-words dans MetricPill, ProgramCard et WorkoutCard	zoom natif 2x/4x, contrôle des rectangles et 55 tests Web	Clos : correctif b002adb, CI 29845956008, CD 29846343559, production 16/16 à 200/400 % et accessibilité 33/33, B2-A37
B2-BUG-035	Contrastes composites 2026-07-21	P1	Axe retourne 416 nœuds incomplete malgré zéro violation	Gradients et ps eudo-éléments empêchent le calcul automatique du fond final	Conserver le détail automatisé et décider les fonds composites de l'échantillon avec une méthode reproductible	audit color-c ontrast sur 8 routes, échantillonnage pixel et borne conservatrice	Clos sur l'échantillon : rejeu rc.4 33/33 ; 165/166 contextes passent l'échantillonnage, le dernier (/programs . section-kicker) est borné à 15,00:1 dans le pire cas ; 166/166 décidés, sans revendiquer une conformité RGAA exhaustive, B2-A37.
B2-BUG-036	Lecteur d'écran 2026-07-21	P0	Arbre AX vérifié mais aucune restitution vocale réellement évaluée	Une session automatisée ne permet pas de juger l'ordre et le confort d'écoute	Parcours Narrator ou NVDA avec scénario, annonces attendues et résultat consigné	grille de restitution lecteur d'écran et transcription Speech Viewer	Clos sur l'échantillon avec réserve documentaire : campagne NVDA rc.4 détaillée, correctifs B2-BUG-042/043 publiés et validation NVDA rc.5 déclarée par l'utilisateur ; aucune conformité RGAA exhaustive, B2-A41.
B2-BUG-037	Gate négative CD / CR-062 2026-07-21	P1	Le chemin vert final était prouvé, mais aucune CI rouge courante n'avait de relevé production avant/après	Un échec volontaire sur main serait destructif ; une PR isolée permet de tester sans risque	Provoquer une erreur ESLint isolée, observer les jobs, comparer Vercel production et tester le YAML	CI 29856584668, PR #46, inventaires Vercel, test:cd-policy 6/6, B2-A38	Clos avec limite explicite : CI rouge actuelle, quatre jobs aval ignorés, aucun CD associé, API/Web production inchangés ; aucun commit rouge poussé sur main
B2-BUG-038	Veille dépendances 2026-07-22	P0	Cinq avis nouvellement détectés : un high sur sharp et quatre moderate sur hono/hono/node-server	Avis publiés après le gel rc.3 et versions transitives devenues vulnérables	Résoudre sharp en 0.35.3, hono en 4.12.31 et @hono/node-server en 2.0.11, puis rejouer audit et suites	audit low, lint, typecheck, pnpm test, pnpm build, B2-A39	Clos dans 0.13.0-rc.4 : audit propre, 239/239 tests, CI 29907294766, CD 29907642144 et healthchecks rc.4.

ID	Source	Priorité	Anomalie	Cause probable	Correction attendue	Test de non-régression	Statut
B2-BUG-039	Revue du paquet 2026-07-22	P0	Cahier, plan, OWASP et matrice peu découvrables dans les annexes ; identifiants nominatifs possibles dans texte, liens, métadonnées ou objets PDF/ZIP	Livrables seulement accessibles via l'archive source et anonymisation limitée au texte visible	Intégrer les quatre livrables complets au PDF, ajouter sommaire/signets et contrôler texte, métadonnées, annotations, flux et ZIP imbriqués	builders PDF/ZIP, recherche des marqueurs, rendu visuel, décompression et gate CR-063	Clos sur r.c. 5 : B2-A41 et les livrables sont intégrés ; 95 pages inspectées (11 + 84) ; anonymisation, ZIP imbriqué, décompression et empreintes vérifiés.
B2-BUG-040	Audit sémantique authentifié 2026-07-22	P1	Après soumission invalide, le focus reste sur le bouton au lieu de rejoindre le premier champ en erreur	Les erreurs sont rendues, mais aucun déplacement de focus n'est demandé après l'échec de validation	Focaliser le premier contrôle signalé par le schéma dans les formulaires séance et programme	tests composants, CI 29907294766, focus actif observé après soumission vide	Clos sur r.c. 4 : focus INPUT#input - sport [name="sport "] contre-recette en production, B2-A40.
B2-BUG-041	Audit sémantique authentifié 2026-07-22	P1	Deux onglets d'un programme exposent aria-controls vers des panneaux absents lorsque les semaines sont inactives	Le composant ne rendait que le panneau courant	Conserver chaque panneau dans le DOM, masquer les inactifs et rendre uniquement l'actif focalisable	CI 29907294766, chaque cible existe et les panneaux inactifs sont masqués	Clos sur r.c. 4 : 3/3 relations résolues, un onglet sélectionné et deux panneaux inactifs hidden, B2-A40.
B2-BUG-042	Parcours NVDA SR-04 2026-07-22	P0	Après une génération valide, NVDA annonce à tort « Erreur : NEXT_REDIRECT » alors que la séance est créée et la navigation réussit	Le catch client intercepte aussi le signal interne de redirection Next.js	Exclure de la région d'erreur uniquement un signal portant un digest Next.js valide, pour les formulaires séance et programme	tests composants séance/programme, typecheck et lint ; rejeu NVDA de production après déploiement	Clos sur r.c. 5 : correctif déployé, CI/CD vertes et contre-recette NVDA déclarée validée par l'utilisateur. Aucun détail supplémentaire de navigateur, version, verbatim ou protocole n'est attribué au rejeu, B2-A41.
B2-BUG-043	Parcours NVDA SR-08 2026-07-22	P1	L'enregistrement des paramètres réussit, mais la confirmation status n'est pas annoncée spontanément	La région status est montée conditionnellement avec son texte déjà présent, ce qui peut ne pas produire de mutation annoncée	Maintenir la région vide dans le DOM puis injecter le texte de succès sans déplacer le focus	test composant dédié, typecheck et lint ; rejeu NVDA de production après déploiement	Clos sur r.c. 5 : région persistante déployée, test de mutation/focus vert et contre-recette NVDA déclarée validée par l'utilisateur, sans transcription détaillée supplémentaire ; B2-A41.

ID	Source	Priorité	Anomalie	Cause probable	Correction attendue	Test de non-régression	Statut
B2-BUG-044	Parcours NVDA SR-09 2026-07-22	P2	La suppression réussit, mais aucun message final explicite n'a été capturé après confirmation	La disparition de la carte sert de retour visuel sans message persistant dédié	Ajouter ou confirmer une région vive de succès, puis vérifier la restitution et le retour du focus	test composant et rejeu NVDA de production	Ouvert non bloquant ; confirmation, focus initial, Échap et suppression effective sont validés, annonce finale à compléter, B2-A41.
B2-BUG-045	Parcours NVDA SR-10 2026-07-22	P2	La déconnexion atteint bien /, mais le titre de destination n'a pas été capturé spontanément	Le changement de route ne produit pas nécessairement une annonce de page dans le navigateur observé	Contre-recetter le titre et le focus après navigation, puis ajouter une annonce de route si nécessaire	rejeu NVDA de production	Ouvert non bloquant ; action de déconnexion et lien « Se connecter » accessibles, annonce de destination à compléter, B2-A41.
B2-BUG-046	Revue accès jury 2026-07-23	P0	Le compte jury pouvait déclencher un nombre illimité de générations IA payantes	L'accès Credentials était sécurisé, mais aucune limite persistante n'était attachée à cette identité	Ajouter un quota API/PostgreSQL atomique de 30 succès, partagé séances/programmes, sans limiter Google	tests unitaires/API, intégration PostgreSQL concurrente et recette navigateur production	Clos sur r.c. 7 : 31e demande refusée en HTTP 429 GENERATION_QUOTA_EXCEEDED, erreurs IA/DB remboursées, suppressions non remboursées ; compteur commun observé à 29/30 sur les deux pages, zéro erreur console, B2-A42.

5. Fiches bugs réelles déjà disponibles

Fiche	Résumé	Lien avec Bloc 2
docs/bloc4/bugs/BUG-001-coverage-threshold.md	Incident historique : seuil franchi surtout par exclusions ; ne clôt pas C2.2.2	Contre-exemple utile et origine de B2-BUG-009
docs/bloc4/bugs/BUG-002-readme-utf16.md	Encodage README incorrect	Traçabilité documentaire, C2.4.1

Ces fiches sont des preuves utiles, mais le présent document reste le plan global Bloc 2 car il relie recette, priorité, correction et test de non-régression.

6. Critères de clôture d'une anomalie

Une anomalie est clôturée lorsque :

- la cause est identifiée ;
- le correctif est appliqué ;
- le cahier de recettes ou le test concerné est mis à jour ;
- une commande ou une vérification manuelle est consignée ;
- le statut final est explicite : corrigé, accepté, reporté ou non reproductible.

7. Suivi avant dépôt

État avant dépôt :

1. [x] Correctifs métier fusionnés par la PR 43, puis correctif de reflow sur la baseline b002adb0e0e7d8d85ee493d54879e190d77d2078 ; CI 29845956008, CD 29846343559, E2E OAuth 29833210488 et accessibilité 33/33 réussis.
2. [x] Réaliser et consigner le zoom navigateur natif : 16 mesures exécutées, quatre défauts détectés à 400 %, correctif validé par 55 tests, le typecheck, le build, 6/6 local public et 16/16 en prévisualisation.
3. [x] Déployer le correctif de reflow et rejouer les 16 mesures sur la production corrigée : 16/16 sans texte ni commande rognés.
4. [x] Réaliser un parcours réel au lecteur d'écran : campagne NVDA 2026.1.1 détaillée sur rc . 4, puis validation NVDA rc . 5 déclarée par l'utilisateur, B2-A41. Aucune conformité RGAA exhaustive ni appréciation auditive détaillée n'est revendiquée.
5. [x] Gate CR-063 intégrée au générateur du paquet : validation des PDF, preuves obligatoires, archive source filtrée/anonymisée et manifeste ; décompression du ZIP et comparaison des empreintes SHA-256 avant remise.
6. [x] Corriger les cinq avis détectés le 22 juillet dans 0 . 13 . 0 - rc . 4 ; audit low, 239 tests, CI/CD et healthchecks verts, B2-A39.
7. [x] Audit sémantique B2-A40 : focus invalide et relations d'onglets corrigés, puis contre-recettés en production rc . 4.
8. [x] CR-063 rejoué sur le paquet rc . 5 avec B2-A41 : 95 pages inspectées (11 + 84), anonymisation validée, ZIP décompressé et empreintes comparées.
9. [x] Publier rc . 5, exécuter sa CI/CD et vérifier ses healthchecks ; B2-BUG-038, 040, 041, 042 et 043 sont clos.
10. [x] Déployer les corrections B2-BUG-042/043 et enregistrer la validation NVDA déclarée par l'utilisateur. B2-BUG-044/045 restent des améliorations P2 ouvertes et non bloquantes.
11. [x] Limiter l'accès jury à 30 générations réussies : compteur persistant et atomique, 267 tests, intégration PostgreSQL concurrente, CI 29994929981, CD 29995297354 et recette navigateur de production, B2-A42.
12. [] Appliquer les consignes administratives exactes de DigiformaCertif.

LIV-03 - Revue de sécurité OWASP A01 à A10 complète

Revue de sécurité OWASP Top 10 - Alcide

Livable transversal utilisé par le Bloc 2, compétence C2.2.3

Revue de code : 2026-07-21 - baseline de campagne sécurité 0d5c6b6 . . .

Baseline historique déployée après le correctif de reflow : b002adb . . . , CI

29845956008, CD 29846343559. Ce correctif ne modifie pas les contrôles de sécurité décrits ci-dessous.

Baseline de production courante : 0.13.0-rc.7,

d42e7f2c8fc86f26c46f850d32eb748870c6140d, CI 29994929981, CD 29995297354.

Méthode et échelle

Cette revue suit les dix catégories OWASP Top 10 2021. Elle distingue :

- **contrôlé** : mesure présente et testée sur la version de référence ;
- **partiel** : mesure utile présente, avec risque résiduel identifié ;
- **à prouver** : code présent mais preuve finale non encore exécutée.

pnpm audit ne couvre que les vulnérabilités connues des dépendances. Il ne constitue pas à lui seul une revue OWASP Top 10.

A01 - Broken Access Control - contrôlé

Contrôles :

- OAuth Google et vérification auth () sur les routes Web privées ;
- secret interservice entre Next.js et Hono ;
- identité utilisateur transmise côté serveur uniquement ;
- repositories workout/program vérifiant l'ownership ;
- service session-log vérifiant workout/program avant insertion et dérivant les métadonnées depuis la ressource détenue par l'utilisateur ;
- UUID validés avant PostgreSQL.

Preuve : B2-A19 consigne 8/8 tests PostgreSQL réels avec deux utilisateurs, dont l'isolation et l'ownership workout/program/session-log. Les tests ont été rejoués dans le job PostgreSQL de la CI de consolidation 29832575391 sur main. Les tests middleware et controllers sont aussi exécutés dans la suite unitaire. L'existence d'une FK seule n'est pas utilisée comme preuve d'ownership.

Risque résiduel : SERVICE_SECRET est une frontière de confiance à fort impact. Sa rotation et son stockage Vercel/GitHub doivent être documentés.

A02 - Cryptographic Failures - contrôlé avec limites

Contrôles exécutés : fichiers .env ignorés, exemples sans valeur secrète, TLS et HSTS observés sur les URL de production et secrets OpenAI/interservice utilisés dans des modules serveur. L'HTML et les neuf scripts effectivement chargés en production ont été inspectés : aucun marqueur OPENAI_API_KEY, SERVICE_SECRET, AUTH_SECRET, AUTH_GOOGLE_SECRET ni motif de clé sk - * longue. Les contrôles locaux Chromium/Firefox donnent le même résultat ; B2-A35.

Risque résiduel : les journaux peuvent contenir effort et notes de douleur, liés à l'identité. Une page de confidentialité informe l'utilisateur, mais la durée de conservation, l'export et la suppression de compte doivent être formalisés et, s'ils sont annoncés, réellement implémentés.

A03 - Injection - contrôlé

Les chaînes utilisateur ne sont pas nécessairement rejetées parce qu'elles ressemblent à du SQL. La protection repose sur les requêtes paramétrées Drizzle, complétées par la validation de forme Zod. Le cahier de recettes ne prétend plus que Zod bloque la chaîne `' ; DROP TABLE ...`.

Preuves : la charge exacte `' ; DROP TABLE workouts ; --` a été insérée puis relue comme donnée via le repository sur PostgreSQL 16.14 ; un SELECT après insertion a confirmé la table intacte et le nettoyage a été vérifié. Les charges XSS script et img onerror restent du texte inerte dans React et dans Chromium/Firefox. Les recherches de sinks DOM et d'appels DB bruts sont vides ; B2-A35.

A04 - Insecure Design - partiel

Contrôles : architecture en couches, schémas partagés, invariants métier sur les sorties IA, timeouts, retry borné, erreurs typées, contrôle d'ownership et limite de taille des entrées.

Le quota de l'accès jury repose sur un compteur PostgreSQL persistant et une réservation atomique, partagé entre les générations de séances et de programmes. Il est limité à 30 générations réussies. La suppression d'un résultat ne rend pas l'unité consommée ; un échec IA ou d'enregistrement en base libère la réservation. Les comptes Google ne sont pas limités par ce mécanisme. Le test PostgreSQL lance 31 réservations concurrentes et observe exactement 30 acceptations et un refus, ce qui couvre le risque de dépassement par concurrence.

Risque résiduel majeur : le rate limit général, distinct du quota jury, utilise un Map mémoire par processus. Il protège un processus unique mais ne garantit pas une limite globale sur Vercel avec cold starts ou plusieurs instances. Le passage à un store distribué atomique reste nécessaire avant de présenter ce rate limit comme une garantie de production.

A05 - Security Misconfiguration - contrôlé avec risque résiduel

Contrôles : secureHeaders, CORS restreint, erreurs sans stack client, variables obligatoires, readiness DB et présence de configuration OpenAI, images non-root, directives CSP object-src, base-uri, form-action et frame-ancestors.

Les en-têtes effectifs du Web et de l'API ont été contrôlés localement puis en production. L'origine CORS hostile ne reçoit aucun Access-Control-Allow-Origin, tandis que le front officiel est autorisé. La CSP de production contient object-src 'none', base-uri 'self', form-action 'self', frame-ancestors 'none' et n'autorise pas unsafe-eval ; B2-A35.

Risques résiduels :

- unsafe-inline reste présent pour scripts/styles, notamment pour les besoins de Next.js ; une CSP à nonce demanderait une évolution dédiée ;
- le liveness check ne doit pas être confondu avec readiness ;
- les secrets et callbacks OAuth de production restent une configuration externe à vérifier.

A06 - Vulnerable and Outdated Components - contrôlé

Contrôles : lockfile, installation figée, audit dès le niveau low rendu bloquant en CI, versions Next.js/React situées sur une ligne corrigée.

Contrôle local du 2026-07-20 sur la version 0.13.0-rc.3 : `pnpm audit --audit-level=low` termine avec le code 0 et indique No known vulnerabilities found. Les six alertes précédentes ont été corrigées par des overrides ciblés, puis le lint, les types, 198 tests, les builds et drizzle-kit check ont été rejoués. La CI main 29747228594 a ensuite confirmé ce résultat avec le seuil bloquant low.

Actualisation du 2026-07-21 : quatre nouveaux avis high sur les dépendances transitives brace-expansion et shell-quote ont fait échouer la CI 29815728217. Les overrides ont été déplacés vers 1.1.16, 2.1.2, 5.0.7 et 1.9.0. L'audit local ne remonte plus de vulnérabilité connue et la CI complète 29816347653 est verte. B2-A27 conserve l'échec, la correction et la contre-vérification. L'audit bloquant au niveau low est de nouveau vert dans la CI de consolidation 29832575391, puis dans la CI canonique 29845956008.

Actualisation du 2026-07-22 : un nouvel audit de la version rc.4 a détecté cinq avis publiés depuis le gel précédent : un avis high sur sharp et quatre avis moderate concernant hono et @hono/node-server. La version 0.13.0-rc.4 les

corrige avec sharp@0.35.3, hono@4.12.31 et @hono/node-server@2.0.11. L'audit de production au seuil low, le lint, la vérification des types, les 239 tests et les builds sont de nouveau verts en localement et dans la CI 29907294766. B2-A39 conserve le constat, les versions résolues et les commandes de contre-vérification. La CD 29907642144 et les healthchecks rc.4 ferment la contre-vérification de production.

La baseline 0.13.0-rc.5 conserve ces versions corrigées. Elle a repassé l'audit de production au seuil low, le lint, les types, 241 tests, les builds et la CI 29930722308, puis la CD 29931146789 et les healthchecks HTTP 200. Les correctifs rc.5 portent sur la restitution d'accessibilité et ne relâchent aucun contrôle de sécurité décrit dans cette revue.

La baseline historique 0.13.0-rc.6 passe à son tour l'audit low, le lint, les types, 256 tests et les builds dans la CI 29990178784. La CD 29990426551, les healthchecks HTTP 200 et la recette navigateur de B2-A42 confirment le déploiement de l'accès jury sans régression des contrôles précédents.

La baseline de production 0.13.0-rc.7 conserve ces correctifs. L'audit low, le lint, les types, 267 tests unitaires/composants - shared 14, API 179, Web 74 -, l'intégration PostgreSQL dédiée et les E2E sont verts dans la CI 29994929981. La CD 29995297354, les healthchecks et la recette navigateur, qui affiche 29 générations restantes après une génération de validation, confirment son déploiement.

A07 - Identification and Authentication Failures - contrôlé avec limites

Contrôles de code : Google OAuth, stratégie de session JWT Auth.js avec durée maximale configurée et vérification serveur sur chaque parcours protégé. Les attributs réels du cookie et l'expiration doivent être relevés sur la version déployée ; ils ne sont pas considérés comme prouvés par la seule configuration.

La suite Playwright authentifiée n'utilise plus une fixture vide. B2-A26 prouve la capture d'un vrai storageState Auth.js après connexion Google manuelle, la vérification de l'identité, le filtrage des cookies sur le domaine Alcide et 4/4 scénarios en CI 29817741589. La déconnexion et l'accès sans session sont couverts par B2-A25. La suite finale ajoute le reflow mobile et axe : 6/6 dans la CI post-déploiement 29833210488. L'expiration et la rotation automatique restent à tester.

La version 0.13.0-rc.6 ajoute un fournisseur Credentials réservé au jury, sans modifier le parcours Google. Le mot de passe n'est jamais stocké en clair : Vercel ne reçoit qu'un hash scrypt salé, comparé avec timingSafeEqual. L'identité technique possède un e-mail dédié ; l'API continue à résoudre son propre UUID PostgreSQL et à appliquer l'ownership. L'accès est absent de l'interface si sa configuration est incomplète, désactivée ou expirée. Le callback JWT revalide à chaque lecture le kill switch, la date absolue et une empreinte de configuration : expiration, désactivation et rotation du hash ou de la version de session invalident donc aussi les sessions existantes. La version de session doit être renouvelée avant chaque réactivation afin qu'un ancien cookie ne redevienne pas valide. Les échecs affichent un message générique. Le callback /api/auth/callback/jury est protégé dans Vercel Firewall par une fenêtre fixe de 10 tentatives par minute et par IP, ce qui réduit le risque de brute force et de consommation CPU de scrypt.

La version 0.13.0-rc.7 borne cet accès à 30 générations réussies, partagées entre séances et programmes. Le Web ne décide pas seul du droit à générer : l'API reconnaît le mode jury transmis par le serveur authentifié, réserve atomiquement le quota dans PostgreSQL et renvoie HTTP 429 lorsque le plafond est atteint. Les échecs techniques sont remboursés, contrairement à la suppression d'un résultat déjà généré. Les sessions Google restent hors de ce quota.

A08 - Software and Data Integrity Failures - contrôlé

Contrôles : lockfile, --frozen-lockfile, CI avant CD, migrations versionnées, validation Zod des sorties OpenAI et images construites depuis le SHA.

Le CD manuel contournant la CI est supprimé. Les actions GitHub sont épinglées par SHA, la CLI Vercel est appelée avec une version explicite et le SHA déployé est conservé dans le manifeste. La CI 29832575391 puis le CD 29832944876 prouvent l'enchaînement sur la baseline de consolidation 0d5c6b6... Le même enchaînement est confirmé sur la baseline canonique b002adb... par la CI 29845956008 et le CD 29846343559.

La chaîne courante est confirmée sur d42e7f2c8fc86f26c46f850d32eb748870c6140d par la CI 29994929981, puis la CD 29995297354, qui applique la migration du quota avant les déploiements API et Web.

A09 - Security Logging and Monitoring Failures - contrôlé avec limites

Les tentatives d'auth invalides, erreurs applicatives, appels IA et erreurs DB disposent d'appels de journalisation dans le code. Une recette contrôlée a obtenu HTTP 401 et vérifié l'événement serveur d'authentification refusée, sans secret, valeur hostile ni stack dans la réponse client. Le monitoring planifié de production a réussi sur la version déployée et B2-A29 a obtenu 150/150 réponses valides sur les trois healthchecks ; B2-A35.

Risque résiduel : console.* n'offre ni corrélation systématique, ni rétention, ni alerte sécurité dédiée. Un logger structuré, un identifiant de requête, une politique de masquage et un export vers un outil d'observabilité restent à mettre en place.

A10 - Server-Side Request Forgery - contrôlé

L'URL OpenAI est fixe côté serveur et aucune URL fournie par l'utilisateur n'est utilisée par fetch. Le budget global de génération est borné sous la durée maximale Vercel ; les appels Web possèdent également un timeout.

Preuves : tests timeout/retry et revue des appels réseau serveur.

Synthèse des risques

Catégorie	État observé	Preuve finale requise
A01 Accès	Contrôlé	PostgreSQL multi-utilisateur + API
A02 Cryptographie/données	Contrôlé avec limites	inspection ressources navigateur et politique données
A03 Injection	Contrôlé	DB réelle + navigateur
A04 Conception	Partiel	stratégie rate limit distribué ou risque accepté
A05 Configuration	Contrôlé avec risque résiduel	CSP/headers/CORS effectifs ; nonce à étudier
A06 Composants	Contrôlé	audit brut du lockfile final
A07 Authentification	Contrôlé	Playwright avec vrai état Auth.js
A08 Intégrité	Contrôlé	CI/CD, actions épinglées et SHA
A09 Logs	Contrôlé avec limites	événement 401 et monitoring ; SIEM absent
A10 SSRF	Contrôlé	tests timeout + revue URL fixe

La revue ne conclut pas « 10/10 sans risque ». Elle fournit au jury les contrôles exécutés et les risques résiduels : confidentialité, rate limit distribué, CSP à nonce, expiration de session et observabilité structurée.

LIV-04 - Matrice user stories, écrans, recettes et preuves complète

Bloc 2 - Matrice besoins, user stories et preuves

Cette matrice relie les besoins fonctionnels du prototype aux écrans et au code effectivement présents, aux scénarios du cahier de recettes et aux annexes de preuve. Elle ne remplace ni le détail des recettes ni les réserves consignées dans les annexes.

Besoin / user story	Route ou écran	Composants Web et API	Scénarios de recette	Preuves B2
En tant qu'utilisateur ou membre du jury, je veux me connecter, accéder aux pages privées et me déconnecter.	/login, Google ou section Accès jury, callback /api/auth/callback/jury, puis /generate ; redirection vers /login depuis les routes privées sans session.	app/(auth)/login/page.tsx, app/api/auth/[...nextauth]/route.ts, lib/auth.ts, lib/jury-auth.ts, contrôle auth() dans les pages privées, navigation de app/layout.tsx.	CR-001 à CR-009	B2-A20 (redirections publiques), B2-A25 (session et déconnexion), B2-A30 (prototype authentifié), B2-A42 (accès jury sécurisé et quota partagé).
En tant qu'utilisateur connecté, je veux générer une séance à partir de mon sport, niveau, durée et objectifs, puis ouvrir son détail.	/generate → /workouts/[id] ; le jury voit le solde commun avant génération.	WorkoutForm, GenerationQuotaNotice, action serveur de app/generate/page.tsx, serverApi.generateWorkout() → POST /workouts/generate ; services Workout/IA et quota de l'API.	CR-008 à CR-015 et CR-066	B2-A25 (génération réelle), B2-A30 (captures), B2-A31 (contrats), B2-A34 (erreurs IA), B2-A42 (30 succès maximum, persistance, concurrence et remboursement des échecs).
En tant qu'utilisateur connecté, je veux générer un programme structuré sur plusieurs semaines et consulter son contenu.	/programs/generate → /programs/[id] ; le jury retrouve le même solde que sur /generate.	ProgramForm, GenerationQuotaNotice, action serveur de app/programs/generate/page.tsx, serverApi.generateProgram() → POST /programs/generate ; services Program/IA et quota de l'API.	CR-008, CR-009, CR-016, CR-017 et CR-066	B2-A25 (programme réel), B2-A30 (capture du formulaire), B2-A31 (contrats), B2-A42 (quota jury partagé séances/programmes et 31e demande refusée en HTTP 429).
En tant qu'utilisateur, je veux retrouver uniquement mes séances, les filtrer par sport et niveau et parcourir les pages de résultats.	/workouts?sport=...&level=...&page=...	app/workouts/page.tsx, WorkoutCard, formulaire GET de filtres ; serverApi.getWorkouts() → GET /workouts ; contrôleur, service et repository Workout.	CR-022 ; contrôles d'isolation CR-023 et CR-024	B2-A19 (PostgreSQL réel et ownership), B2-A25 (filtre sport corrigé), B2-A34 (suites API/Web/PostgreSQL finales).
En tant qu'utilisateur, je veux lister et paginer mes programmes, puis naviguer entre les semaines et les séances.	/programs?page=..., /programs/[id], /programs/[id]/sessions/[sessionId].	app/programs/page.tsx, ProgramCard, ProgramWeekTabs ; serverApi.getPrograms() et getProgram() → GET /programs, GET /programs/:id.	CR-018 à CR-020	B2-A19 (isolation PostgreSQL), B2-A25 (détail et navigation clavier des onglets), B2-A34 (pagination et isolation).
En tant que sportif, je veux consulter le déroulé d'une séance et l'exécuter avec un Timer utilisable au clavier.	/workouts/[id] et /programs/[id]/sessions/[sessionId].	WorkoutTimeline, Timer, pages de détail ; serverApi.getWorkout() ou getProgram() → GET /workouts/:id ou GET /programs/:id.	CR-019, CR-023 à CR-029	B2-A25 (détail, Timer, pause/reprise, plein écran et focus), B2-A34 (parcours final CR-065), B2-A36 (clavier et structure automatisables).
En tant qu'utilisateur, je veux enregistrer la fin d'une séance avec durée active, effort, ressenti et notes facultatives afin d'alimenter mon suivi.	Formulaire de fin intégré au Timer des deux écrans de séance ; restitution sur /dashboard.	Timer, SessionCompletionForm, actions completeWorkout() et completeProgramSession() ; serverApi.createSessionLog() → POST /session-logs ; contrôleur, service et repository SessionLog.	CR-030 à CR-034 et CR-065	B2-A19 (persistance et ownership PostgreSQL), B2-A34 (durée 487 s, note, parcours production et dashboard 3 → 4).

Besoin / user story	Route ou écran	Composants Web et API	Scénarios de recette	Preuves B2
En tant qu'utilisateur, je veux voir une synthèse personnelle de mes séances créées et terminées, de la durée, de l'effort et des sports pratiqués.	/dashboard.	app/dashboard/page.tsx, getTopSports(); serverApi.getStats() → GET /workouts/stats et getSessionLogStats() → GET /session-logs/stats.	CR-040, CR-041 et CR-065	B2-A25 (agrégation sport corrigée), B2-A34 (état vide, totaux, isolation et incrément production).
En tant qu'utilisateur, je veux connaître le fournisseur IA, choisir un modèle autorisé et recevoir une confirmation ou une erreur explicite.	/settings.	SettingsForm, action serveur de app/setting s/page.tsx; serverApi.getAiSettings() et saveAiSettings() → GET /settings; PUT /settings; contrôleur et repository Settings.	CR-036 à CR-039	B2-A25 (lecture en production), B2-A34 (persistance, restauration et rejet du modèle non autorisé).
En tant qu'utilisateur, je veux supprimer une séance ou un programme après confirmation, sans perdre le contrôle du focus ni masquer une erreur API.	Cartes de /workouts et /programs, ainsi que détail /programs/[id].	DeleteConfirmationButton, DeleteWorkoutButton, DeleteProgramButton; serverApi.deleteWorkout() et deleteProgram() → DELETE /workouts/:id, DELETE /programs/:id.	CR-021, CR-024 et CR-035	B2-A19 (suppression et ownership PostgreSQL), B2-A25 (suppression réelle et interaction), B2-A34 (annulation, Échap et erreurs API).
En tant qu'utilisateur, y compris au clavier, avec un lecteur d'écran ou sur petit écran, je veux comprendre et actionner les parcours publics et privés sans perte d'information.	/, /login, /confidentialite, /dashboard, /generate, /programs, /programs/generate, /workouts, /settings, dialogues de suppression et Timer.	Structure sémantique des pages et formulaires, ProgramWeekTabs, DeleteConfirmationButton, Timer; tests Playwright/axe, tests de structure/composants et parcours NVDA.	CR-051 à CR-055	B2-A20 (public 320 px/clavier/axe), B2-A25 (contrôles authentifiés et focus), B2-A30 (reflow authentifié), B2-A36 (audit automatisable final), B2-A37 (zoom et contrastes), B2-A40 (sémantique), B2-A41 (NVDA réel et écarts).

Sources et limite de lecture

- Scénarios et statuts : docs/bloc2/cahier-recettes.md.
- Description et statut des annexes : docs/rncp/bloc2-annexes/index.md.
- Routes Web : apps/web/app/ ; composants : apps/web/components/ ; client serveur : apps/web/lib/server-api.ts.
- Routes API : apps/api/src/routes/ ; contrôleurs, services et repositories : apps/api/src/controllers/, apps/api/src/services/ et apps/api/src/repositories/.

La couverture accessibilité ne doit pas être interprétée comme une conformité RGAA exhaustive : CR-055 est clos avec une réserve documentaire. B2-A37 indique que les 166 contextes composites de l'échantillon sont décidés. B2-A41 consigne la campagne NVDA détaillée sur rc.4, les correctifs publiés dans rc.5 et la validation NVDA déclarée par l'utilisateur. B2-BUG-044/045 restent des améliorations P2 non bloquantes ; aucune appréciation auditive détaillée n'est revendiquée.

DOC-01 - Manuel de déploiement complet

Production canonique

Composant	Plateforme	URL
Frontend	Vercel	https://ai-sport-web.vercel.app
API	Vercel	https://ai-sport-api.vercel.app
Base de données	Neon PostgreSQL	via DATABASE_URL

La CI/CD est documentée dans docs/ci-cd.md.

Variables d'environnement Vercel

Projet Web:

```
API_URL=https://ai-sport-api.vercel.app
NEXT_PUBLIC_API_URL=https://ai-sport-api.vercel.app
SERVICE_SECRET=<same value as API>
AUTH_SECRET=<Auth.js secret>
AUTH_GOOGLE_ID=<Google OAuth client id>
AUTH_GOOGLE_SECRET=<Google OAuth client secret>
JURY_ACCESS_ENABLED=false
JURY_ACCESS_IDENTIFIER=<identifiant temporaire>
JURY_ACCESS_PASSWORD_HASH=<hash script salé>
JURY_ACCESS_USER_ID=<identité de session stable>
JURY_ACCESS_EMAIL=<email technique dédié>
JURY_ACCESS_NAME=<nom affiché>
JURY_ACCESS_EXPIRES_AT=<date ISO 8601 absolue avec fuseau>
JURY_ACCESS_SESSION_VERSION=<nonce à renouveler à chaque activation>
NEXTAUTH_URL=https://ai-sport-web.vercel.app
```

L'accès jury est limité à l'environnement Vercel Production. Le mot de passe en clair ne doit jamais être ajouté à Vercel ou au dépôt. Pour produire son hash sans écrire le secret dans l'historique PowerShell :

```
$securePassword = Read-Host "Mot de passe jury" -AsSecureString
$secretPointer = [Runtime.InteropServices.Marshal]::SecureStringToBSTR($securePassword)
try {
    $env:JURY_PASSWORD = [Runtime.InteropServices.Marshal]::PtrToStringBSTR($secretPointer)
    npm run jury:hash
} finally {
    [Runtime.InteropServices.Marshal]::ZeroFreeBSTR($secretPointer)
    Remove-Item Env:JURY_PASSWORD -ErrorAction SilentlyContinue
}
```

La sortie script\$. . . devient JURY_ACCESS_PASSWORD_HASH. À chaque réactivation, renouveler aussi JURY_ACCESS_SESSION_VERSION pour que les anciens cookies ne puissent pas redevenir valides. Le callback POST /api/auth/callback/jury est protégé dans Vercel Firewall par une fenêtre fixe de 10 tentatives par minute et par IP.

Projet API:

```
DATABASE_URL=<Neon pooled PostgreSQL URL>
SERVICE_SECRET=<same value as Web>
OPENAI_API_KEY=<OpenAI API key gérée par Alcide côté serveur>
FRONTEND_URL=https://ai-sport-web.vercel.app
NODE_ENV=production
```

GitHub Actions

1. CI - Alcide vérifie lint, types, tests et couvertures API/Web/PostgreSQL, build, smoke E2E public, audit dès le niveau low, politique de déploiement Vercel et Docker.
2. CD - Vercel se lance uniquement après une CI verte sur main si la variable GitHub ENABLE_GHA_VERCEL_CD=true est définie. Il n'existe plus de lancement manuel contournant les gates.
3. CD - Vercel applique les migrations Drizzle avant le déploiement API ; un échec bloque ensuite l'API et le Web. DB - Drizzle migrations reste un chemin manuel de reprise, rattaché à l'environnement production. Au relevé du 2026-07-20, cet environnement ne possédait aucune règle de protection ni approbateur ; ce n'est donc pas encore une gate humaine.

4. Les previews Vercel de pull request restent actives. Pour `VERCEL_ENV=production`,

`ignoreCommand` ignore le déploiement automatique de l'intégration Git ; le workflow CD force explicitement le chemin canonique après CI verte.

Secrets GitHub requis pour la CD:

```
VERCEL_TOKEN
VERCEL_ORG_ID
VERCEL_API_PROJECT_ID
VERCEL_WEB_PROJECT_ID
DATABASE_URL
```

Le token doit autoriser `vercel pull/build/deploy` sur les deux projets. Le run CD canonique 29995297354, déclenché automatiquement après la CI 29994929981, a réussi sur le SHA `d42e7f2c8fc86f26c46f850d32eb748870c6140d` : migration, API, Web et smoke tests de production. Les productions automatiques de l'intégration Git sont annulées par `ignoreCommand`, puis une seule production GitHub Actions aboutit par projet. Les runs 29747228594 et 29747592571 restent des preuves historiques du même protocole avant la correction finale de reflow.

Quota de génération du jury

Le quota s'applique uniquement à la session Auth.js identifiée comme accès jury. Les comptes Google restent illimités. Il autorise 30 générations réussies au total, avec un compteur unique partagé par `/generate` et `/programs/generate`. Le compteur est stocké dans PostgreSQL et ne dépend donc pas de l'instance Vercel qui traite la requête.

La réservation d'une unité est atomique et précède l'appel à l'IA. La 31e demande reçoit un refus HTTP 429, y compris en cas de concurrence. La suppression ultérieure d'une séance ou d'un programme ne rembourse pas une génération réussie. Un échec de l'appel IA ou de l'enregistrement en base libère en revanche la réservation afin de ne pas pénaliser le jury pour une erreur technique. Le test d'intégration PostgreSQL dédié lance 31 réservations concurrentes et vérifie 30 acceptations pour un refus.

La contre-recette navigateur de production a effectué une génération de validation et vérifié l'affichage de 29 générations restantes sur l'interface jury.

Deploiement manuel Vercel

Cette procédure est réservée au diagnostic ou à une intervention d'urgence autorisée. Elle ne doit pas servir à contourner la CI ni à constituer la preuve de la version remise ; le chemin nominal reste le workflow CD après CI verte.

Depuis la racine du depot:

```
pnpm install --frozen-lockfile
pnpm build
```

API:

```
cd apps/api
vercel pull --yes --environment=production
vercel build --prod
vercel deploy --prebuilt --prod
```

Web:

```
cd apps/web
vercel pull --yes --environment=production
vercel build --prod
vercel deploy --prebuilt --prod
```

Migrations Neon

Dans le chemin nominal, le job `migrate-db` du workflow CD - Vercel applique les migrations avant le déploiement API. Pour une reprise autorisée ou une migration isolée, lancer le workflow manuel DB - Drizzle migrations.

En local, uniquement si `DATABASE_URL` pointe volontairement vers la cible:

```
pnpm install --frozen-lockfile
pnpm db:migrate
```


Verification post-déploiement

```
curl https://ai-sport-api.vercel.app/health
curl https://ai-sport-api.vercel.app/health/ready
curl https://ai-sport-web.vercel.app/api/health
curl -I https://ai-sport-web.vercel.app
```

Checklist:

- [x] CI verte sur le SHA applicatif livré
- [x] Migrations Drizzle appliquées par la CD
- [x] SERVICE_SECRET cohérent côté Web et API, prouvé par les smoke tests service-to-service
- [x] OAuth Google démarre avec le callback `https://ai-sport-web.vercel.app/api/auth/callback/google`
- [x] API liveness et readiness HTTP 200 après déploiement
- [x] Web healthcheck HTTP 200 après déploiement
- [x] Génération d'une séance testée avec un compte authentifié, puis donnée de recette supprimée (B2-A25)
- [x] Génération d'un programme testée avec un compte authentifié, puis donnée de recette supprimée (B2-A25)
- [x] Quota jury persistant affiché à 29/30 après une génération de validation
- [x] 31 réservations concurrentes testées sur PostgreSQL : 30 acceptées, 1 refusée
- [x] 267 tests unitaires/composants verts (shared 14, API 179, Web 74), intégration PostgreSQL dédiée et E2E verts
- [x] run CI automatique vert sur la baseline applicative livrée (29994929981)
- [x] run CD automatique vert sur la baseline applicative livrée (29995297354)
- [x] zoom natif 200/400 % contre-recetté en production, 16/16, puis suite

d'accessibilité rejouée, 33/33

Alternative Docker Compose

Pour une démonstration locale ou un auto-hebergement:

```
cp .env.example .env
## Remplacer OPENAI_API_KEY, SERVICE_SECRET et les secrets OAuth de démonstration.
docker compose up -d postgres
docker compose --profile tools run --rm migrate
docker compose --profile tools run --rm seed # facultatif
docker compose up --build -d
```

Les commandes de migration et de seed utilisent des services outillage basés sur le stage Docker builder. Elles ne sont pas exécutées dans l'image API de production, qui ne contient volontairement ni `drizzle-kit`, ni `tsx`, ni les sources TypeScript.

URLs locales:

Service	URL
Web	<code>http://localhost:3000</code>
API	<code>http://localhost:3001</code>
PostgreSQL	<code>localhost:5432</code>

Alternative Fly.io pour l'API

Le fichier `apps/api/fly.toml` reste disponible. Depuis la racine:

```
fly deploy --config apps/api/fly.toml --remote-only .
```

Secrets Fly requis:

```
DATABASE_URL
OPENAI_API_KEY
SERVICE_SECRET
FRONTEND_URL=https://ai-sport-web.vercel.app
NODE_ENV=production
```

DOC-02 - Manuel utilisateur complet

1. Présentation

Alcide est une application web de coaching sportif assisté par IA. Elle permet à un utilisateur connecté de générer des séances ou programmes sportifs personnalisés, de les consulter, de suivre une séance avec timer et d'observer sa progression.

Public cible :

- sportif débutant, intermédiaire ou avancé ;
- coach ou utilisateur souhaitant préparer rapidement une séance ;
- jury RNCP pendant la démonstration.

2. Accéder à l'application

URL de production : <https://ai-sport-web.vercel.app>.

Accès temporaire du jury

1. Ouvrir l'URL de production puis /login.
2. Dans la section Accès jury, saisir l'identifiant et le mot de passe remis dans l'édition PDF confidentielle.
3. Cliquer sur Ouvrir l'espace de démonstration.
4. Vérifier l'arrivée sur /generate, puis parcourir les fonctionnalités.
5. À la fin du test, utiliser Se déconnecter.

Cet accès crée une véritable session Auth.js associée à un utilisateur de démonstration isolé. Il ne contourne ni la protection des routes, ni les contrôles d'ownership de l'API. Il est temporaire : son expiration, sa désactivation, la rotation de son secret ou le renouvellement de sa version de session invalident les sessions déjà ouvertes. Avant toute réactivation, la version de session doit être renouvelée pour empêcher la réutilisation d'un ancien cookie.

Le compte jury dispose de **30 générations réussies au maximum**, partagées entre les séances et les programmes. Les pages /generate et /programs/generate affichent le même nombre de générations restantes. Ce compteur est conservé entre les connexions et les appareils :

- une séance ou un programme généré avec succès consomme une unité ;
- une erreur IA ou d'enregistrement ne consomme pas définitivement l'unité ;
- supprimer ensuite une séance ou un programme ne restitue pas l'unité ;
- à zéro, les formulaires indiquent Quota jury atteint et toute nouvelle demande est refusée ;
- cette limite ne concerne pas les comptes connectés avec Google.

Accès utilisateur avec Google

1. Depuis la page d'accueil, cliquer sur le bouton de connexion.
2. Choisir la connexion Google.
3. Autoriser l'application.
4. Après connexion, l'utilisateur accède aux fonctionnalités protégées.

Si l'utilisateur tente d'accéder directement à une page protégée sans session, il est redirigé vers la page de connexion.

3. Générer une séance d'entraînement

1. Aller sur la page Générer ou /generate.
2. Renseigner le sport souhaité.
3. Choisir le niveau.
4. Indiquer la durée.
5. Décrire les objectifs ou contraintes.
6. Valider le formulaire.

Résultat attendu :

- les champs invalides affichent un message d'erreur ;
- une demande valide crée une séance ;
- l'utilisateur est redirigé vers le détail de la séance.

En cas d'erreur IA ou serveur, un message d'erreur est affiché à l'utilisateur et la génération peut être relancée. Pour le compte jury, l'échec n'est pas décompté définitivement du quota.

4. Générer un programme

1. Aller sur la page de génération de programme.
2. Renseigner l'objectif sportif.
3. Choisir le niveau, la durée et les contraintes.
4. Soumettre le formulaire.

Résultat attendu :

- Alcide génère un programme multi-semaines ;
- le programme peut être consulté depuis la liste des programmes ;
- chaque semaine ou séance peut être consultée dans le détail.

5. Consulter ses séances

1. Aller sur /workouts.
2. Lire les cartes de séances disponibles.
3. Utiliser les filtres par sport ou niveau si nécessaire.
4. Ouvrir une séance pour voir le détail.

La liste affiche uniquement les séances de l'utilisateur connecté.

6. Utiliser le timer

1. Ouvrir le détail d'une séance.
2. Cliquer sur Démarrer.
3. Suivre l'exercice affiché.
4. Utiliser Pause ou Reprendre si nécessaire.
5. Laisser le timer passer automatiquement aux phases suivantes.

Le timer annonce les changements d'état de façon accessible grâce aux zones dynamiques prévues dans l'interface.

7. Terminer et journaliser une séance

Lorsqu'une séance ou session est terminée, l'utilisateur peut renseigner son ressenti lorsque le formulaire est disponible :

- effort perçu ;
- feedback de difficulté ;
- notes de douleur éventuelles ;
- commentaire éventuel.

Ces informations alimentent les statistiques du dashboard.

Les notes de douleur ne constituent pas un diagnostic médical. Elles sont associées au compte connecté et doivent être considérées comme des données personnelles potentiellement sensibles. Consulter la page Confidentialité avant de les renseigner.

8. Consulter le dashboard

1. Cliquer sur Dashboard.

2. Lire les indicateurs principaux :

- séances créées ; - séances terminées ; - temps réalisé ; - effort moyen ; - dernière séance terminée ; - répartition par niveau ; - sports les plus pratiqués.

Si aucune séance n'existe, le dashboard propose de commencer par une première génération.

9. Paramétrer l'IA

La page de paramètres permet uniquement de choisir un modèle OpenAI parmi les modèles proposés. OpenAI est le fournisseur de l'application et la clé API est gérée par l'exploitant côté serveur. L'utilisateur ne peut ni saisir une clé, ni choisir un autre fournisseur.

Si la lecture ou l'enregistrement des paramètres échoue, l'interface affiche une erreur ; elle ne doit pas présenter une valeur de secours comme si elle avait été enregistrée.

10. Supprimer une séance

1. Depuis la liste des séances, cliquer sur l'action de suppression.

2. Confirmer la suppression.

3. Vérifier que la liste est mise à jour.

Si l'utilisateur annule la confirmation, la séance est conservée.

11. Accessibilité utilisateur

L'application prévoit :

- navigation clavier ;
- focus visible ;
- labels de formulaire ;
- messages d'erreur associés aux champs ;
- états de chargement ;
- informations dynamiques pour le timer.

Pour vérifier l'accessibilité en démonstration, utiliser la touche Tab pour parcourir l'interface et contrôler que chaque action reste atteignable.

Le reflow a été contre-recetté en production avec un zoom Chromium natif à 200 % et 400 % sur huit routes, soit 16 contrôles réussis sur 16. Les 166 contextes composites de l'échantillon sont décidés dans B2-A37. Un parcours technique NVDA, les correctifs rc. 5 et la validation NVDA déclarée par l'utilisateur sont consignés dans B2-A41, sans revendication de conformité RGAA exhaustive ni d'appréciation auditive détaillée.

12. Problèmes courants

Problème	Cause possible	Action utilisateur
Redirection vers login	Session absente ou expirée	Se reconnecter
Section Accès jury absente	Accès temporaire désactivé, expiré ou mal configuré	Utiliser Google ou contacter le responsable de la démonstration
Connexion jury impossible	Identifiants invalides, accès expiré ou désactivé	Vérifier le PDF confidentiel puis contacter le responsable de la démonstration, sans multiplier les essais
Génération impossible	IA indisponible, clé absente ou erreur serveur	Réessayer plus tard ou contacter le responsable de la démonstration
Quota jury atteint	30 séances/programmes déjà générés avec succès	Consulter les données déjà créées ; le quota ne se réinitialise pas en supprimant un résultat
Aucun résultat dans la liste	Aucun entraînement créé ou filtre trop restrictif	Réinitialiser les filtres ou générer une séance
Dashboard vide	Aucune séance créée ou terminée	Générer puis exécuter une séance
Accès refusé à une séance	Séance inexistante ou appartenant à un autre utilisateur	Revenir à la liste personnelle

13. Parcours de démonstration recommandé

1. Se connecter.
2. Vérifier le compteur jury identique sur les deux pages de génération.
3. Générer une séance courte.
4. Ouvrir le détail.
5. Démarrer le timer.
6. Revenir à la liste.
7. Filtrer les séances.
8. Ouvrir le dashboard.
9. Montrer la déconnexion.

DOC-03 - Manuel de mise à jour complet

1. Objectif

Ce manuel décrit la procédure de mise à jour d'Alcide pour livrer une nouvelle version applicative sans casser les parcours existants.

Il couvre :

- mise à jour du code ;
- mise à jour des dépendances ;
- migrations de base de données ;
- tests de non-régression ;
- déploiement ;
- vérification post-déploiement ;
- rollback.

2. Préconditions

Avant toute mise à jour :

- travailler sur une branche dédiée ;
- vérifier l'état Git avec `git status --short --branch` ;
- vérifier la version actuelle dans `package.json` ;
- récupérer les dernières modifications avec `git fetch --prune origin` puis `git pull --ff-only origin main` si la branche est `main` ;
- ne jamais modifier une variable secrète réelle dans le dépôt.

3. Mise à jour du code applicatif

1. Créer ou utiliser une branche de travail.
2. Modifier uniquement le périmètre nécessaire.
3. Mettre à jour les tests si le comportement change.
4. Mettre à jour la documentation RNCP si la preuve associée change.
5. Relire le diff :

```
git diff --stat
git diff
```

Critère de validation :

- le diff est cohérent avec l'objectif ;
- aucune modification hors périmètre n'est présente ;
- les preuves RNCP restent alignées avec le code réel.

4. Mise à jour des dépendances

1. Identifier les dépendances à mettre à jour.
2. Lire le changelog des dépendances majeures.
3. Mettre à jour `package.json` ou utiliser l'outil `package manager`.
4. Régénérer le lockfile avec `pnpm`.
5. Lancer les contrôles :

```
pnpm install --frozen-lockfile
pnpm lint
```

```
pnpm typecheck
pnpm test
pnpm test:coverage
pnpm build
pnpm audit --audit-level=low
```

Critère de validation :

- le lockfile est cohérent ;
- aucun test critique ne régresse ;
- aucune vulnérabilité connue à partir du niveau low n'est laissée sans correction ou justification explicite.

5. Migration de base de données

Lorsqu'un changement touche `apps/api/src/db/schema.ts` :

1. Générer la migration :

```
pnpm db:generate
```

2. Relire le fichier de migration généré.
3. Vérifier que la migration est compatible avec les données existantes.
4. Appliquer la migration sur l'environnement cible :

```
pnpm db:migrate
```

5. Vérifier les fonctionnalités concernées.

Pour le quota jury, vérifier en particulier la table `generation_quotas`, sa clé utilisateur et l'atomicité de l'incrément. La migration ne doit ni remettre à zéro un compteur existant, ni appliquer la limite aux comptes Google. Le test d'intégration PostgreSQL concurrent doit confirmer que 30 réservations au maximum sont acceptées.

Critères de prudence :

- éviter les suppressions destructrices non justifiées ;
- prévoir une sauvegarde avant production ;
- documenter tout changement irréversible.

6. Tests de non-régression

Commandes minimales avant livraison :

```
pnpm lint
pnpm typecheck
pnpm test
pnpm test:coverage
pnpm build
```

Commandes recommandées avant dépôt RNCP ou livraison importante :

```
pnpm test:e2e:smoke
$env:E2E_AUTH_EMAIL='adresse-du-compte-dedie@example.com'
$env:E2E_BASE_URL='https://ai-sport-web.vercel.app'
pnpm test:e2e:auth:browser
## Après la connexion Google et le retour sur /generate :
pnpm test:e2e:auth:capture
pnpm test:e2e:authenticated
```

`test:e2e:smoke` couvre le public. La commande authentifiée exige un `storageState Auth.js` réel, local, non committé. La procédure sécurisée complète est décrite dans `docs/testing-authenticated-e2e.md`. `pnpm test:e2e` seul marque la suite authentifiée ignorée si cette variable manque ; il ne prouve donc pas le parcours OAuth. Si les E2E ne sont pas relancés, la documentation doit conserver le statut "à relancer" au lieu d'annoncer une réussite.

7. Mise à jour de version

Pour une version applicative :

1. Mettre à jour la version dans :

- package.json ; - apps/api/package.json ; - apps/web/package.json.

2. Vérifier les fallback de healthcheck :

- apps/api/src/routes/health.routes.ts ; - apps/web/app/api/health/route.ts.

3. Mettre à jour CHANGELOG.md.

4. Vérifier que docs/deployment.md et les documents RNCP ne mentionnent pas une version contradictoire.

Contrôle :

```
rg -n "0\\.12\\.0|version applicative|APP_VERSION|NEXT_PUBLIC_APP_VERSION" `
package.json apps docs README.md CHANGELOG.md`
```

Adapter la recherche selon la nouvelle version.

8. Déploiement

Le déploiement se fait via les workflows et la cible Vercel/Neon documentée.

Contrôles avant déploiement :

- CI verte ;
- migrations prêtes ou non nécessaires ;
- variables d'environnement présentes ;
- build local ou CI réussi ;
- changelog mis à jour.

Contrôles après déploiement :

```
curl https://<api-url>/health
curl https://<api-url>/health/ready
curl https://<web-url>/api/health
```

Puis vérifier manuellement :

1. page d'accueil ;
2. login ;
3. génération ou consultation avec données seedées ;
4. liste des séances ;
5. détail et timer ;
6. dashboard ;
7. avec une session jury, même compteur sur /generate et /programs/generate, puis refus HTTP 429 GENERATION_QUOTA_EXCEEDED lorsque la limite est atteinte.

9. Rollback

Rollback applicatif :

1. Identifier la dernière version stable dans Vercel ou Git.
2. Revenir au déploiement précédent.
3. Vérifier les healthchecks.
4. Relancer un smoke test.
5. Documenter l'incident ou l'écart dans le plan de correction.

Rollback base de données :

- privilégier une sauvegarde/restauration lorsque la migration est destructive ;
- éviter de lancer une migration inverse non testée ;
- ne pas supprimer `generation_quotas` ni réinitialiser ses compteurs sans décision explicite, car une suppression de contenu ne rembourse pas le quota ;
- consigner précisément le changement de schéma et l'impact utilisateur.

10. Traçabilité

Après une mise à jour, documenter :

- version livrée ;
- fichiers principaux modifiés ;
- commandes lancées ;
- résultat des tests ;
- migration ou non ;
- statut du déploiement ;
- anomalies détectées ;
- action de rollback si nécessaire.

Documents à mettre à jour si concernés :

- `CHANGELOG.md`
- `docs/deployment.md`
- `docs/ci-cd.md`
- `docs/bloc2/cahier-recettes.md`
- `docs/rncp/dossier-professionnel-rncp39583.md`
- `docs/rncp/matrice-conformite-rncp39583.md`